

3. Detailed Audit Controls

3.1. Information Technology (IT) Security Guidelines

3.1.1. Implementation of Information Security

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Security Policy							
3.1.1.1	An information security policy document has been formulated that includes physical, personnel, procedural and technical controls and was submitted to the Controller before commencement of operation.	1. Obtain the softcopy/hardcopy of the information security policy 2. Check the following 1. Controller received the policy approved by CA management before commencing operations 2. Policy contains physical, personnel, procedural and technical controls 3. information is classified depending upon its sensitivity for the CA as per IT Act-2000 4. both confidential and non-confidential information addressed in the policy 5. CA has prepared detailed manuals for performing its activities 6. CA ensures security and risk management controls are implemented 7. policy has been approved by CA management. Verify by checking approval date. 8. policy has been communicated to all employees via mail or training	Mandatory	IT CA Rules 19.2	Yes	3.1.1.1-2	

		session 9. Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined 3. verify roles and responsibilities defined 4. Verify the all recent changes done to the policy since last audit 5. For sample recent changes done to the policy validate details were submitted to Controller within two weeks					
3.1.1.2	CA shall ensure the security policy clearly addresses security of both confidential and non-confidential information. The Certifying Authority shall prepare detailed manuals for performing all its activities and shall scrupulously adhere to them.	1. Obtain the softcopy/hardcopy of the information security policy 2. Check the following 1. Controller received the policy approved by CA management before commencing operations 2. Policy contains physical, personnel, procedural and technical controls 3. information is classified depending upon its sensitivity for the CA as per IT Act-2000 4. both confidential and non-confidential information addressed in the policy 5. CA has prepared detailed manuals for performing its activities 6. CA ensures security and risk	Mandatory	WebTrust 3.9.5, IT Regulations 3	No	3.1.1.2-3	

		management controls are implemented 7. policy has been approved by CA management. Verify by checking approval date. 8. policy has been communicated to all employees via mail or training session 9. Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined 3. verify roles and responsibilities defined 4. Verify the all recent changes done to the policy since last audit 5. For sample recent changes done to the policy validate details were submitted to Controller within two weeks					
3.1.1.3	The Certifying Authority shall as approved, in respect of security and risk management controls continuously ensure that security policies and safeguards are in place. Such controls include personnel security and incident handling measures to prevent fraud and security breaches. The security policy shall be approved by management,	1. Obtain the softcopy/hardcopy of the information security policy 2. Check the following 1. Controller received the policy approved by CA management before commencing operations 2. Policy contains physical, personnel, procedural and technical controls 3. information is classified depending upon its sensitivity for the CA as per IT Act-2000 4. both	Mandatory	IT Regulations 3, WebTrust 3.1.1	Yes	3.1.1.3-4	

		confidential and non-confidential information addressed in the policy 5. CA has prepared detailed manuals for performing its activities 6. CA ensures security and risk management controls are implemented 7. policy has been approved by CA management. Verify by checking approval date. 8. policy has been communicated to all employees via mail or training session 9. Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined 3. verify roles and responsibilities defined 4. Verify the all recent changes done to the policy since last audit 5. For sample recent changes done to the policy validate details were submitted to Controller within two weeks					
3.1.1.4	The Certifying Authority shall as approved, in respect of security and risk management controls continuously ensure that security policies and safeguards are in place. Such controls include personnel security and incident handling measures to prevent fraud and	1. Obtain the softcopy/hardcopy of the information security policy 2. Check the following 1. Controller received the policy approved by CA management before commencing	Mandatory	IT Regulations 3, WebTrust 3.1.1			

	security breaches. The security policy shall be approved by management, published and communicated to all employees.	operations 2. Policy contains physical, personnel, procedural and technical controls 3. information is classified depending upon its sensitivity for the CA as per IT Act-2000 4. both confidential and non-confidential information addressed in the policy 5. CA has prepared detailed manuals for performing its activities 6. CA ensures security and risk management controls are implemented 7. policy has been approved by CA management. Verify by checking approval date. 8. policy has been communicated to all employees via mail or training session 9. Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined 3. verify roles and responsibilities defined 4. Verify the all recent changes done to the policy since last audit 5. For sample recent changes done to the policy validate details were submitted to Controller within two weeks						
--	---	--	--	--	--	--	--	--

3.1.1.5	An authorized personnel shall be responsible for ensuring that security procedures within their area of responsibility are carried out correctly	1. Obtain the softcopy/hardcopy of the information security policy 2. Check the following 1. Controller received the policy approved by CA management before commencing operations 2. Policy contains physical, personnel, procedural and technical controls 3. information is classified depending upon its sensitivity for the CA as per IT Act-2000 4. both confidential and non-confidential information addressed in the policy 5. CA has prepared detailed manuals for performing its activities 6. CA ensures security and risk management controls are implemented 7. policy has been approved by CA management. Verify by checking approval date. 8. policy has been communicated to all employees via mail or training session 9. Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities	Mandatory	WebTrust 3.9.8				
---------	--	---	-----------	----------------	--	--	--	--

		defined 3. verify roles and responsibilities defined 4. Verify the all recent changes done to the policy since last audit 5. For sample recent changes done to the policy validate details were submitted to Controller within two weeks						
3.1.1.6	A review process shall be designed for maintaining the security policy. Review dates and responsibilities should be recorded.	1. Obtain the softcopy/hardcopy of the information security policy 2. Check the following 1. Controller received the policy approved by CA management before commencing operations 2. Policy contains physical, personnel, procedural and technical controls 3. information is classified depending upon its sensitivity for the CA as per IT Act-2000 4. both confidential and non-confidential information addressed in the policy 5. CA has prepared detailed manuals for performing its activities 6. CA ensures security and risk management controls are implemented 7. policy has been approved by CA management. Verify by checking approval date. 8. policy has been	Mandatory	WebTrust 3.1.3				

		communicated to all employees via mail or training session 9. Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined 3. verify roles and responsibilities defined 4. Verify the all recent changes done to the policy since last audit 5. For sample recent changes done to the policy validate details were submitted to Controller within two weeks						
3.1.1.7	Any change made by the Certifying Authority in the security policy shall be submitted by it within two weeks to the Controller	1. Obtain the softcopy/hardcopy of the information security policy 2. Check the following 1. Controller received the policy approved by CA management before commencing operations 2. Policy contains physical, personnel, procedural and technical controls 3. information is classified depending upon its sensitivity for the CA as per IT Act-2000 4. both confidential and non-confidential information addressed in the policy 5. CA has prepared detailed manuals for performing its	Mandatory	IT CA Rules 19	Yes	3.1.1.7-8		

		activities 6. CA ensures security and risk management controls are implemented 7. policy has been approved by CA management. Verify by checking approval date. 8. policy has been communicated to all employees via mail or training session 9. Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined 3. verify roles and responsibilities defined 4. Verify the all recent changes done to the policy since last audit 5. For sample recent changes done to the policy validate details were submitted to Controller within two weeks					
3.1.1.8	Test	1. Obtain the softcopy/hardcopy of the information security policy 2. Check the following 1. Controller received the policy approved by CA management before commencing operations 2. Policy contains physical, personnel, procedural and technical controls 3. information is classified depending upon its	Optional	Test			

		sensitivity for the CA as per IT Act-2000 4. both confidential and non-confidential information addressed in the policy 5. CA has prepared detailed manuals for performing its activities 6. CA ensures security and risk management controls are implemented 7. policy has been approved by CA management. Verify by checking approval date. 8. policy has been communicated to all employees via mail or training session 9. Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined 3. verify roles and responsibilities defined 4. Verify the all recent changes done to the policy since last audit 5. For sample recent changes done to the policy validate details were submitted to Controller within two weeks						
3.1.1.9	Test2	1. Obtain the softcopy/hardcopy of the information security policy 2. Check the following 1. Controller received the policy approved by	Optional	Hello				

		CA management before commencing operations 2. Policy contains physical, personnel, procedural and technical controls 3. information is classified depending upon its sensitivity for the CA as per IT Act-2000 4. both confidential and non-confidential information addressed in the policy 5. CA has prepared detailed manuals for performing its activities 6. CA ensures security and risk management controls are implemented 7. policy has been approved by CA management. Verify by checking approval date. 8. policy has been communicated to all employees via mail or training session 9. Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined 3. verify roles and responsibilities defined 4. Verify the all recent changes done to the policy since last audit 5. For sample recent changes done to the policy validate details						
--	--	--	--	--	--	--	--	--

		were submitted to Controller within two weeks						
Self-Assessment								
3.1.1.10	A documented security self-assessment plan shall be prepared by the CA	1. Obtain the self-assessment plan developed by the CA 2. Verify on a sample basis the for last two self-assessments conducted 3. Collect report of the self-assessment plan 4. Check the following: a. Findings of self-assessment were shared with the management b. Action was taken to address the finding	Mandatory	IT CA Rules 2.e				
3.1.1.11	Self-Assessment shall be performed on a periodic basis and the findings shall be reported to management and discussed for closure	1. Obtain the self-assessment plan developed by the CA 2. Verify on a sample basis the for last two self-assessments conducted 3. Collect report of the self-assessment plan 4. Check the following: a. Findings of self-assessment were shared with the management b. Action was taken to address the finding	Mandatory	IT CA Rules 2.e				
Risk Assessment								
3.1.1.12	The CA's security program shall include an annual Risk Assessment	1. Obtain copy of annual Risk Assessment plan 2. Check the following: a. Threats are identified and documented as part of risk assessment b. Standard operating procedures are present for combating threats. c. controls are in place to prevent misuse, alteration and destruction of sensitive information d. adequate cyber security tools are implemented by the CA such as DLP, Web Gateway, Email Gateway, Proxy Servers, and Firewalls, SSL/TLS, IDS/IPS, SAST, DAST, etc. e. a vulnerability assessment by the above mentioned tools are carried out at a pre decided interval. Report any scheduled VA left out. f. security plan has been developed g. updates and patches are applied in timely manner	Mandatory	IT CA Rules SCHEDULE-II 17.3 CA Browser Forum 5				

		3. Check the security plan covers the following safeguards: a. administrative, b. organizational, c. technical, and d. physical 4. Verify formal change management procedures have been developed						
3.1.1.13	A list of foreseeable internal and external threats that could result in unauthorized access, disclosure, misuse, alteration, or destruction of any critical information shall be maintained.	1. Obtain copy of annual Risk Assessment plan 2. Check the following: a. Threats are identified and documented as part of risk assessment b. Standard operating procedures are present for combating threats. c. controls are in place to prevent misuse, alteration and destruction of sensitive information d. adequate cyber security tools are implemented by the CA such as DLP, Web Gateway, Email Gateway, Proxy Servers, and Firewalls, SSL/TLS, IDS/IPS, SAST, DAST, etc. e. a vulnerability assessment by the above mentioned tools are carried out at a pre decided interval. Report any scheduled VA left out. f. security plan has been developed g. updates and patches are applied in timely manner 3. Check the security plan covers the following safeguards: a. administrative, b. organizational, c. technical, and d. physical 4. Verify formal change management procedures have been developed	Mandatory	CA Browser Forum 5				
3.1.1.14	The sufficiency of the policies, procedures, information systems, technology, and other arrangements that the CA has in place to counter cyber threats shall be verified.	1. Obtain copy of annual Risk Assessment plan 2. Check the following: a. Threats are identified and documented as part of risk assessment b. Standard operating procedures are present for combating threats. c. controls are in place to prevent misuse, alteration and destruction of sensitive information d. adequate cyber security tools are implemented by the CA such as DLP, Web Gateway,	Mandatory	CA Browser Forum 5				

		Email Gateway, Proxy Servers, and Firewalls, SSL/TLS, IDS/IPS, SAST, DAST, etc. e. a vulnerability assessment by the above mentioned tools are carried out at a pre decided interval. Report any scheduled VA left out. f. security plan has been developed g. updates and patches are applied in timely manner 3. Check the security plan covers the following safeguards: a. administrative, b. organizational, c. technical, and d. physical 4. Verify formal change management procedures have been developed						
3.1.1.15	A security plan shall be developed covering the following: • Security procedures to manage the risks • administrative, organizational, technical, and physical safeguards • cost of implementing the specific measures • security breach plan in case of any incidents	1. Obtain copy of annual Risk Assessment plan 2. Check the following: a. Threats are identified and documented as part of risk assessment b. Standard operating procedures are present for combating threats. c. controls are in place to prevent misuse, alteration and destruction of sensitive information d. adequate cyber security tools are implemented by the CA such as DLP, Web Gateway, Email Gateway, Proxy Servers, and Firewalls, SSL/TLS, IDS/IPS, SAST, DAST, etc. e. a vulnerability assessment by the above mentioned tools are carried out at a pre decided interval. Report any scheduled VA left out. f. security plan has been developed g. updates and patches are applied in timely manner 3. Check the security plan covers the following safeguards: a. administrative, b. organizational, c. technical, and d. physical 4. Verify formal change management procedures have been developed	Mandatory	CA Browser Forum 5				
3.1.1.16	Hypervisors, operating system, database, and network device patches and updates	1. Obtain copy of annual Risk Assessment plan 2. Check the following: a. Threats are identified and	Mandatory	WebTrust 3.6.18				

	shall be applied in a timely manner when deemed necessary based on a risk assessment and follow formal change management procedures	documented as part of risk assessment b. Standard operating procedures are present for combating threats. c. controls are in place to prevent misuse, alteration and destruction of sensitive information d. adequate cyber security tools are implemented by the CA such as DLP, Web Gateway, Email Gateway, Proxy Servers, and Firewalls, SSL/TLS, IDS/IPS, SAST, DAST, etc. e. a vulnerability assessment by the above mentioned tools are carried out at a pre decided interval. Report any scheduled VA left out. f. security plan has been developed g. updates and patches are applied in timely manner 3. Check the security plan covers the following safeguards: a. administrative, b. organizational, c. technical, and d. physical 4. Verify formal change management procedures have been developed							
Training									
3.1.1.17	The CA shall ensure all personnel performing duties with respect to operation of a CA,ESP, CSP shall receive comprehensive training covering the following: 1. CA/ESP/CSP/RA security principles and mechanisms 2. All PKI software versions in use on the CA system 3. All PKI duties they are expected to perform 4. Disaster recovery and business continuity procedures	1. Obtain the training plan and material for CA employees 2. Check the following: a. All relevant topics are covered in the training material b. Records of training are maintained by CA (e.g. Attendance sheet) c. Refresher training is conducted d. Training is given personnel in case of implementation of every new tool by the CA e. Personnel are trained with the update business continuity policy and procedures at regular intervals f. Training requirements are reviewed at least once a year 3. Obtain list of personnel entrusted with validation specialist duties 4. Check the following a. Validation specialist are trained to maintain required skill level b. All Validation Specialists have passed the examination provided by the CA 5. Obtain list of personnel	Mandatory	X.509 Policy 5.3.3, IT CA Rules SCHEDULE-III.15					

		responsible for trusted roles 6. Check if the changes made in CA, ESP, CSP operations were communicated with individuals responsible for trusted roles 7. Verify only trusted personals are performing verification at all levels						
3.1.1.18	Refresher training must be conducted as and when required, and the Certifying Authority must review these requirements at least once a year. Records of all trainings shall be maintained and reviewed periodically	1. Obtain the training plan and material for CA employees 2. Check the following: a. All relevant topics are covered in the training material b. Records of training are maintained by CA (e.g. Attendance sheet) c. Refresher training is conducted d. Training is given personnel in case of implementation of every new tool by the CA e. Personnel are trained with the update business continuity policy and procedures at regular intervals f. Training requirements are reviewed at least once a year 3. Obtain list of personnel entrusted with validation specialist duties 4. Check the following a. Validation specialist are trained to maintain required skill level b. All Validation Specialists have passed the examination provided by the CA 5. Obtain list of personnel responsible for trusted roles 6. Check if the changes made in CA, ESP, CSP operations were communicated with individuals responsible for trusted roles 7. Verify only trusted personals are performing verification at all levels	Mandatory	IT CA Rules SCHEDULE III 16 CA Browser Forum 5.3.3				
3.1.1.19	CA shall ensure personnel entrusted with Validation Specialist duties maintain a skill level that enables them to perform such duties satisfactoril	1. Obtain the training plan and material for CA employees 2. Check the following: a. All relevant topics are covered in the training material b. Records of training are maintained by CA (e.g. Attendance sheet) c. Refresher training is conducted d. Training is given personnel in case of implementation of every new tool by the CA e. Personnel are trained with the update business continuity policy and procedures at regular intervals f. Training requirements are	Mandatory	CA Browser Forum 5.3.3				

		reviewed at least once a year 3. Obtain list of personnel entrusted with validation specialist duties 4. Check the following a. Validation specialist are trained to maintain required skill level b. All Validation Specialists have passed the examination provided by the CA 5. Obtain list of personnel responsible for trusted roles 6. Check if the changes made in CA, ESP, CSP operations were communicated with individuals responsible for trusted roles 7. Verify only trusted personals are performing verification at all levels						
3.1.1.20	All Validation Specialists shall pass an examination provided by the CA on the information verification requirements	1. Obtain the training plan and material for CA employees 2. Check the following: a. All relevant topics are covered in the training material b. Records of training are maintained by CA (e.g. Attendance sheet) c. Refresher training is conducted d. Training is given personnel in case of implementation of every new tool by the CA e. Personnel are trained with the update business continuity policy and procedures at regular intervals f. Training requirements are reviewed at least once a year 3. Obtain list of personnel entrusted with validation specialist duties 4. Check the following a. Validation specialist are trained to maintain required skill level b. All Validation Specialists have passed the examination provided by the CA 5. Obtain list of personnel responsible for trusted roles 6. Check if the changes made in CA, ESP, CSP operations were communicated with individuals responsible for trusted roles 7. Verify only trusted personals are performing verification at all levels	Mandatory	CA Browser Forum 5.3.3				
3.1.1.21	All individuals responsible for trusted roles shall be made aware of any significant changes in the CA, ESP CSP, or	1. Obtain the training plan and material for CA employees 2. Check the following: a. All relevant topics are covered in the training material b. Records of training are	Mandatory	X.509 Policy 5.3.4 CA Browser Forum 5.3.4				

	RA operations, as applicable.	maintained by CA (e.g. Attendance sheet) c. Refresher training is conducted d. Training is given personnel in case of implementation of every new tool by the CA e. Personnel are trained with the update business continuity policy and procedures at regular intervals f. Training requirements are reviewed at least once a year 3. Obtain list of personnel entrusted with validation specialist duties 4. Check the following a. Validation specialist are trained to maintain required skill level b. All Validation Specialists have passed the examination provided by the CA 5. Obtain list of personnel responsible for trusted roles 6. Check if the changes made in CA, ESP, CSP operations were communicated with individuals responsible for trusted roles 7. Verify only trusted personals are performing verification at all levels						
--	-------------------------------	---	--	--	--	--	--	--

3.1.2. Information Classification

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Information Classification							
3.1.2.1	Documented processes shall be created for classification, declassification, labeling, storage, access, destruction and reproduction of classified data.	1. Obtain copy of the process for handling classified data 2. Check the following a. procedure exists for classifying data based on its sensitivity for the CA b. procedures exist for destruction, access and reproduction of data c. Information is labeled in accordance with CA's information classification documented procedures	Mandatory	IT CA Rules 19.1, WebTrust	Yes	3.1.2.1-21	
3.1.2.2	CA shall ensure information labeling and handling are performed in accordance with	1. Obtain copy of the process for handling classified data	Mandatory	WebTrust 3.2.4	Yes	3.1.2.2-22	

	the CA's information classification documented procedures basis following categories: • Confidential • Restricted • Internal • Unclassified • Top Secret • Secret • Confidentiality • Restricted • Unclassified	2. Check the following a. procedure exists for classifying data based on its sensitivity for the CA b. procedures exist for destruction, access and reproduction of data c. Information is labeled in accordance with CA's information classification documented procedures					
--	--	---	--	--	--	--	--

3.1.3. Information Management

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
System Administration							
3.1.3.1	The CA shall designate a trained "System Administrators" who will ensure that the protective security measures of the system are functional and who will maintain the security posture of CA's organization	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active	Mandatory	IT CA Rules SCHEDULE-II 5.1			

		Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active					
3.1.3.2	The System Administrator may have a designated System Security Administrator who will assume security responsibilities and provide physical, logical and procedural safeguards for information	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security	Mandatory	IT CA Rules SCHEDULE-II 5.1			

		Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active						
3.1.3.3	CA shall ensure System Security Administrator is properlytrained before	1. Obtain the name of system administrator appointed by the CA	Mandatory	IT CA Rules SCHEDULE-II 5.1				

	assigning the system security responsibilities	2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done.						
--	---	---	--	--	--	--	--	--

		10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active						
3.1.3.4	System Administrator shall solely be responsible for creating, classifying, and retrieving, modifying, deleting or archiving information.	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system	Mandatory	IT CA Rules SCHEDULE-II 5.1				

		access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active					
3.1.3.5	The system administration's password and operation of trusted services must not be written down (in paper or electronic form) or shared with anyone.	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to	Mandatory	IT CA Rules SCHEDULE-II 5.1			

		another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active					
3.1.3.6	A system for password management should be put in place to cover the eventualities such as forgotten password or changeover to another person in case of System Administrator (or System Security Administrator) leaving the organization. Every instance of usage of administrator's passwords must be documented.	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator	Mandatory	IT CA Rules SCHEDULE-II 5.1			

		with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is						
--	--	---	--	--	--	--	--	--

		enabled or active						
3.1.3.7	The System Administrator shall promptly disable access to a user's account if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access. Reactivation of the user's account must be authorized in writing by the System Administrator (Digitally signed E-mail may be acceptable)	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of	Mandatory	IT CA Rules SCHEDULE-II 5.1				

		security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active						
3.1.3.8	The System Administrator must take steps to safeguards classified information as prescribed by its owner.	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator	Mandatory	IT CA Rules SCHEDULE-II 5.1				

		promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active					
3.1.3.9	The System Administrator must authorize privileged access to users only on a need-to-know and need-to-do basis and also only after the authorization is documented.	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the	Mandatory	IT CA Rules SCHEDULE-II 5.1			

		password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active					
3.1.3.10	All security violations must be recorded, investigated, and periodic status reports compiled for review by the management	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator	Mandatory	IT CA Rules SCHEDULE-II 5.1			

		have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously						
--	--	---	--	--	--	--	--	--

		11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active						
3.1.3.11	The System Administrator together with the system support staff, shall conduct a regular analysis of problems reported to and identify any weaknesses in protection of the information	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-	Mandatory	IT CA Rules SCHEDULE-II 5.1				

		do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active						
3.1.3.12	The System Administrator shall ensure that the data, file and Public Key Infrastructure (PKI) servers are not left unmonitored while these systems are powered on	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is	Mandatory	IT CA Rules SCHEDULE-II 5.1				

		documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active						
3.1.3.13	The System Administrator should ensure that no generic user is enabled or active on the system	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security	Mandatory	IT CA Rules SCHEDULE-II 5.1				

		Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active						
Sensitive Information Control								

3.1.3.14	Electronic communication systems, such as router, switches, network device and computers, used for transmission of sensitive information should be equipped or installed with suitable security software and if necessary with an encryptor or encryption software. The appropriate procedure in this regard shall be documented	1. Obtain documented procedure to ensure safety of communication systems 2. Obtain list of communication systems (i.e. router, switches & computers) used for transmission of sensitive information 3. Verify security implementation in devices is done as per the procedure	Mandatory	IT CA Rules SCHEDULE-II 5.2				
3.1.3.15	The Certifying Authority shall manage its functions in accordance with the levels of integrity and security approved by the Controller from time to time	1. Verify the CA manages its functions in accordance with the levels of integrity and security approved by the Controller from time to time. 2. Validate the CA discloses information on the assurance levels of certificates that it issues and the limitations of its liabilities to each of its subscribers and relying parties	Mandatory	IT Regulations 3				
3.1.3.16	The Certifying Authority shall disclose information on the assurance levels of the certificates that it issues and the limitations of its liabilities to each of its subscribers and relying parties	1. Verify the CA manages its functions in accordance with the levels of integrity and security approved by the Controller from time to time. 2. Validate the CA discloses information on the assurance levels of certificates that it issues and the limitations of its liabilities to each of its subscribers and relying parties	Mandatory	IT Regulations 3				
Sensitive Information Security								
3.1.3.17	Highly sensitive information assets shall be stored on secure removable media and should be in an encrypted format to avoid compromise by unauthorized persons.	1. Refer the Process for handling classified data 2. Verify Highly sensitive information assets is stored on secure removable media and is in encrypted format 3. Verify highly sensitive information	Mandatory	T CA Rules SCHEDULE-II 5.3				

		is classified in accordance as per Control No. 3.1.2.1 4. Validate access control mechanism exist for cases where multiple people have access to sensitive information and data 5. Conduct a walkthrough to verify removable electronic storage media is removed from the computer and properly secured at the end of the work session or workday						
3.1.3.18	Highly sensitive information shall be classified in accordance as per Control No. 3.1.2.1	1. Refer the Process for handling classified data 2. Verify Highly sensitive information assets is stored on secure removable media and is in encrypted format 3. Verify highly sensitive information is classified in accordance as per Control No. 3.1.2.1 4. Validate access control mechanism exist for cases where multiple people have access to sensitive information and data 5. Conduct a walkthrough to verify removable electronic storage media is removed from the computer and properly secured at the end of the work session or workday	Mandatory	IT CA Rules SCHEDULE-II 5.3				
3.1.3.19	Sensitive information and data, which are stored on the fixed disk of a computer shared by more than one person, must be protected by access control software (e.g., password). Security packages must be installed which partition or provide authorization to segregated directories/files.	1. Refer the Process for handling classified data 2. Verify Highly sensitive information assets is stored on secure removable media and is in encrypted format 3. Verify highly sensitive information is classified in accordance as per Control No. 3.1.2.1	Mandatory	IT CA Rules SCHEDULE-II 5.3				

		4. Validate access control mechanism exist for cases where multiple people have access to sensitive information and data 5. Conduct a walkthrough to verify removable electronic storage media is removed from the computer and properly secured at the end of the work session or workday						
3.1.3.20	Removable electronic storage media must be removed from the computer and properly secured at the end of the work session or workday.	1. Refer the Process for handling classified data 2. Verify Highly sensitive information assets is stored on secure removable media and is in encrypted format 3. Verify highly sensitive information is classified in accordance as per Control No. 3.1.2.1 4. Validate access control mechanism exist for cases where multiple people have access to sensitive information and data 5. Conduct a walkthrough to verify removable electronic storage media is removed from the computer and properly secured at the end of the work session or workday	Mandatory	IT CA Rules SCHEDULE-II 5.3				
Prevention of Computer Misuse								
3.1.3.21	The computer system shall be configured with minimum of the required accounts and network services.	1. For sample computer system verify configuration is done with minimum of the required accounts and network services. 2. Validate systems are not working on default settings 3. Obtain documented measures for safeguard the security of computers and computer information from misuse 4. Check the	Mandatory	X.509 Policy 6.5.1				

		following: a. Implementation of measures for safeguarding computers and information from misuse b. Breach reporting process and remedial measures taken c. All incidents are reported to System Administrator d. Procedure to prevent future occurrence of an incident						
3.1.3.22	Prevention, detection, and deterrence measures shall be implemented to safeguard the security of computers and computer information from misuse. The measures taken shall be properly documented and reviewed regularly.	1. For sample computer system verify configuration is done with minimum of the required accounts and network services. 2. Validate systems are not working on default settings 3. Obtain documented measures for safeguard the security of computers and computer information from misuse 4. Check the following: a. Implementation of measures for safeguarding computers and information from misuse b. Breach reporting process and remedial measures taken c. All incidents are reported to System Administrator d. Procedure to prevent future occurrence of an incident	Mandatory	IT CA Rules SCHEDULE-II 5.5				
3.1.3.23	CA shall ensure adequate information is provided to all persons, including management, systems developers and programmers, end-users, and third party users warning them against misuse of computers.	1. For sample computer system verify configuration is done with minimum of the required accounts and network services. 2. Validate systems are not working on default settings 3. Obtain documented measures for safeguard the security	Mandatory	IT CA Rules SCHEDULE-II 5.5				

		of computers and computer information from misuse 4. Check the following: a. Implementation of measures for safeguarding computers and information from misuse b. Breach reporting process and remedial measures taken c. All incidents are reported to System Administrator d. Procedure to prevent future occurrence of an incident						
3.1.3.24	Effective measures including reporting of suspected breach, investigation and remedial measures shall be established	1. For sample computer system verify configuration is done with minimum of the required accounts and network services. 2. Validate systems are not working on default settings 3. Obtain documented measures for safeguard the security of computers and computer information from misuse 4. Check the following: a. Implementation of measures for safeguarding computers and information from misuse b. Breach reporting process and remedial measures taken c. All incidents are reported to System Administrator d. Procedure to prevent future occurrence of an incident	Mandatory	IT CA Rules SCHEDULE-II 5.5				
3.1.3.25	All incidents related to breaches shall be reported to the System Administrator or System Security Administrator for appropriate action to prevent future occurrence. These will be responsible for investigation and	1. For sample computer system verify configuration is done with minimum of the required accounts and network services. 2. Validate systems are not working on	Mandatory	IT CA Rules SCHEDULE-II 5.5				

	follow up action	default settings 3. Obtain documented measures for safeguard the security of computers and computer information from misuse 4. Check the following: a. Implementation of measures for safeguarding computers and information from misuse b. Breach reporting process and remedial measures taken c. All incidents are reported to System Administrator d. Procedure to prevent future occurrence of an incident						
3.1.3.26	Procedure shall be set-up to establish the nature of any alleged abuse and determine the subsequent action required to be taken to prevent its future occurrence	1. For sample computer system verify configuration is done with minimum of the required accounts and network services. 2. Validate systems are not working on default settings 3. Obtain documented measures for safeguard the security of computers and computer information from misuse 4. Check the following: a. Implementation of measures for safeguarding computers and information from misuse b. Breach reporting process and remedial measures taken c. All incidents are reported to System Administrator d. Procedure to prevent future occurrence of an incident	Mandatory	IT CA Rules SCHEDULE-II 5.5				

3.1.4. Physical and Operational security

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Site Location & Design							

3.1.4.1	The location and construction of the facility housing CA and Certificate Status Provider (CSP) equipment shall be consistent with facilities used to house high value, sensitive information. The site shall not be in locations that are prone to natural or man-made disasters, like flood, fire, chemical contamination and explosions	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper- evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information	Mandatory	X.509 Policy 5.1.1, IT CA Rules SCHEDULE-III 3.1					
---------	--	---	-----------	--	--	--	--	--	--

		7. Verify measures CA has implemented to keep the location of DSC system hidden						
3.1.4.2	Construction shall be done in compliance with all applicable building and safety regulations as laid down by the relevant Government agencies with use of fire resistant material and non-toxic chemicals.	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper- evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation	Mandatory	IT CA Rules SCHEDULE-II 4.1.3				

		and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden						
3.1.4.3	CA Shall ensure all external walls shall be constructed of brick or reinforced concrete of sufficient thickness to resist forcible attack. Ground level windows shall be fortified with sturdy mild steel grills or impact-resistant laminated security glass. All internal walls must be from the floor to the ceiling and must be tamper-evident	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper- evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control	Mandatory	IT CA Rules SCHEDULE-II 4.1.5				

		rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden						
3.1.4.4	Air-conditioning system, power supply system and uninterrupted power supply unit with proper backup shall be installed depending upon the nature of operation. All ducting holes of the air-conditioning system must be designed so as to prevent intrusion of any kind.	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper- evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in	Mandatory	IT CA Rules SCHEDULE-II 4.1.6				

		separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden						
3.1.4.5	Media library, electrical and mechanical control rooms shall be housed in separate isolated areas, with access granted only to specific, named individuals on a need basis	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper- evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of	Mandatory	IT CA Rules SCHEDULE-II 4.1.8				

		power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden						
3.1.4.6	Any facility that supports mission-critical and sensitive applications must be located and designed for reparability, relocation and reconfiguration. The ability to relocate, reconstitute and reconfigure these applications must be tested as part of the business continuity/disaster recovery plan.	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper- evident	Mandatory	IT CA Rules SCHEDULE-II 4.1.9				

		d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden					
3.1.4.7	All removable media and papers containing sensitive or plain text information shall be listed, documented and stored in a container properly identified in the CA Facilit	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or	Mandatory	IT CA Rules SCHEDULE-III 3.3			

		reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper- evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden					
3.1.4.8	CA shall ensure exact location of Digital Signature Certification System shall not be publicly identified	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety	Mandatory	IT CA Rules SCHEDULE-III 3.3			

		regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper- evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden							
Fire Protection									
3.1.4.9	No combustible materials shall be stored within hundred meters of the operational site	1. Conduct walkthrough to check the following: a. No combustible materials is stored	Mandatory	IT CA Rules SCHEDULE-II 4.2					

		within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly pasted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis					
3.1.4.10	Automatic fire detection, fire suppression systems and audible alarms as prescribed by the Fire Brigade or any other agency of the Central or State Government shall be installed at the operational site	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and	Mandatory	IT CA Rules SCHEDULE-II 4.2			

		smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly posted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis						
3.1.4.11	Fire extinguishers shall be installed at the operational site and their locations clearly marked with appropriate signs	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly posted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis	Mandatory	IT CA Rules SCHEDULE-II 4.2				
3.1.4.12	Periodic testing, inspection and maintenance of the fire	1. Conduct walkthrough to check the following:	Mandatory	IT CA Rules SCHEDULE-II 4.3				

	equipment and fire suppression systems should be carried out.	a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly pasted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis						
3.1.4.13	There shall be no eating, drinking or smoking in the operational site	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems	Mandatory	IT CA Rules SCHEDULE-II 4.2				

		are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly pasted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis						
3.1.4.14	The work areas shall be kept clean at all times.	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly pasted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis	Mandatory	IT CA Rules SCHEDULE-II 4.2				
3.1.4.15	Procedures for the safe	1. Conduct	Mandatory	IT CA Rules SCHEDULE-				

	evacuation of personnel in an emergency shall be visibly posted/displayed at prominent places at the operational site	walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly posted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis		II 4.2				
3.1.4.16	Periodic training and fire drills shall be conducted	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire	Mandatory	IT CA Rules SCHEDULE-II 4.2				

		equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly pasted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis						
3.1.4.17	Fire doors exist on security perimeters around CA operational facilities and are alarmed and conform to local fire regulations.	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly pasted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis	Mandatory	WebTrust 3.4.6				

Physical Access								
3.1.4.18	Responsibilities round the clock, seven days a week, three hundred sixty five days a year for physical security of the systems used for operation and also actual physical layout at the site of operation shall be defined and assigned to named individuals	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited to authorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in the operation h. A manned reception	Mandatory	IT CA Rules SCHEDULE-II 4.4, CA Browser Forum 5.1.2				

		area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system						
3.1.4.19	All Certifying Authority personnel must have their identity and authorization verified before they are included in the access list for physical access to the Certifying Authority's system. All personnel are required to wear visible identification. Employees are encouraged to challenge anyone not wearing visible identification	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the	Mandatory	WebTrust 3.4.9 IT CA Rules SCHEDULE-				

		register/list maintained for same g. Physical access to CA facilities and equipment is limited to authorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in the operation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system					
3.1.4.20	Dual control over the inventory and issue of access cards/keys during normal business hours to the Data Centre shall be in place.	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on	Mandatory	IT CA Rules SCHEDULE-II 4.4			

		sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited to authorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in the operation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system						
3.1.4.21	Entrance to the main	1. Obtain copy of the	Mandatory	IT CA Rules SCHEDULE-III 3.5				

	building where the Certifying Authority's facilities such as Data Centre, PKI Server and Network devices are housed and entrance to each security zone shall be video recorded round the clock. The recording must be carefully scrutinized and maintained for at least one year	responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited to authorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in the operation h. A manned reception area is present at operational site i. Unescorted access to						
--	---	--	--	--	--	--	--	--

		server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system						
3.1.4.22	Biometric physical access security systems shall be installed to control and audit access to the operational site	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to	Mandatory	IT CA Rules SCHEDULE-II 4.4				

		CA facilities and equipment is limited to authorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in the operation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system					
3.1.4.23	Unauthorized intrusion shall be manually or electronically monitored at all times at the CAs Site	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each	Mandatory	IT CA Rules SCHEDULE-II 3.4.6			

		year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited to authorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in the operation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system						
3.1.4.24	Physical access to CA facilities and equipment should be limited to authorized individuals,	1. Obtain copy of the responsibilities assigned for physical security and verify	Mandatory	WebTrust 4.8.3, IT CA Rules SCHEDULE-II 4.4				

	protected through restricted security perimeters, and shall be operated under multiple person (at least dual custody) control. Personnel authorized for limited physical access shall not be allowed to gain unauthorized access to restricted area within operational site	individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited to authorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in the operation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access						
--	--	--	--	--	--	--	--	--

		list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system						
3.1.4.25	A manned reception area or other means to control physical access should be present at the CA operations site	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited to authorized	Mandatory	WebTrust 3.4.3				

		individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in the operation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system					
3.1.4.26	Unescorted access to Certifying Authority's server shall be limited to those personnel identified on an access list	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized	Mandatory	IT CA Rules SCHEDULE-III 3.3			

		and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited to authorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in the operation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system					
3.1.4.27	Access security system shall be installed to control and audit details of personnel using the Digital Signature Certification System.	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct	Mandatory	IT CA Rules SCHEDULE-III 3.6			

		walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited to authorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in the operation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed						
--	--	---	--	--	--	--	--	--

		j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system						
3.1.4.28	An inventory of access cards shall be maintained by the CA and periodically reviewed	1. Verify the CA maintains and inventory of access cards and reviews it periodically 2. Obtain the up-to-date list of personnel who possess cards/keys 3. Verify the list is updated regularly and archived for a period of three years 4. Validate the process followed in case of loss of access cards, check list of cases where cards were lost and verify if the process was followed. 5. Conduct a walkthrough to check the following: a. Any personnel not on access list is escorted at all times within the operational site b. All individuals, other than operations staff, sign in and sign out of the operational site and are accompanied by operations staff. Verify by checking register/log where entries have been made. c. All personnel entering and leaving CA operational facilities are logged. Verify by checking the physical register or electronic media used for logging. d. CA operational facility has security zones laid out within the facility. Verify the documented proof for zoning performed. e. Access rights to all	Mandatory	IT CA Rules SCHEDULE-III 3.7				

		security zones are laid out. Verify by checking the access list for various security zones f. Security zones are separate from the other by floor to ceiling concrete reinforced walls. Conduct physical walkthrough of the zones to ascertain the same 6. Collect site access log and verify all entries are recorded and inspected periodically						
3.1.4.29	An up-to-date list of personnel who possess the cards/keys shall be regularly maintained and archived for a period of three years. Loss of access cards/keys shall be reported immediately to the Security Administrator; who shall take appropriate actions to prevent unauthorized access.	1. Verify the CA maintains and inventory of access cards and reviews it periodically 2. Obtain the up-to-date list of personnel who possess cards/keys 3. Verify the list is updated regularly and archived for a period of three years 4. Validate the process followed in case of loss of access cards, check list of cases where cards were lost and verify if the process was followed. 5. Conduct a walkthrough to check the following: a. Any personnel not on access list is escorted at all times within the operational site b. All individuals, other than operations staff, sign in and sign out of the operational site and are accompanied by operations staff. Verify by checking register/log where entries have been made. c. All personnel entering and leaving CA operational facilities are logged. Verify by checking the physical register or electronic media used for logging. d. CA operational facility has security	Mandatory	IT CA Rules SCHEDULE-III 3.8				

		zones laid out within the facility. Verify the documented proof for zoning performed. e. Access rights to all security zones are laid out. Verify by checking the access list for various security zones f. Security zones are separate from the other by floor to ceiling concrete reinforced walls. Conduct physical walkthrough of the zones to ascertain the same 6. Collect site access log and verify all entries are recorded and inspected periodically						
3.1.4.30	Any personnel not on the access list shall be properly escorted and supervised at all times within the operational site premises. All individuals, other than operations staff, shall sign in and sign out of the operational site and shall be accompanied by operations staff.	1. Verify the CA maintains and inventory of access cards and reviews it periodically 2. Obtain the up-to-date list of personnel who possess cards/keys 3. Verify the list is updated regularly and archived for a period of three years 4. Validate the process followed in case of loss of access cards, check list of cases where cards were lost and verify if the process was followed. 5. Conduct a walkthrough to check the following: a. Any personnel not on access list is escorted at all times within the operational site b. All individuals, other than operations staff, sign in and sign out of the operational site and are accompanied by operations staff. Verify by checking register/log where entries have been made. c. All personnel entering and leaving CA operational facilities are logged. Verify by checking the	Mandatory	IT CA Rules IT CA Rules SCHEDULE-III 3.9, SCHEDULE II 4.4				

		physical register or electronic media used for logging. d. CA operational facility has security zones laid out within the facility. Verify the documented proof for zoning performed. e. Access rights to all security zones are laid out. Verify by checking the access list for various security zones f. Security zones are separate from the other by floor to ceiling concrete reinforced walls. Conduct physical walkthrough of the zones to ascertain the same 6. Collect site access log and verify all entries are recorded and inspected periodically						
3.1.4.31	A site access log shall be maintained at the Certifying Authority's operational site and inspected periodically. All personnel entering and leaving CA operational facilities shall be logged (i.e., an audit trail of all access is securely maintained).	1. Verify the CA maintains and inventory of access cards and reviews it periodically 2. Obtain the up-to-date list of personnel who possess cards/keys 3. Verify the list is updated regularly and archived for a period of three years 4. Validate the process followed in case of loss of access cards, check list of cases where cards were lost and verify if the process was followed. 5. Conduct a walkthrough to check the following: a. Any personnel not on access list is escorted at all times within the operational site b. All individuals, other than operations staff, sign in and sign out of the operational site and are accompanied by operations staff. Verify by checking register/log where entries have been made.	Mandatory	WebTrust 3.4.11, IT CA Rules SCHEDULE III 3.3				

		c. All personnel entering and leaving CA operational facilities are logged. Verify by checking the physical register or electronic media used for logging. d. CA operational facility has security zones laid out within the facility. Verify the documented proof for zoning performed. e. Access rights to all security zones are laid out. Verify by checking the access list for various security zones f. Security zones are separate from the other by floor to ceiling concrete reinforced walls. Conduct physical walkthrough of the zones to ascertain the same 6. Collect site access log and verify all entries are recorded and inspected periodically						
3.1.4.32	A multi-tiered access mechanism must be installed at the Certifying Authority's operational site. The facility should have clearly laid out security zones within its facility with well-defined access rights to each security zone.	1. Verify the CA maintains and inventory of access cards and reviews it periodically 2. Obtain the up-to-date list of personnel who possess cards/keys 3. Verify the list is updated regularly and archived for a period of three years 4. Validate the process followed in case of loss of access cards, check list of cases where cards were lost and verify if the process was followed. 5. Conduct a walkthrough to check the following: a. Any personnel not on access list is escorted at all times within the operational site b. All individuals, other than operations staff, sign in and sign out of the operational site and are accompanied by operations staff. Verify	Mandatory	IT CA Rules SCHEDULE III 3.4				

		by checking register/log where entries have been made. c. All personnel entering and leaving CA operational facilities are logged. Verify by checking the physical register or electronic media used for logging. d. CA operational facility has security zones laid out within the facility. Verify the documented proof for zoning performed. e. Access rights to all security zones are laid out. Verify by checking the access list for various security zones f. Security zones are separate from the other by floor to ceiling concrete reinforced walls. Conduct physical walkthrough of the zones to ascertain the same 6. Collect site access log and verify all entries are recorded and inspected periodically						
3.1.4.33	Each security zone must be separated from the other by floor to ceiling concrete reinforced walls.	1. Verify the CA maintains and inventory of access cards and reviews it periodically 2. Obtain the up-to-date list of personnel who possess cards/keys 3. Verify the list is updated regularly and archived for a period of three years 4. Validate the process followed in case of loss of access cards, check list of cases where cards were lost and verify if the process was followed. 5. Conduct a walkthrough to check the following: a. Any personnel not on access list is escorted at all times within the operational site b. All individuals, other than operations	Mandatory	IT CA Rules SCHEDULE III 3.4				

		staff, sign in and sign out of the operational site and are accompanied by operations staff. Verify by checking register/log where entries have been made. c. All personnel entering and leaving CA operational facilities are logged. Verify by checking the physical register or electronic media used for logging. d. CA operational facility has security zones laid out within the facility. Verify the documented proof for zoning performed. e. Access rights to all security zones are laid out. Verify by checking the access list for various security zones f. Security zones are separate from the other by floor to ceiling concrete reinforced walls. Conduct physical walkthrough of the zones to ascertain the same 6. Collect site access log and verify all entries are recorded and inspected periodically						
3.1.4.34	Alarm and intrusion detection system must be installed at every stage with adequate power backup capable of continuing operation even in the event of loss of main power.	1. Verify Alarm and intrusion detection system are installed at every stage with adequate power backup 2. Validate Electrical/Electronic circuits to external security alarm monitoring service are supervised 3. Validate access to PKI Server, root keys or any personal computer system or network device is prohibited	Mandatory	IT CA Rules SCHEDULE III 3.4				
3.1.4.35	Electrical/Electronic circuits to external security alarm monitoring service (if used) shall be supervised	1. Verify Alarm and intrusion detection system are installed at every stage with adequate power backup	Mandatory	IT CA Rules SCHEDULE III 3.4				

		2. Validate Electrical/Electronic circuits to external security alarm monitoring service are supervised 3. Validate access to PKI Server, root keys or any personal computer system or network device is prohibited						
3.1.4.36	Access to PKI Server, root keys or any personal computer system or network device shall be prohibited	1. Verify Alarm and intrusion detection system are installed at every stage with adequate power backup 2. Validate Electrical/Electronic circuits to external security alarm monitoring service are supervised 3. Validate access to PKI Server, root keys or any personal computer system or network device is prohibited	Mandatory	IT CA Rules SCHEDULE III 3.4				
3.1.4.37	Access to infrastructure components essential to operation of Certifying Authority such as power control panels, communication infrastructure, Digital Signature Certification system, cabling, etc. shall be restricted to authorized personnel.	1. Verify list of personnel with access to essential components for CA is maintained 2. Validate no unauthorized personnel has access to these components by checking the controls implemented to prevent unauthorized access such as locked door, biometric etc.	Mandatory	IT CA Rules SCHEDULE III 3.8				
3.1.4.38	By-pass or deactivation of normal physical security arrangements shall be authorized and documented by security personnel	1. Verify all By-pass or deactivation of normal physical security arrangements is authorized and documented by security personnel	Mandatory	IT CA Rules SCHEDULE III 3.9				
3.1.4.39	Intrusion detection systems shall be used to monitor and record physical access to the Digital Signature Certification system during and after office hours.	1. Conduct walkthrough to check the following: a. Intrusion detection systems are used to monitor and record physical access to the DSC system during	Mandatory	IT CA Rules SCHEDULE III 3.10				

		and after office hours b. Computer System or PKI Server performing the DSC functions are dedicated to those functions and should not be used for any other purposes c. Emergency exits are tested periodically. Validate by checking proper functioning of emergency exits. d. Unauthorized access to areas storing hardware is prohibited. Verify by checking the access list for areas storing the hardware. e. Two person physical access control are present at both the cryptographic module and computer system for CAs issuing Class 1, Class 2 and Class 3 certificates. Practical demonstration of the two person physical access should be done in the presence of the auditor.						
3.1.4.40	Computer System or PKI Server performing the Digital Signature Certification functions shall be dedicated to those functions and should not be used for any other purposes.	1. Conduct walkthrough to check the following: a. Intrusion detection systems are used to monitor and record physical access to the DSC system during and after office hours b. Computer System or PKI Server performing the DSC functions are dedicated to those functions and should not be used for any other purposes c. Emergency exits are tested periodically. Validate by checking proper functioning of emergency exits. d. Unauthorized access to areas storing hardware is prohibited. Verify by checking the access list for areas storing the hardware. e. Two person physical access control are present at both the cryptographic module and computer system	Mandatory	IT CA Rules SCHEDULE III 3.11				

		for CAs issuing Class 1, Class 2 and Class 3 certificates. Practical demonstration of the two person physical access should be done in the presence of the auditor.						
3.1.4.41	Emergency exits shall be tested periodically to ensure that the access security systems are operational	1. Conduct walkthrough to check the following: a. Intrusion detection systems are used to monitor and record physical access to the DSC system during and after office hours b. Computer System or PKI Server performing the DSC functions are dedicated to those functions and should not be used for any other purposes c. Emergency exits are tested periodically. Validate by checking proper functioning of emergency exits. d. Unauthorized access to areas storing hardware is prohibited. Verify by checking the access list for areas storing the hardware. e. Two person physical access control are present at both the cryptographic module and computer system for CAs issuing Class 1, Class 2 and Class 3 certificates. Practical demonstration of the two person physical access should be done in the presence of the auditor.	Mandatory	IT CA Rules CHEDULE II 4.4				
3.1.4.42	Unauthorized access to areas storing hardware shall be prohibited	1. Conduct walkthrough to check the following: a. Intrusion detection systems are used to monitor and record physical access to the DSC system during and after office hours b. Computer System or PKI Server performing the DSC functions are dedicated to those functions and should not be used for any	Mandatory	X.509 Policy 5.1.2.1				

		other purposes c. Emergency exits are tested periodically. Validate by checking proper functioning of emergency exits. d. Unauthorized access to areas storing hardware is prohibited. Verify by checking the access list for areas storing the hardware. e. Two person physical access control are present at both the cryptographic module and computer system for CAs issuing Class 1, Class 2 and Class 3 certificates. Practical demonstration of the two person physical access should be done in the presence of the auditor.						
3.1.4.43	Two person physical access control shall be present at both the cryptographic module and computer system for CAs issuing Class 1, Class 2 and Class 3 certificates.	1. Conduct walkthrough to check the following: a. Intrusion detection systems are used to monitor and record physical access to the DSC system during and after office hours b. Computer System or PKI Server performing the DSC functions are dedicated to those functions and should not be used for any other purposes c. Emergency exits are tested periodically. Validate by checking proper functioning of emergency exits. d. Unauthorized access to areas storing hardware is prohibited. Verify by checking the access list for areas storing the hardware. e. Two person physical access control are present at both the cryptographic module and computer system for CAs issuing Class 1, Class 2 and Class 3 certificates. Practical demonstration of the two person physical access should be done in the presence	Mandatory	X.509 Policy 5.1.2.				

		of the auditor.						
3.1.4.44	Removable cryptographic modules shall be deactivated prior to storage. When not in use, removable cryptographic modules, activation information used to access or enable cryptographic modules shall be placed in secure containers. Activation data shall either be memorized, or recorded and stored in a manner commensurate with the security afforded the cryptographic module, and shall not be stored with the cryptographic module.	1. Verify removable cryptographic modules are deactivated before storage 2. Validate activation information used to access or enable cryptographic modules is placed in secure containers. 3. Check the mechanism used to store activation data	Mandatory	X.509 Policy 5.1.2.1				
3.1.4.45	The Certifying Authority must ensure that no single individual may gain access to the Digital Signature Certificate server and the computer server maintaining all information associated with generation, issue and management of Digital Signature Certificate and private keys of the Certifying Authority. Minimum two individuals, preferably using a split-knowledge technique, such as twin passwords, must perform any operation associated with generation, issue and management of Digital Signature Certificate and application of private key of the Certifying Authority.	1. Verify the process of security check to be conducted if the facility housing the CA and CSP equipment is left unattended 2. Validate it covers the requirements mentioned in control description 3. Check the list of persons responsible for doing the security checks mentioned in control - 3.1.4.45 4. Verify if a group of people are assigned the security check responsibility a log identifying the person performing a check at each instance is maintained 5. Check if the facility is not continuously attended, the last person to depart initials a sign-out sheet that indicates the date and time, and asserts that all necessary physical protection mechanisms are in place and activated	Mandatory	IT CA Rules SCHEDULE III 12				
Inventory Management								
3.1.4.46	Inventory control processes and procedures shall be documented and implemented to manage	1. Obtain copy of Inventory control processes and procedures and check	Mandatory	WebTrust 4.8.3				

	the origination, arrival, condition, departure and destination of each device.	the following: a. Policy and procedure are implemented to manage the origination, arrival, condition, departure and destination of each device. b. Details of all media are inventoried c. An independent physical inventory check of all media is conducted at least every six months. Verify by checking latest report of physical inventory check d. An up-to-date inventory list of all documentation is maintained. Verify by checking previous versions of inventory list to validate periodicity of update e. All equipment related to CA Operations are inventoried. Verify by conducting a random check on sample basis for the infrastructure and check its entry in to inventory						
3.1.4.47	Details of all media shall be inventoried. An independent physical inventory check of all media shall be conducted at least every six months.	1. Obtain copy of Inventory control processes and procedures and check the following: a. Policy and procedure are implemented to manage the origination, arrival, condition, departure and destination of each device. b. Details of all media are inventoried c. An independent physical inventory check of all media is conducted at least every six months. Verify by checking latest report of physical inventory check d. An up-to-date inventory list of all documentation is maintained. Verify by checking previous versions of inventory list to validate	Mandatory	IT CA Rules SCHEDULE II 8.3				

		periodicity of update e. All equipment related to CA Operations are inventoried. Verify by conducting a random check on sample basis for the infrastructure and check its entry in to inventory						
3.1.4.48	An up-to-date inventory list of all documentation shall be maintained to ensure control and accountability.	1. Obtain copy of Inventory control processes and procedures and check the following: a. Policy and procedure are implemented to manage the origination, arrival, condition, departure and destination of each device. b. Details of all media are inventoried c. An independent physical inventory check of all media is conducted at least every six months. Verify by checking latest report of physical inventory check d. An up-to-date inventory list of all documentation is maintained. Verify by checking previous versions of inventory list to validate periodicity of update e. All equipment related to CA Operations are inventoried. Verify by conducting a random check on sample basis for the infrastructure and check its entry in to inventory	Mandatory	IT CA Rules SCHEDULE II 16				
3.1.4.49	All equipment related to CA Operations shall be inventoried	1. Obtain copy of Inventory control processes and procedures and check the following: a. Policy and procedure are implemented to manage the origination, arrival, condition, departure and destination of each device. b. Details of all media are inventoried	Mandatory	WebTrust 3.4.16				

		c. An independent physical inventory check of all media is conducted at least every six months. Verify by checking latest report of physical inventory check d. An up-to-date inventory list of all documentation is maintained. Verify by checking previous versions of inventory list to validate periodicity of update e. All equipment related to CA Operations are inventoried. Verify by conducting a random check on sample basis for the infrastructure and check its entry in to inventory						
Media Storage								
3.1.4.50	All sensitive information stored in any media shall bear or be assigned an appropriate security classification.	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of	Mandatory	IT CA Rules SCHEDULE II 5.2				

		authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.							
--	--	---	--	--	--	--	--	--	--

3.1.4.51	Media library, electrical and mechanical control rooms shall be housed in separate isolated areas, with access granted only to specific, named individuals on a need basis. The area must be fire resistant and free of toxic chemicals	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by	Mandatory	IT CA Rules SCHEDULE II 4.1.8				

		management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.						
3.1.4.52	Storage media (i.e. floppy diskettes, magnetic tapes, portable hard disks, optical disks, etc.) containing sensitive information shall be secured according to their classification	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals.	Mandatory	IT CA Rules SCHEDULE II 5.2				

		e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media							
--	--	---	--	--	--	--	--	--	--

		q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.						
3.1.4.53	Responsibilities for media library management and protection shall be clearly defined and assigned	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that	Mandatory	IT CA Rules SCHEDULE II 8.3				

		containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.						
3.1.4.54	Access to the media library (both on-site and off-site) shall be restricted to the authorized persons only. A list of personnel authorized to enter the library shall be	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security	Mandatory	IT CA Rules SCHEDULE II 8.3				

	maintained	classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed						
--	------------	--	--	--	--	--	--	--

		n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.						
3.1.4.55	Media containing sensitive and back up data must be stored at three different physical locations in the country, which can be reached in few hours. Media that contains audit, archive, or backup information shall be duplicated and stored in a	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to	Mandatory	X.509 Policy, IT CA Rules				

		the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain						
--	--	---	--	--	--	--	--	--

		sensitive data prior to their disposal.						
3.1.4.56	Media containing sensitive and back up data must be stored at three different physical locations in the country, which can be reached in few hours. Media that contains audit, archive, or backup information shall be duplicated and stored in a location separate from the CA location.	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that contains audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All	Mandatory	X.509 Policy, IT CA Rules				

		incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.						
3.1.4.57	A media management system shall be in place to account for all media stored on-site and off-site	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list	Mandatory	IT CA Rules SCHEDULE II 8.3				

		d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are							
--	--	--	--	--	--	--	--	--	--

		present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.						
3.1.4.58	All incoming/outgoing media transfers shall be authorized by management and users.	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical	Mandatory	IT CA Rules SCHEDULE II 8.3				

		locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.						
3.1.4.59	All media shall have external volume identification. Internal labels shall be fixed, where available	1. Obtain Media Management policy and verify the following: a. All sensitive	Mandatory	IT CA Rules SCHEDULE II 8.3				

		information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized						
--	--	--	--	--	--	--	--	--

		addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.						
3.1.4.60	Procedures shall be in place to ensure that only authorized addition/removal of media from the library is allowed.	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly	Mandatory	IT CA Rules SCHEDULE II 8.3				

		defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing						
--	--	--	--	--	--	--	--	--

		storage media are checked to ensure that they do not contain sensitive data prior to their disposal.						
3.1.4.61	Media retention periods shall be established and approved by management in accordance with legal regulatory and user requirements.	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by	Mandatory	IT CA Rules SCHEDULE II 8.3				

		providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.						
3.1.4.62	Proper records of all movements of computer tapes/disks between on-site and off-site media library must be maintained.	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named	Mandatory	IT CA Rules SCHEDULE II 8.4				

		individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and							
--	--	--	--	--	--	--	--	--	--

		off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.						
3.1.4.63	There shall be procedures to ensure the authorized and secure transfer to media to/from external parties and the off-site location including a means to authenticate the receipt shall be in place.	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the	Mandatory	IT CA Rules SCHEDULE II 8.4				

		country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.						
3.1.4.64	Computer media that are being transported to off-	1. Obtain Media Management policy	Mandatory	IT CA Rules SCHEDULE II 8.4				

	site data backup locations should be stored in locked carrying cases that provide magnetic field protection and protection from impact while loading and unloading and during transportation	and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification						
--	---	--	--	--	--	--	--	--

		m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.						
3.1.4.65	All items of equipment containing storage media (fixed and removable disks) shall be checked to ensure that they do not contain sensitive data prior to their disposal.	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for	Mandatory	WebTrust 3.4.21				

		media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and backup data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic						
--	--	--	--	--	--	--	--	--

		field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.						
3.1.4.66	Procedures shall be in place to ensure the secure disposal of sensitive information assets on all corrupted/damaged or affected media both internal (e.g. hard disk/optical disk) and external (e.g. diskette, disk drive, tapes etc.) to the system	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location.	Mandatory	IT CA Rules SCHEDULE II 5.2				

		j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.						
Power and Air Conditioning								
3.1.4.67	Air-conditioning system and power supply system unit shall be installed by the CA	1. Conduct walkthrough of CA facility and check the following: a. existence of Air conditioning and power supply system b. backup power is present to automatically lockout input, finish any pending actions, and	Mandatory	IT CA Rules SCHEDULE II 4.1				

		record the state of the equipment before lack of power or air conditioning causes a shutdown						
3.1.4.68	CAs shall have backup power sufficient to automatically lockout input, finish any pending actions, and record the state of the equipment before lack of power or air conditioning causes a shutdown	1. Conduct walkthrough of CA facility and check the following: a. existence of Air conditioning and power supply system b. backup power is present to automatically lockout input, finish any pending actions, and record the state of the equipment before lack of power or air conditioning causes a shutdown	Mandatory	X.509 Policy 5.1.3				
Waste Disposal								
3.1.4.69	Procedures shall be designed and implemented for disposing off sensitive waste material.	1. Verify procedure is present and implemented for disposing off the sensitive waste material 2. Validate all media used for storage of information pertaining to all functions	Mandatory	X.509 Policy 5.1.7, IT CA Rules SCHEDULE III 5				
3.1.4.70	All media used for storage of information pertaining to all functions associated with generation, production, issue and management of Digital Signature Certificate shall be scrutinized before being destroyed or released for disposal	associated of DSC is scrutinized before being destroyed or released for disposal. Verify by checking on sample basis, media was disposed off based on defined procedure	Mandatory	IT CA Rules SCHEDULE III 5				
Data Backup and Off-site Retention								
3.1.4.71	A Certifying Authority must ensure that facility used for off- site backup shall be within the country and shall have the same level of security as the primary Certifying Authority site	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented	Mandatory	WebTrust, IT CA Rules SCHEDULE III 6				

		c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up						
3.1.4.72	Back-up procedures shall be documented, scheduled and	1. Conduct walkthrough of the CA backup site and check	Mandatory	IT CA Rules SCHEDULE II 9				

	monitored.	the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for						
--	------------	--	--	--	--	--	--	--

		information backed up						
3.1.4.73	Full system backups of the CAs, sufficient to recover from system failure, shall be made on a periodic schedule	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information	Mandatory	X.509 Policy 5.1.8				

		p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up						
3.1.4.74	Backups shall be performed and stored off-site not less than once every 7 days. At least one full backup copy shall be stored at an offsite location (at a location separate from the CA equipment). Only the latest full backup need be retained.	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location	Mandatory	X.509 Policy 5.1.8				

		n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up						
3.1.4.75	One set of the original disks for all operating system and application software must be maintained to ensure that a valid, virus-free backup exists and is available for use at any time	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the	Mandatory	IT CA Rules SCHEDULE II 9				

		integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up						
3.1.4.76	Backups of the system, application and data shall be performed on a regular basis. Backups should also be made for application under development and data conversion efforts.	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is	Mandatory	IT CA Rules SCHEDULE II 9				

		also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up						
3.1.4.77	Data backup is required for all systems including personal computers, servers and distributed systems and databases.	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is	Mandatory	IT CA Rules SCHEDULE II 9				

		maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up						
3.1.4.78	Critical system data and file server software shall have full backups taken weekly.	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than	Mandatory	IT CA Rules SCHEDULE II 9				

		once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up						
3.1.4.79	The Certifying Authority should verify the integrity of the backups at least once every six months	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site	Mandatory	IT CA Rules SCHEDULE II 9				

		b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up						
--	--	---	--	--	--	--	--	--

3.1.4.80	The backups shall be kept in an area physically separate from the server. If critical system data on the LAN represents unique versions of the information assets, then the information backups should be rotated on a periodic basis to an off-site storage location.	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security	Mandatory	IT CA Rules SCHEDULE II 9					
----------	---	---	-----------	------------------------------	--	--	--	--	--

		requirements of backup copies are consistent with control for information backed up						
3.1.4.81	Critical system data and file server software must have incremental backups taken daily.	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are	Mandatory	IT CA Rules SCHEDULE II 9				

		backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up						
3.1.4.82	Systems that are completely static may not require periodic backup, but shall be backed up after changes or updates in the information	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information	Mandatory	IT CA Rules SCHEDULE II 9				

		backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up						
3.1.4.83	Each LAN/system should have a primary and backup operator to ensure continuity of business operations.	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken	Mandatory	IT CA Rules SCHEDULE II 9				

		weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up						
3.1.4.84	The security requirements of backup copies shall be consistent with the controls for the information backed up	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for	Mandatory	WebTrust 4.2.4				

		application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up						
Environmental Protection								
3.1.4.85	Water detectors shall be installed under the raised floors throughout the operational site and shall be connected to audible alarms	1. Conduct walkthrough of the CA facility and check the following: a. Water detectors are installed under the raised floors throughout the operational site and are connected to audible alarms b. temperature and humidity condition in the operational site is monitored and controlled periodically c. periodic inspection, testing and maintenance of equipment is scheduled. Verify by checking previous reports on a sample	Mandatory	IT CA Rules SCHEDULE II 4.3				

		basis based on frequency d. personnel at operational site is trained to monitor and control various devices						
3.1.4.86	The temperature and humidity condition in the operational site shall be monitored and controlled periodically	1. Conduct walkthrough of the CA facility and check the following: a. Water detectors are installed under the raised floors throughout the operational site and are connected to audible alarms b. temperature and humidity condition in the operational site is monitored and controlled periodically c. periodic inspection, testing and maintenance of equipment is scheduled. Verify by checking previous reports on a sample basis based on frequency d. personnel at operational site is trained to monitor and control various devices	Mandatory	IT CA Rules SCHEDULE II 4.3				
3.1.4.87	Periodic inspection, testing and maintenance of the equipment and systems shall be scheduled.	1. Conduct walkthrough of the CA facility and check the following: a. Water detectors are installed under the raised floors throughout the operational site and are connected to audible alarms b. temperature and humidity condition in the operational site is monitored and controlled periodically c. periodic inspection, testing and maintenance of equipment is scheduled. Verify by checking previous reports on a sample basis based on frequency d. personnel at operational site is trained to monitor and control various devices	Mandatory	T CA Rules SCHEDULE II 4.3				

3.1.4.88	Personnel at the operational site shall be trained to monitor and control the various equipment and devices installed at the operational site for the purpose of fire and environment protection	1. Conduct walkthrough of the CA facility and check the following: a. Water detectors are installed under the raised floors throughout the operational site and are connected to audible alarms b. temperature and humidity condition in the operational site is monitored and controlled periodically c. periodic inspection, testing and maintenance of equipment is scheduled. Verify by checking previous reports on a sample basis based on frequency d. personnel at operational site is trained to monitor and control various devices	Mandatory	IT CA Rules SCHEDULE II 4				
Third Party Access								
3.1.4.89	Access to the computer systems by other Organizations shall be subjected to a similar level of security protection and controls as in stated in Information Technology security guidelines under IT CA Rules	1. Verify access to computer systems by other organizations is subjected to a similar level of security protection and controls as stated in IT CA Rules 2. Validate in case Data Centre uses external service/facility provider for any of their operations, all related risks are evaluated before onboarding the outsourced vendor 3. Verify on sample basis the external service or facility provider has signed non-disclosure agreements with the management of the Data Centre/operational site 4. Check the external service/facility provider provides an equivalent level of security controls as required by Information Technology Security Guidelines	Mandatory	IT CA Rules SCHEDULE II 5.4				

3.1.4.90	In case the Data Centre uses the facilities of external service/facility provider (outsourcer) for any of their operations, the use of external service/facility providers (e.g. outsourcer) shall be evaluated in light of the possible security exposures and risks involved and all such agreements shall be approved by the information asset owner. The external service or facility provider shall also sign non-disclosure agreements with the management of the Data Centre/operational site.	1. Verify access to computer systems by other organizations is subjected to a similar level of security protection and controls as stated in IT CA Rules 2. Validate in case Data Centre uses external service/facility provider for any of their operations, all related risks are evaluated before onboarding the outsourced vendor 3. Verify on sample basis the external service or facility provider has signed non-disclosure agreements with the management of the Data Centre/operational site 4. Check the external service/facility provider provides an equivalent level of security controls as required by Information Technology Security Guidelines	Mandatory	IT CA Rules SCHEDULE II 5.4				
3.1.4.91	The external service/facility provider (e.g. outsourcer) shall provide an equivalent level of security controls as required by Information Technology Security Guidelines	1. Verify access to computer systems by other organizations is subjected to a similar level of security protection and controls as stated in IT CA Rules 2. Validate in case Data Centre uses external service/facility provider for any of their operations, all related risks are evaluated before onboarding the outsourced vendor 3. Verify on sample basis the external service or facility provider has signed non-disclosure agreements with the management of the Data Centre/operational site 4. Check the external service/facility provider provides an equivalent level of security controls as	Mandatory	IT CA Rules SCHEDULE II 5.4				

		required by Information Technology Security Guidelines						
--	--	---	--	--	--	--	--	--

3.1.5. Personnel Security

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Personnel Security							
3.1.5.1	The Certifying Authority must ensure that all personnel performing duties with respect to its operation must: • be appointed in writing; • be bound by contract or statute to the terms and conditions of the position they are to fill; • have received comprehensive training with respect to the duties they are to perform; • be bound by statute or contract not to disclose sensitive Certifying Authority's security related information or subscriber information; • not be assigned duties that may cause a conflict of interest with their Certifying Authority's duties; • be aware and trained in the relevant aspects of the Information Technology Security Policy and Security Guidelines framed for carrying out Certifying Authority's operation	1. For sample CA personnel, perform the following checks: a. personnel received an offer letter with roles and responsibilities appointed in writing. Verify on sample basis for personnel b. personnel is bound by contract or statute to the terms and conditions of the position they are to fill. Verify by checking the contract c. personnel has received comprehensive training via sessions organized specifically for the job. Check training logs d. personnel is bound by statute or contract not to disclose sensitive CA's security related information or subscriber information and has signed NDA for same. e. personnel is not assigned duties that may cause a conflict of interest with their CA's duties f. personnel is aware and trained in the relevant aspects of the Information Technology Security Policy and Security Guidelines	Mandatory	IT CA Rules SCHEDULE III 14			
3.1.5.2	A Certifying Authority must make available to his personnel the Digital Signature Certificate policies it supports, its Certification Practice Statement, Information	1. Validate CA has made available to his personnel the DSC policies, CPS, IT security guideline, Information Technology Security	Mandatory	IT CA Rules SCHEDULE III 17			

	Technology Security Policy and any specific statutes, policies or contracts relevant to their position	Policy and any specific statutes, policies or contracts relevant to their position 2. Verify the CA provides reasonable assurance that personnel and employment practices enhance and support the trustworthiness of the CA's operations and receive regular security/PKI based trainings						
3.1.5.3	The CA shall provide reasonable assurance that personnel and employment practices enhance and support the trustworthiness of the CA's operations	1. Validate CA has made available to his personnel the DSC policies, CPS, IT security guideline, Information Technology Security Policy and any specific statutes, policies or contracts relevant to their position 2. Verify the CA provides reasonable assurance that personnel and employment practices enhance and support the trustworthiness of the CA's operations and receive regular security/PKI based trainings	Mandatory	WebTrust 3.3				
3.1.5.4	Prior to the engagement of any person whether as an employee, agent, or an independent contractor of the CA, the CA shall verify perform a background check. The scope of the background check shall include the following areas covering the past five years: • Employment; • Education (Regardless of the date of award, the highest educational degree shall be verified); • Place of residence (3 years); • Law Enforcement; and • References The background shall be refreshed every three years	1. Check the documented procedure detailing the background check criteria for an employee or an independent contractor of the CA 2. Verify that the scope of background check contains the details covered in control description	Mandatory	WebTrust 3.3.7, X.509 Policy 5.3.2				

3.1.5.5	The CA and CSP shall make available to its personnel this certificate policy, the applicable CPS, and any relevant statutes, policies or contracts	1. Verify the CA and CSP share all relevant statutes, policies or contracts with their personnel	Mandatory	X.509 Policy 5.3.7				
3.1.5.6	Personnel appointed to trusted roles (CA trusted roles) shall: • Have successfully completed an appropriate training program; • Have demonstrated the ability to perform their duties; • Be trustworthy; • Have no other duties that would interfere or conflict with their duties for the trusted role; • Have not been previously relieved of duties for reasons of negligence or nonperformance of duties; • Have not been denied a security clearance, or had a security clearance revoked for cause; • Have not been convicted of a felony offense; and • Be appointed in writing by an approving authority • Be bound by statute or contract not to disclose sensitive Certifying Authority's security related information or subscriber information;	1. Obtain the list of personnel having CA trusted roles 2. Verify for sample personnel, they adhere to the requirements mentioned in control description 3. Validate the personnel in Trusted Roles maintain skill levels consistent with the CA's training and performance programs	Mandatory	X.509 Policy 5.3.1				
3.1.5.7	All personnel in Trusted Roles shall maintain skill levels consistent with the CA's training and performance programs.	1. Obtain the list of personnel having CA trusted roles 2. Verify for sample personnel, they adhere to the requirements mentioned in control description 3. Validate the personnel in Trusted Roles maintain skill levels consistent with the CA's training and performance programs	Mandatory	CA Browser Forum 5.3.4				

3.1.6. System integrity and security measures

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
User's Account Management							

3.1.6.1	Procedures for user account management shall be established to control access to application systems and data	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met	Mandatory	IT CA Rules SCHEDULE II 6.5				
3.1.6.2	Users shall be authorized by the computer system owner to access the computer services	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the	Mandatory	IT CA Rules SCHEDULE II 6.5				

		computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met						
3.1.6.3	A written statement of access rights shall be given to all users.	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met	Mandatory	IT CA Rules SCHEDULE II 6.5				
3.1.6.4	All users shall be required to sign an undertaking to acknowledge that they understand the conditions of access	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system	Mandatory	IT CA Rules SCHEDULE II 6.5				

		owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met						
3.1.6.5	Where access to computer services is administered by service providers, access shall not be provided until authorization is completed. This shall include the acknowledgment of receipt of the accounts by the users	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts	Mandatory	IT CA Rules SCHEDULE II 6.5				

		i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met						
3.1.6.6	A formal record of all registered users of the computer services shall be maintained.	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met	Mandatory	IT CA Rules SCHEDULE II 6.5				
3.1.6.7	Access rights of users who have been transferred, or left the organization shall be removed immediately	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access	Mandatory	IT CA Rules SCHEDULE II 6.5				

		e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met						
3.1.6.8	A periodic check shall be carried out for redundant user accounts and access rights that are no longer required. Redundant user accounts shall not be re-issued to another user	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met	Mandatory	IT CA Rules SCHEDULE II 6.5				
3.1.6.9	User accounts shall be suspended under the following conditions	1. For the User Account Management process, check the following on sample basis:	Mandatory	IT CA Rules SCHEDULE II 6.5				

		a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met						
3.1.6.10	User accounts shall be suspended under the following conditions • When an individual is on extended leave or inactive use of over thirty days. In case of protected computer system, the limit of thirty days may be reduced to fifteen days by the System Administrator. • Immediately upon the termination of the services of an individual. • Suspended or inactive accounts shall be deleted after a two months period. In case of protected computer systems, the limit of two months may be reduced to one month.	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been	Mandatory	IT CA Rules SCHEDULE II 6.5				

		transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met						
Use of Security Systems or Facilities								
3.1.6.11	Security controls shall be installed and maintained on each computer system or computer node to prevent unauthorized users from gaining entry to the information system and to prevent unauthorized access to data.	1. For sample computers, check the minimum baseline security controls are installed and maintained on each computer system 2. Validate system software or resource of the computer system is accessible after being authenticated by access control system	Mandatory	IT CA Rules SCHEDULE II 6.1				
3.1.6.12	Security controls shall be installed and maintained on each computer system or computer node to prevent unauthorized users from gaining entry to the information system and to prevent unauthorized access to data.	1. For sample computers, check the minimum baseline security controls are installed and maintained on each computer system 2. Validate system software or resource of the computer system is accessible after being authenticated by access control system	Mandatory	IT CA Rules SCHEDULE II 6.1				
3.1.6.13	Any system software or resource of the computer system should only be accessible after being authenticated by access control system	1. For sample computers, check the minimum baseline security controls are installed and maintained on each computer system 2. Validate system software or resource of the computer system is accessible after being authenticated by access control system	Mandatory	IT CA Rules SCHEDULE II 6.1				
System Access Control								
3.1.6.14	Access control software and system software security features shall be implemented to protect resources. Management approval	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval	Mandatory	IT CA Rules SCHEDULE II 6.2, IT Regulations 3				

	is required to authorize issuance of user identification (ID) and resource privileges. Approved access and integrity controls such as intrusion detection, virus scanning, prevention of denial-of service attacks and physical security measures shall be followed by the Certifying Authority for all its systems that store and process the subscribers' information and certificates.	is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files						
3.1.6.15	The access control software or operating system of the computer system shall provide features to restrict access to the system and data resources. The use	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize	Mandatory	IT CA Rules SCHEDULE II 6.2				

	of common passwords such as "administrator" or "president" or "game" etc. to protect	issuance of user identification (ID) and resource privileges b. Access control software and system software security features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files						
3.1.6.16	The access control software or operating system of the computer system shall provide features to restrict access to the system and data resources. The use of common passwords	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user	Mandatory	IT CA Rules SCHEDULE II 6.2				

	such as "administrator" or "president" or "game" etc. to protect access to the system and data resources represent a security exposure and shall be avoided. All passwords used must be resistant to dictionary attacks.	identification (ID) and resource privileges b. Access control software and system software security features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files					
3.1.6.17	An Access Control System manual documenting the access granted to different level of users shall be prepared to provide guidance to the System Administrator for grant of access.	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and	Mandatory	IT CA Rules SCHEDULE II 6.2			

		resource privileges b. Access control software and system software security features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files						
3.1.6.18	Each user shall be assigned a unique user ID. Adequate user education shall be provided to help users in password choice and password protection. Sharing of user IDs shall not be allowed	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges	Mandatory	IT CA Rules SCHEDULE II 6.2				

		b. Access control software and system software security features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files						
3.1.6.19	Stored passwords shall be encrypted using internationally proven encryption techniques to prevent unauthorized disclosure and modification.	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control	Mandatory	IT CA Rules SCHEDULE II 6.2				

		software and system software security features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files							
3.1.6.20	Stored passwords shall be protected by access controls from unauthorized disclosure and modification	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system	Mandatory	IT CA Rules SCHEDULE II 6.2					

		software security features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files						
3.1.6.21	Automatic time-out for terminal inactivity should be implemented	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security	Mandatory	IT CA Rules SCHEDULE II 6.2				

		features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files					
3.1.6.22	Where a second level access control is implemented through the application system, password controls similar to those implemented for the computer system shall be in place .	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security features are	Mandatory	IT CA Rules SCHEDULE II 6.2			

		implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files					
3.1.6.23	Activities of all remote users shall be logged and monitored closely	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security features are implemented	Mandatory	IT CA Rules SCHEDULE II 6.2			

		c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files					
3.1.6.24	The facility to login as another user from one user's login shall be denied. However, the system should prohibit direct login as a trusted user (e.g. root in Unix, administrator in Windows NT or Windows 2000). This means that there must be a user account configured for the trusted administrator.	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security features are implemented c. Approved access and	Mandatory	IT CA Rules SCHEDULE II 6.2			

		integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files					
3.1.6.25	The startup and shutdown procedure of the security software must be Automated	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security features are implemented c. Approved access and integrity controls are	Mandatory	IT CA Rules SCHEDULE II 6.2			

		implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files						
3.1.6.26	Sensitive Operating System files, which are more prone to hackers must be protected against all known attacks using proven tools and techniques. That is to say no user will be able to modify them except with the permission of System Administrator.	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security features are implemented c. Approved access and integrity controls are implemented	Mandatory	IT CA Rules SCHEDULE II 6.2				

		d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files					
Password Management							
3.1.6.27	Quality standards for password shall be enforced. The quality level shall be increased progressively. The following control features shall be implemented for passwords: • Minimum of eight characters without leading or trailing blanks; • Shall be different from the existing password and the two previous ones;	1. Verify on sample basis the passwords used across CA systems comply with the requirements mentioned in control 2. Verify on sample basis the password retries is limited to maximum three attempts (two for sensitive for sensitive systems) 3. Check the user ID is revoked after the user exhausts permissible limit of password retries on sample basis	Mandatory	IT CA Rules SCHEDULE II 6.3			

	• Shall be changed at least once every ninety days; for sensitive system password shall be changed at least once every thirty days; and • Shall not be shared, displayed or printed. Shall have at least on number, one capital letter, one small case letter and one special character	4. Validate the initial or reset passwords is changed by the user upon first use 5. Check the passwords are encrypted instorage to prevent unauthorized disclosure and protect them from dictionary attacks and all known password cracking algorithms.						
3.1.6.28	Password retries shall be limited to a maximum of three attempted logons after which the user ID shall then be revoked; for sensitive systems, the number of password retries should be limited to a maximum of two.	1. Verify on sample basis the passwords used across CA systems comply with the requirements mentioned in control 2. Verify on sample basis the password retries is limited to maximum three attempts (two for sensitive for sensitive systems) 3. Check the user ID is revoked after the user exhausts permissible limit of password retries on sample basis 4. Validate the initial or reset passwords is changed by the user upon first use 5. Check the passwords are encrypted instorage to prevent unauthorized disclosure and protect them from dictionary attacks and all known password cracking algorithms.	Mandatory	IT CA Rules SCHEDULE II 6.3				
3.1.6.29	Initial or reset passwords must be changed by the user upon first use. Users shall follow defined policies and procedures in the selection and use of passwords.	1. Verify on sample basis the passwords used across CA systems comply with the requirements mentioned in control 2. Verify on sample basis the password retries is limited to maximum three attempts (two for sensitive for sensitive systems) 3. Check the user ID is revoked after the user exhausts permissible limit of password retries on sample basis 4. Validate the initial or reset passwords is changed by the user upon first use 5. Check the passwords	Mandatory	WebTrust 3.6.6, IT CA Rules SCHEDULE II 6.3				

		are encrypted instorage to prevent unauthorized disclosure and protect them from dictionary attacks and all known password cracking algorithms.						
3.1.6.30	Passwords shall always be encrypted in storage to prevent unauthorized disclosure and protect them from dictionary attacks and all known password cracking algorithms.	1. Verify on sample basis the passwords used across CA systems comply with the requirements mentioned in control 2. Verify on sample basis the password retries is limited to maximum three attempts (two for sensitive for sensitive systems) 3. Check the user ID is revoked after the user exhausts permissible limit of password retries on sample basis 4. Validate the initial or reset passwords is changed by the user upon first use 5. Check the passwords are encrypted instorage to prevent unauthorized disclosure and protect them from dictionary attacks and all known password cracking algorithms.	Mandatory	IT CA Rules SCHEDULE II 6.3				
Privileged User`s Management								
3.1.6.31	System privileges shall be granted to users only on a need-to- use basis. Login privileges for highly privileged accounts should be available only from Console and terminals situated within Console room.	1. For the privileged user management process, check the following on sample basis: a. System privileges are granted to users only on a need-to-use basis b. Login privileges for highly privileged accounts are available only from Console and terminals situated within Console room c. An audit trail of activities conducted by highly privileged users is maintained for two years and reviewed periodically at least every week by operator who is independent of System Administrator d. Privileged user is be allowed to log in to the computer system from	Mandatory	IT CA Rules SCHEDULE II 6.4				

		remote terminal e. Separate user IDs are allowed to the user for performing privileged and normal (non-privileged) activities f. user IDs for emergency use are recorded and approved. g. Passwords are reset after emergency use						
3.1.6.32	An audit trail of activities conducted by highly privileged users shall be maintained for two years and reviewed periodically at least every week by operator who is independent of System Administrator	1. For the privileged user management process, check the following on sample basis: a. System privileges are granted to users only on a need-to-use basis b. Login privileges for highly privileged accounts are available only from Console and terminals situated within Console room c. An audit trail of activities conducted by highly privileged users is maintained for two years and reviewed periodically at least every week by operator who is independent of System Administrator d. Privileged user is be allowed to log in to the computer system from remote terminal e. Separate user IDs are allowed to the user for performing privileged and normal (non-privileged) activities f. user IDs for emergency use are recorded and approved. g. Passwords are reset after emergency use	Mandatory	IT CA Rules SCHEDULE II 6.4				
3.1.6.33	Privileged user shall not be allowed to log in to the computer system from remote terminal. The usage of the computer system by the privilege user shall be allowed during a certain time period.	1. For the privileged user management process, check the following on sample basis: a. System privileges are granted to users only on a need-to-use basis b. Login privileges for highly privileged accounts are available only from Console and terminals situated within Console room c. An audit trail of activities conducted by	Mandatory	IT CA Rules SCHEDULE II 6.4				

		highly privileged users is maintained for two years and reviewed periodically at least every week by operator who is independent of System Administrator d. Privileged user is be allowed to log in to the computer system from remote terminal e. Separate user IDs are allowed to the user for performing privileged and normal (non-privileged) activities f. user IDs for emergency use are recorded and approved. g. Passwords are reset after emergency use						
3.1.6.34	Separate user IDs shall be allowed to the user for performing privileged and normal (non-privileged) activities.	1. For the privileged user management process, check the following on sample basis: a. System privileges are granted to users only on a need-to-use basis b. Login privileges for highly privileged accounts are available only from Console and terminals situated within Console room c. An audit trail of activities conducted by highly privileged users is maintained for two years and reviewed periodically at least every week by operator who is independent of System Administrator d. Privileged user is be allowed to log in to the computer system from remote terminal e. Separate user IDs are allowed to the user for performing privileged and normal (non-privileged) activities f. user IDs for emergency use are recorded and approved. g. Passwords are reset after emergency use	Mandatory	IT CA Rules SCHEDULE II 6.4				
3.1.6.35	The use of user IDs for emergency use shall be recorded and approved. The passwords shall be reset after use.	1. For the privileged user management process, check the following on sample basis: a. System privileges are	Mandatory	T CA Rules SCHEDULE II 6.4				

		granted to users only on a need-to-use basis b. Login privileges for highly privileged accounts are available only from Console and terminals situated within Console room c. An audit trail of activities conducted by highly privileged users is maintained for two years and reviewed periodically at least every week by operator who is independent of System Administrator d. Privileged user is be allowed to log in to the computer system from remote terminal e. Separate user IDs are allowed to the user for performing privileged and normal (non-privileged) activities f. user IDs for emergency use are recorded and approved. g. Passwords are reset after emergency use						
Data and Resource Protection								
3.1.6.36	All information assets shall be assigned an "owner" responsible for the integrity of that data/resource. Custodians shall be assigned and shall be jointly responsible for information assets by providing computer controls to assist owners.	1. Check the list of data assets and the corresponding owner/custodian for the same.	Mandatory	IT CA Rules SCHEDULE II 6.6				
3.1.6.37	The operating system or security system of the computer system shall: • Define user authority and enforce access control to data within the computer system; • Be capable of specifying, for each named individual, a list of named data objects (e.g. file, Programme) or groups of named objects, and the type of access allowed.	1. Verify the operating system or security system of the computer system define user authority and enforce access control to data within the computer system Check these are capable of specifying for each named individual, a list of named data objects (e.g. file, Programme) or groups of named objects, and the type of access allowed.	Mandatory	IT CA Rules SCHEDULE II 6.6				

3.1.6.38	For networked or shared computer systems, system users shall be limited to a profile of data objects required to perform their needed tasks	1. Verify for networked or shared computer systems, system users shall be limited to a profile of data objects required to perform their needed tasks	Mandatory	IT CA Rules SCHEDULE II 6.6				
3.1.6.39	Application Programmer shall not be allowed to access the production system	2. Validate that application programmer does not have access to the production system	Mandatory	IT CA Rules SCHEDULE II 6.6				
3.1.6.40	Procedures shall be implemented to ensure the secure storage or distribution of all outputs/reports, in accordance with procedures defined by the owners for each system	1. For the jobs performed in the Data Centre check the following: a. procedures have been established to ensure that all changes to the job schedules are appropriately approved b. list of people who have been assigned authority to approve changes to job schedule c. automated job scheduling is used d. Procedures are established to ensure that only authorized and correct job stream and parameter changes are made. e. Procedures are established to maintain logs of system activities f. Procedures are established to ensure that people other than well-trained computer operators are prohibited from operating the computer equipment g. Procedures are implemented to ensure the secure storage or distribution of all outputs/reports, in accordance with procedures defined by the owners for each system	Mandatory	IT CA Rules SCHEDULE II 8.2				
Sensitive Systems Protection								
3.1.6.41	Security tokens/smart cards/bio-metric technologies such as Iris recognition, finger print verification technologies etc. shall be used to complement the usage of passwords	1. For sensitive system protection, check the following have been implemented: a. Security tokens/smart cards/bio-metric technologies such as Iris recognition etc. are used	Mandatory	IT CA Rules SCHEDULE II 7				

	to access the computer system	to complement the usage of passwords to access the computer system b. For computer system processing sensitive data, identify the list of organizations which have access to sensitive data and check the access control measures implemented to establish its effectiveness c. Data in storage is encrypted						
3.1.6.42	For computer system processing sensitive data, access by other Organizations shall be prohibited or strictly controlled.	1. For sensitive system protection, check the following have been implemented: a. Security tokens/smart cards/bio-metric technologies such as Iris recognition etc. are used to complement the usage of passwords to access the computer system b. For computer system processing sensitive data, identify the list of organizations which have access to sensitive data and check the access control measures implemented to establish its effectiveness c. Data in storage is encrypted	Mandatory	IT CA Rules SCHEDULE II 7				
3.1.6.43	For sensitive data, encryption of data in storage shall be considered to protect its confidentiality and integrity.	1. For sensitive system protection, check the following have been implemented: a. Security tokens/smart cards/bio-metric technologies such as Iris recognition etc. are used to complement the usage of passwords to access the computer system b. For computer system processing sensitive data, identify the list of organizations which have access to sensitive data and check the access control measures implemented to establish its effectiveness c. Data in storage is encrypted	Mandatory	IT CA Rules SCHEDULE II 7				
Data Centre Operations Security								

3.1.6.44	Procedures shall be established to ensure that all changes to the job schedules are appropriately approved. The authority to approve changes to job schedules shall be clearly assigned.	1. For the jobs performed in the Data Centre check the following: a. procedures have been established to ensure that all changes to the job schedules are appropriately approved b. list of people who have been assigned authority to approve changes to job schedule c. automated job scheduling is used d. Procedures are established to ensure that only authorized and correct job stream and parameter changes are made. e. Procedures are established to maintain logs of system activities f. Procedures are established to ensure that people other than well-trained computer operators are prohibited from operating the computer equipment g. Procedures are implemented to ensure the secure storage or distribution of all outputs/reports, in accordance with procedures defined by the owners for each system	Mandatory	IT CA Rules SCHEDULE II 8.1				
3.1.6.45	As far as possible, automated job scheduling should be used. Manual job scheduling should require prior approval from the competent authority	1. For the jobs performed in the Data Centre check the following: a. procedures have been established to ensure that all changes to the job schedules are appropriately approved b. list of people who have been assigned authority to approve changes to job schedule c. automated job scheduling is used d. Procedures are established to ensure that only authorized and correct job stream and parameter changes are made. e. Procedures are established to maintain logs of system activities f. Procedures are established to ensure	Mandatory	IT CA Rules SCHEDULE II 8.1				

		that people other than well-trained computer operators are prohibited from operating the computer equipment g. Procedures are implemented to ensure the secure storage or distribution of all outputs/reports, in accordance with procedures defined by the owners for each system						
3.1.6.46	Procedures shall be established to ensure that only authorized and correct job stream and parameter changes are made.	1. For the jobs performed in the Data Centre check the following: a. procedures have been established to ensure that all changes to the job schedules are appropriately approved b. list of people who have been assigned authority to approve changes to job schedule c. automated job scheduling is used d. Procedures are established to ensure that only authorized and correct job stream and parameter changes are made. e. Procedures are established to maintain logs of system activities f. Procedures are established to ensure that people other than well-trained computer operators are prohibited from operating the computer equipment g. Procedures are implemented to ensure the secure storage or distribution of all outputs/reports, in accordance with procedures defined by the owners for each system	Mandatory	IT CA Rules SCHEDULE II 8.2				
3.1.6.47	Procedures shall be established to maintain logs of system activities. Such logs shall be reviewed by a competent independent party for indications of dubious activities. Appropriate retention periods shall be set for	1. For the jobs performed in the Data Centre check the following: a. procedures have been established to ensure that all changes to the job schedules are appropriately approved b. list of people who	Mandatory	IT CA Rules SCHEDULE II 8.2				

	such logs.	have been assigned authority to approve changes to job schedule c. automated job scheduling is used d. Procedures are established to ensure that only authorized and correct job stream and parameter changes are made. e. Procedures are established to maintain logs of system activities f. Procedures are established to ensure that people other than well-trained computer operators are prohibited from operating the computer equipment g. Procedures are implemented to ensure the secure storage or distribution of all outputs/reports, in accordance with procedures defined by the owners for each system						
3.1.6.48	Procedures shall be established to ensure that people other than well-trained computer operators are prohibited from operating the computer equipment	1. For the jobs performed in the Data Centre check the following: a. procedures have been established to ensure that all changes to the job schedules are appropriately approved b. list of people who have been assigned authority to approve changes to job schedule c. automated job scheduling is used d. Procedures are established to ensure that only authorized and correct job stream and parameter changes are made. e. Procedures are established to maintain logs of system activities f. Procedures are established to ensure that people other than well-trained computer operators are prohibited from operating the computer equipment g. Procedures are implemented to ensure the secure storage or distribution of all outputs/reports, in	Mandatory	IT CA Rules SCHEDULE II 8.2				

		accordance with procedures defined by the owners for each system						
--	--	--	--	--	--	--	--	--

3.1.7. Disaster Recovery

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Incident and Compromise Handling Procedures							
3.1.7.1	An incident management plan shall be developed and approved by the management. The plan shall include the following areas: • Certifying Authority's certification key compromise; • Hacking of systems and network; • Breach of physical security; • Infrastructure availability; • Fraudulent registration and generation of Digital Signature Certificates; and • Digital Signature Certificate suspension and revocation information.	1. Obtain copy of the incident management plan 2. Verify the plan has been approved by the management 3. Validate the plan includes the areas mentioned in the control description	Mandatory	IT CA Rules SCHEDULE III 11.3			
3.1.7.2	An incident response action plan shall be established to ensure the readiness of the Certifying Authority to respond to incidents. The plan should include the following areas: • Compromise control; • Notification to user community; (if applicable) • Revocation of affected Digital Signature Certificates; (if applicable) • Responsibilities of personnel handling incidents; • Investigation of service disruption; • Service restoration procedure; • Monitoring and audit trail analysis; and • Media and public relation	1. Verify an incident response action plan has been established by the CA 2. Validate the plan includes the areas mentioned in the control description	Mandatory	IT CA Rules SCHEDULE III 11.3			
3.1.7.3	A formal security incident reporting procedure exists setting out the actions to be taken on receipt of an incident report. This	1. Verify the security incident reporting procedure and check the following: a. Procedure details	Mandatory	WebTrust 3.5.9			

	includes a definition and documentation of assigned responsibilities and escalation procedures. Any incidents are reported to PA as a matter of urgency.	actions to be taken on receipt of an incident report b. definition and documentation of assigned responsibilities and escalation procedures exist c. procedures have been established for reporting observed or suspected security weaknesses in, or threats to, systems or services as they are detected. d. Procedure exist and are implemented for reporting hardware and software malfunctions e. Procedures exist and are followed to assess that corrective action is taken for reported incidents f. formal problem management process and procedure exist g. help desk is set up to assist users in the resolution of problems. Check tickets raised on helpdesk and their resolution on sample basis						
3.1.7.4	Users of CA systems are required to note and report observed or suspected security weaknesses in, or threats to, systems or services as they are detected.	1. Verify the security incident reporting procedure and check the following: a. Procedure details actions to be taken on receipt of an incident report b. definition and documentation of assigned responsibilities and escalation procedures exist c. procedures have been established for reporting observed or suspected security weaknesses in, or threats to, systems or services as they are detected. d. Procedure exist and are implemented for reporting hardware and software malfunctions e. Procedures exist	Mandatory	WebTrust 3.5.10				

		and are followed to assess that corrective action is taken for reported incidents f. formal problem management process and procedure exist g. help desk is set up to assist users in the resolution of problems. Check tickets raised on helpdesk and their resolution on sample basis						
3.1.7.5	Procedures exist and are followed for reporting hardware and software malfunctions.	1. Verify the security incident reporting procedure and check the following: a. Procedure details actions to be taken on receipt of an incident report b. definition and documentation of assigned responsibilities and escalation procedures exist c. procedures have been established for reporting observed or suspected security weaknesses in, or threats to, systems or services as they are detected. d. Procedure exist and are implemented for reporting hardware and software malfunctions e. Procedures exist and are followed to assess that corrective action is taken for reported incidents f. formal problem management process and procedure exist g. help desk is set up to assist users in the resolution of problems. Check tickets raised on helpdesk and their resolution on sample basis	Mandatory	WebTrust 3.5.11				
3.1.7.6	Procedures exist and are followed to assess that corrective action is taken for reported incidents	1. Verify the security incident reporting procedure and check the following: a. Procedure details actions to be taken on	Mandatory	WebTrust 3.5.12				

		receipt of an incident report b. definition and documentation of assigned responsibilities and escalation procedures exist c. procedures have been established for reporting observed or suspected security weaknesses in, or threats to, systems or services as they are detected. d. Procedure exist and are implemented for reporting hardware and software malfunctions e. Procedures exist and are followed to assess that corrective action is taken for reported incidents f. formal problem management process and procedure exist g. help desk is set up to assist users in the resolution of problems. Check tickets raised on helpdesk and their resolution on sample basis						
3.1.7.7	A formal problem management process exists that allows the types, volumes and impacts of incidents and malfunctions to be documented, quantified and monitored	1. Verify the security incident reporting procedure and check the following: a. Procedure details actions to be taken on receipt of an incident report b. definition and documentation of assigned responsibilities and escalation procedures exist c. procedures have been established for reporting observed or suspected security weaknesses in, or threats to, systems or services as they are detected. d. Procedure exist and are implemented for reporting hardware and software malfunctions e. Procedures exist and are followed to	Mandatory	WebTrust 3.5.13				

		assess that corrective action is taken for reported incidents f. formal problem management process and procedure exist g. help desk is set up to assist users in the resolution of problems. Check tickets raised on helpdesk and their resolution on sample basis						
3.1.7.8	Procedures for identifying, reporting and resolving problems, such as nonfunctioning of Certifying Authority's system; breaches in Information Technology security; and hacking, shall be established and communicated to all personnel concerned. It shall include emergency procedures. Periodic reports shall be submitted for management review	1. Verify the security incident reporting procedure and check the following: a. Procedure details actions to be taken on receipt of an incident report b. definition and documentation of assigned responsibilities and escalation procedures exist c. procedures have been established for reporting observed or suspected security weaknesses in, or threats to, systems or services as they are detected. d. Procedure exist and are implemented for reporting hardware and software malfunctions e. Procedures exist and are followed to assess that corrective action is taken for reported incidents f. formal problem management process and procedure exist g. help desk is set up to assist users in the resolution of problems. Check tickets raised on helpdesk and their resolution on sample basis	Mandatory	IT CA Rules Section II 22				
3.1.7.9	A help desk shall be set up to assist users in the resolution of problems. A system for recording, tracking and reporting the status of reported problems shall be established to	1. Verify the security incident reporting procedure and check the following: a. Procedure details actions to be taken on receipt of an incident	Mandatory	IT CA Rules Section II 22				

	ensure that they are promptly managed and resolved with minimal impact on the user of the computing resources	report b. definition and documentation of assigned responsibilities and escalation procedures exist c. procedures have been established for reporting observed or suspected security weaknesses in, or threats to, systems or services as they are detected. d. Procedure exist and are implemented for reporting hardware and software malfunctions e. Procedures exist and are followed to assess that corrective action is taken for reported incidents f. formal problem management process and procedure exist g. help desk is set up to assist users in the resolution of problems. Check tickets raised on helpdesk and their resolution on sample basis						
Recovery Procedure								
3.1.7.10	Commitment shall be obtained in writing from computer equipment and supplies vendors to replace critical equipment and supplies within a specified period of time following a destruction of the computing facility.	1. Validate the recover procedure is documented and implemented 2. Verify written commitment in form of a contract has been taken from computer equipment and supplies vendors to replace critical equipment and supplies within a specified period of time following a destruction of the computing facility. 3. Check the business continuity plan includes procedures for emergency ordering of equipment and availability of services 4. Verify need for backup hardware is	Mandatory	IT CA Rules SCHEDULE II 24				

		evaluated in accordance to business needs						
3.1.7.11	The business continuity plan shall be developed which inter alia include the procedures for emergency ordering of the equipment and availability of the services.	1. Validate the recover procedure is documented and implemented 2. Verify written commitment in form of a contract has been taken from computer equipment and supplies vendors to replace critical equipment and supplies within a specified period of time following a destruction of the computing facility. 3. Check the business continuity plan includes procedures for emergency ordering of equipment and availability of services 4. Verify need for backup hardware is evaluated in accordance to business needs	Mandatory	IT CA Rules SCHEDULE II 24				
3.1.7.12	The need for backup hardware and other peripherals should be evaluated in accordance to business needs	1. Validate the recover procedure is documented and implemented 2. Verify written commitment in form of a contract has been taken from computer equipment and supplies vendors to replace critical equipment and supplies within a specified period of time following a destruction of the computing facility. 3. Check the business continuity plan includes procedures for emergency ordering of equipment and availability of services 4. Verify need for backup hardware is evaluated in accordance to	Mandatory	IT CA Rules SCHEDULE II 24				

		business needs						
Emergency Preparedness								
3.1.7.13	Emergency response procedures for all activities connected with computer operation shall be developed and documented. These procedures should be reviewed periodically	1. Verify emergency response procedure has been developed and documented 2. Validate emergency drills are held periodically	Mandatory	IT CA Rules SCHEDULE II 23				
3.1.7.14	Emergency drills should be held periodically to ensure that the documented emergency procedures are effective.	1. Verify emergency response procedure has been developed and documented 2. Validate emergency drills are held periodically	Mandatory	IT CA Rules SCHEDULE II 23				
Disaster Recovery/Management								
3.1.7.15	Disaster recovery plan shall be developed, properly documented, tested and maintained to ensure that in the event of a failure of the information system or destruction of the facility, essential level of service will be provided. The disaster recovery framework should include: • emergency procedures, describing the immediate action to be taken in case of a major incident • fall back procedure, describing the actions to be taken to relocate essential activities or support services to a backup site • restoration procedures, describing the action to be taken to return to normal operation at the original site	1. Obtain copy of the documented disaster recovery plan and check the following: a. Plan has been tested and maintained to ensure service will be provided in case of an emergency b. The DR framework includes requirements covered in control 3.1.7.15 c. The documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16 d. Specific disaster management plan is present for critical applications e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster f. Each component/aspect of the plan has a person and a backup assigned to its execution g. Periodic training of personnel and users associated with	Mandatory	IT CA Rules SCHEDULE II 26				

		computer system and network is conducted h. Test plan has been developed and documented i. Results of tests are documented for management review j. DR plan is updated regularly						
3.1.7.16	The documentation should include: • definition of a disaster; • condition for activating the plan; • stages of a crisis; • who will make decisions in the crisis • role of individuals for each component of the plan; • composition of the recovery team; and • decision making process for return to normal operation	1. Obtain copy of the documented disaster recovery plan and check the following: a. Plan has been tested and maintained to ensure service will be provided in case of an emergency b. The DR framework includes requirements covered in control 3.1.7.15 c. The documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16 d. Specific disaster management plan is present for critical applications e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster f. Each component/aspect of the plan has a person and a backup assigned to its execution g. Periodic training of personnel and users associated with computer system and network is conducted h. Test plan has been developed and documented i. Results of tests are documented for management review j. DR plan is updated regularly	Mandatory	IT CA Rules SCHEDULE II 26				
3.1.7.17	Specific disaster	1. Obtain copy of the	Mandatory	IT CA Rules SCHEDULE II 26				

	management plan for critical applications shall be developed, documented, tested and maintained on a regular basis.	documented disaster recovery plan and check the following: a. Plan has been tested and maintained to ensure service will be provided in case of an emergency b. The DR framework includes requirements covered in control 3.1.7.15 c. The documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16 d. Specific disaster management plan is present for critical applications e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster f. Each component/aspect of the plan has a person and a backup assigned to its execution g. Periodic training of personnel and users associated with computer system and network is conducted h. Test plan has been developed and documented i. Results of tests are documented for management review j. DR plan is updated regularly						
3.1.7.18	Responsibilities and reporting structure shall be clearly defined which will take effect immediately on the declaration of a disaster	1. Obtain copy of the documented disaster recovery plan and check the following: a. Plan has been tested and maintained to ensure service will be provided in case of an emergency b. The DR framework includes requirements covered in control 3.1.7.15 c. The documentation covers definition of	Mandatory	IT CA Rules SCHEDULE II 26				

		disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16 d. Specific disaster management plan is present for critical applications e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster f. Each component/aspect of the plan has a person and a backup assigned to its execution g. Periodic training of personnel and users associated with computer system and network is conducted h. Test plan has been developed and documented i. Results of tests are documented for management review j. DR plan is updated regularly					
3.1.7.19	Each component/aspect of the plan should have a person and a backup assigned to its execution	1. Obtain copy of the documented disaster recovery plan and check the following: a. Plan has been tested and maintained to ensure service will be provided in case of an emergency b. The DR framework includes requirements covered in control 3.1.7.15 c. The documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16 d. Specific disaster management plan is present for critical applications e. Responsibilities and reporting structure is clearly defined and will take	Mandatory	T CA Rules SCHEDULE II 26			

		effect immediately on the declaration of a disaster f. Each component/aspect of the plan has a person and a backup assigned to its execution g. Periodic training of personnel and users associated with computer system and network is conducted h. Test plan has been developed and documented i. Results of tests are documented for management review j. DR plan is updated regularly						
3.1.7.20	Periodic training of personnel and users associated with computer system and network should be conducted defining their roles and responsibilities in the event of a disaster	1. Obtain copy of the documented disaster recovery plan and check the following: a. Plan has been tested and maintained to ensure service will be provided in case of an emergency b. The DR framework includes requirements covered in control 3.1.7.15 c. The documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16 d. Specific disaster management plan is present for critical applications e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster f. Each component/aspect of the plan has a person and a backup assigned to its execution g. Periodic training of personnel and users associated with computer system and network is conducted	Mandatory	IT CA Rules SCHEDULE II 26				

		h. Test plan has been developed and documented i. Results of tests are documented for management review j. DR plan is updated regularly						
3.1.7.21	Test plan shall be developed, documented and maintained. Periodic tests shall be carried out to test the effectiveness of the procedures in the plan. The results of the tests shall be documented for management review	1. Obtain copy of the documented disaster recovery plan and check the following: a. Plan has been tested and maintained to ensure service will be provided in case of an emergency b. The DR framework includes requirements covered in control 3.1.7.15 c. The documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16 d. Specific disaster management plan is present for critical applications e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster f. Each component/aspect of the plan has a person and a backup assigned to its execution g. Periodic training of personnel and users associated with computer system and network is conducted h. Test plan has been developed and documented i. Results of tests are documented for management review j. DR plan is updated regularly	Mandatory	IT CA Rules SCHEDULE II 26				
3.1.7.22	Disaster recovery plan should be updated regularly to ensure its	1. Obtain copy of the documented disaster recovery plan and	Mandatory	IT CA Rules SCHEDULE II 26				

	continuing Effectiveness	check the following: a. Plan has been tested and maintained to ensure service will be provided in case of an emergency b. The DR framework includes requirements covered in control 3.1.7.15 c. The documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16 d. Specific disaster management plan is present for critical applications e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster f. Each component/aspect of the plan has a person and a backup assigned to its execution g. Periodic training of personnel and users associated with computer system and network is conducted h. Test plan has been developed and documented i. Results of tests are documented for management review j. DR plan is updated regularly						
Compromise and Disaster Recovery								
3.1.7.23	The Certifying Authority must establish business continuity procedures that outline the steps to be taken in the event of the corruption or loss of computing and networking resources, nominated website, repository, software and/or data. Where a repository is not under the control of the Certifying Authority, the Certifying Authority must ensure that	1. Verify the CA has established business continuity procedures 2. Validate the procedures cover the requirements mentioned in control description	Mandatory	IT CA Rules SCHEDULE III 11.1				

	any agreement with the repository provides for business continuity procedures.							
Secure facility after a natural or other type of disaster								
3.1.7.24	The Certifying Authority must establish a disaster recovery plan outlining the steps to be taken to re-establish a secure facility in the event of a natural or other type of disaster. Where a repository is not under the control of the Certifying Authority the Certifying Authority must ensure that any agreement with the repository provides that a disaster recovery plan be established and documented by the repository.	1. Validate the CAs DR plan covers steps to be taken to re-establish a secure facility in the event of a natural or other type of disaster 2. Verify in case the repository is not under CAs control, CA has signed an agreement with the repository provider that a disaster recovery plan be established and documented by the repositor	Mandatory	IT CA Rules SCHEDULE III 11.2				

3.1.8. Audit Logging

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Retention Period for Audit Logs and Archive							
3.1.8.1	The Certifying Authority must retain its audit logs onsite for at least twelve months	1. Verify on sample basis CA retains audit logs onsite for at least twelve months 2. Validate process has been established original media cannot retain the data for the required period, a mechanism to periodically transfer the archived data to new media is defined by the archive site	Mandatory	IT CA Rules SCHEDULE III 9.3			
3.1.8.2	If the original media cannot retain the data for the required period, a mechanism to periodically transfer the archived data to new media shall be defined by the archive site.	1. Verify on sample basis CA retains audit logs onsite for at least twelve months 2. Validate process has been established original media cannot retain the data for the required period, a mechanism to periodically transfer	Mandatory	X.509 Policy 5.5.2			

		the archived data to new media is defined by the archive site						
Audit Logging								
3.1.8.3	The CA and each Delegated Third Party shall record details of the actions taken to process a certificate request and to issue a Certificate, including all information generated and documentation received in connection with the certificate request; the time and date; and the personnel involved. The CA shall make these records available to its Qualified Auditor as proof of the CA's compliance with these Requirements.	1. Verify on sample basis the CA records details of the actions taken to process a certificate request and to issue a Certificate 2. Validate security audit logs for activities that are core to CAs operations are automatically collected 3. Check all security audit logs, both electronic and non-electronic, are retained and made available during compliance audits	Mandatory	CA Browser Forum 5.4.1				
3.1.8.4	Where possible, the security audit logs shall be automatically collected. Where this is not possible, a logbook, paper form, or other physical mechanism shall be used	1. Verify on sample basis the CA records details of the actions taken to process a certificate request and to issue a Certificate 2. Validate security audit logs for activities that are core to CAs operations are automatically collected 3. Check all security audit logs, both electronic and non-electronic, are retained and made available during compliance audits	Mandatory	X.509 Policy 5.4				
3.1.8.5	The Certifying Authority must maintain secure and reliable records and logs for activities that are core to its operations and review them regularly to detect any anomaly in the system..All security audit logs, both electronic and non-electronic, shall be retained and made available during compliance audits	1. Verify on sample basis the CA records details of the actions taken to process a certificate request and to issue a Certificate 2. Validate security audit logs for activities that are core to CAs operations are automatically	Mandatory	X.509 Policy 5.4, IT Regulations 3				

		collected 3. Check all security audit logs, both electronic and non-electronic, are retained and made available during compliance audits						
Types of Events Recorded								
3.1.8.6	To facilitate decision-making, all agreements and correspondence relating to services provided by Certifying Authority should be collected and consolidated, either electronically or manually, at a single location.	1. Verify the CA collects and consolidates electronically or manually, security information which may not be generated by his system such as covered in control 3.1.8.10 2. Verify all agreements and correspondence relating to services provided by CA are collected and consolidated, either electronically or manually, at a single location.	Mandatory	IT CA Rules SCHEDULE III 9.1				
3.1.8.7	The Certifying Authority shall maintain record of all events relating to the security of his system. The records should be maintained in audit log file and shall include such events as: • System start-up and shutdown; • Certifying Authority's application start-up and shutdown; • Attempts to create, remove, set passwords or change the system • privileges of the PKI Master Officer, PKI Officer, or PKI Administrator; • Changes to keys of the Certifying Authority or any of his other details; • Changes to Digital Signature Certificate creation policies, e.g. validity period; • Login and logoff attempts; • Unauthorised attempts at network access to the Certifying Authority's system; • Unauthorised attempts to access system files; • Generation of own keys; • Creation and revocation of	1. For sample audit log files, check the following details are recorded: a. System start-up and shutdown; b. CA's application start-up and shutdown; c. Attempts to create, remove, set passwords or change the system d. privileges of the PKI Master Officer, PKI Officer, or PKI Administrator; e. Changes to keys of the CA or any of his other details; f. Changes to DSC creation policies g. Login and logoff attempts; h. Unauthorised attempts at network access i. Unauthorised attempts to access system files; j. Generation of own keys;	Mandatory	IT CA Rules SCHEDULE III 9.1				

	Digital Signature Certificates; • Attempts to initialize remove, enable, and disable subscribers, and update and recover their keys; • Failed read-and-write operations on the Digital Signature Certificate and Certificate Revocation List (CRL) directory	k. Creation and revocation of DSC; l. Attempts to initialize remove, enable, and disable subscribers, and update and recover their keys; m. Failed read-and-write operations on the Digital Signature Certificate and Certificate Revocation List (CRL) directory						
3.1.8.8	CA and Subscriber Certificate lifecycle management events, including the following shall be recorded: • Certificate requests, renewal, and re-key requests, and revocation; • All verification activities stipulated in these Requirements and the CA's Certification Practice Statement; • Date, time, phone number used, persons spoken to, and end results of verification telephone calls; • Acceptance and rejection of certificate requests; Issuance of Certificates; and • Generation of Certificate Revocation Lists and OCSP entries	1. On a sample basis validate the CA and Subscriber Certificate lifecycle management events, including the following are recorded: a. Certificate requests, renewal, and re-key requests, and revocation; b. All verification activities stipulated in these Requirements and the CA's Certification Practice Statement; c. Date, time, phone number used, persons spoken to, and end results of verification telephone calls; d. Acceptance and rejection of certificate requests; e. Issuance of Certificates; and f. Generation of Certificate Revocation Lists and OCSP entries	Mandatory	CA Browser Forum 5.4.1				
3.1.8.9	All security auditing capabilities of the CA, CSP, and RA operating system and the CA, CSP, and RA applications required by this CP shall be enabled	1. Verify all security auditing capabilities of the CA, CSP, and RA operating system and the CA, CSP, and RA applications required by this CP are enabled	Mandatory	X.509 Policy 5.4.1				

3.1.8.10	A Certifying Authority should consider the use of automated security management and monitoring tools providing an integrated view of the security situation at any point in time. Records of the following application transactions shall be maintained: • Registration; • Certification; • Publication; • Suspension; and • Revocation.	1. Verify CA has implemented automated security management and monitoring tools providing an integrated view of the security situation at any point in time 2. Validate records of application transactions as mentioned in control 3.1.8.7 are maintained 3. Check the records and log files are reviewed regularly for the activities mentioned in control 3.1.8.8 4. Verify all logs contain date and time of the event and the identity of subscriber/ subordinate/ entity which caused the event	Mandatory	IT CA Rules SCHEDULE III 9.1				
3.1.8.11	Records and log files shall be reviewed regularly for the following activities: • Misuse; • Errors; • Security violations; • Execution of privileged functions; • Change in access control lists; • Change in system configuration	1. Verify CA has implemented automated security management and monitoring tools providing an integrated view of the security situation at any point in time 2. Validate records of application transactions as mentioned in control 3.1.8.7 are maintained 3. Check the records and log files are reviewed regularly for the activities mentioned in control 3.1.8.8 4. Verify all logs contain date and time of the event and the identity of subscriber/ subordinate/ entity which caused the event	Mandatory	IT CA Rules SCHEDULE III 9.1				
3.1.8.12	All logs, whether maintained through electronic or manual means, should contain the date and time of the event,	1. Verify CA has implemented automated security management and	Mandatory	IT CA Rules SCHEDULE III 9.1				

	and the identity of the subscriber/subordinate/ entity which caused the event	monitoring tools providing an integrated view of the security situation at any point in time 2. Validate records of application transactions as mentioned in control 3.1.8.7 are maintained 3. Check the records and log files are reviewed regularly for the activities mentioned in control 3.1.8.8 4. Verify all logs contain date and time of the event and the identity of subscriber/ subordinate/ entity which caused the event						
3.1.8.13	A Certifying Authority should also collect and consolidate, either electronically or manually, security information which may not be generated by his system, such as: • Physical access logs; • System configuration changes and maintenance; • Personnel changes; • Discrepancy and compromise reports; • Records of the destruction of media containing key material, activation data, or personal subscriber information	1. Verify the CA collects and consolidates electronically or manually, security information which may not be generated by his system such as covered in control 3.1.8.10 2. Verify all agreements and correspondence relating to services provided by CA are collected and consolidated, either electronically or manually, at a single location.	Mandatory	IT CA Rules SCHEDULE III 9.1				
3.1.8.14	Log entries shall include the following elements: • Date and time of entry; • Identity of the person making the journal entry; and • Description of the entry.	1. For sample log entries, check the following are recorded: a. Date and time of entry; b. Identity of the person making the journal entry; and c. Description of the entry.	Mandatory	CA Browser Forum 5.4.1				
3.1.8.15	The audit record shall include the following (either recorded automatically or	1. For sample audit records, check the following are	Mandatory	X.509 Policy 5.4.1				

	manually for each auditable event): • The type of event, • The date and time the event occurred • Success or failure where appropriate, and • The identity of the entity and/or operator that caused the even	included: a. The type of event, b. The date and time the event occurred, c. Success or failure where appropriate, and d. The identity of the entity and/or operator that caused the even						
Frequency of Processing Audit Logs								
3.1.8.16	The Certifying Authority must ensure that its audit logs are reviewed by its personnel at least once every two weeks and all significant events are detailed in an audit log summary. Such reviews should involve verifying that the log has not been tampered with, and then briefly inspecting all log entries, with a more thorough investigation of any alerts or irregularities in the logs. Action taken following these reviews must be documented	1. Verify the CA audit logs are reviewed by its personnel at least once every two weeks and all significant events are detailed in an audit log summary 2. Verify audit logs are reviewed at least every 30 days to examine significant sample of security audit data generated by the CA, CSP since the last review 3. Verify the Audit Administrator explains all significant events in an audit log summary	Mandatory	IT CA Rules SCHEDULE III 9.2				
3.1.8.17	Audit logs shall be reviewed at least once every 30 days. Statistically Significant sample of security audit data generated by the CA, CSP, or RA since the last review shall be examined (where the confidence intervals for each category of security audit data are determined by the security ramifications of the category and the availability of tools to perform such a review), as well as a reasonable search for any evidence of malicious activity.	1. Verify the CA audit logs are reviewed by its personnel at least once every two weeks and all significant events are detailed in an audit log summary 2. Verify audit logs are reviewed at least every 30 days to examine significant sample of security audit data generated by the CA, CSP since the last review 3. Verify the Audit Administrator explains all significant events in an audit log summary	Mandatory	X.509 Policy 5.4.2				
3.1.8.18	The Audit Administrator shall explain all significant	1. Verify the CA audit logs are	Mandatory	X.509 Policy 5.4.2				

	events in an audit log summary. Actions taken as a result of reviews involving verifying that the log has not been tampered with, there is no discontinuity or other loss of audit data, and then briefly inspecting all log entries shall be documented.	reviewed by its personnel at least once every two weeks and all significant events are detailed in an audit log summary 2. Verify audit logs are reviewed at least every 30 days to examine significant sample of security audit data generated by the CA, CSP since the last review 3. Verify the Audit Administrator explains all significant events in an audit log summary						
Protection of Audit Logs								
3.1.8.19	The electronic audit log system must include mechanisms to protect the log files from unauthorized viewing, modification, and deletion. Manual audit information must be protected from unauthorised viewing, modification and destruction	1. Verify the electronic audit log system include mechanisms to protect the log files from unauthorized viewing, modification, and deletion 2. Check the system has been configured to ensure only authorized people read and archive audit logs 3. Validate if it is acceptable for the system to over-write audit logs after they have been backed up and archived by asking the CA for practical demonstration	Mandatory	IT CA Rules SCHEDULE III 9.4				
3.1.8.20	System configuration and procedures shall be implemented together to ensure that: • Only authorized people have read access to the logs; • Only authorized people may archive audit logs; and, • Audit logs are not modified.	1. Verify the electronic audit log system include mechanisms to protect the log files from unauthorized viewing, modification, and deletion 2. Check the system has been configured to ensure only authorized people read and archive audit logs 3. Validate if it is acceptable for the	Mandatory	X.509 Policy 5.4.4				

		system to over-write audit logs after they have been backed up and archived by asking the CA for practical demonstration						
3.1.8.21	It shall be acceptable for the system to over-write audit logs after they have been backed up and archived	1. Verify the electronic audit log system include mechanisms to protect the log files from unauthorized viewing, modification, and deletion 2. Check the system has been configured to ensure only authorized people read and archive audit logs 3. Validate if it is acceptable for the system to over-write audit logs after they have been backed up and archived by asking the CA for practical demonstration	Mandatory	X.509 Policy 5.4.4				
Records Archival								
3.1.8.22	Digital Signature Certificates stored and generated by the Certifying Authority must be retained for at least seven years after the date of its expiration. This requirement does not include the backup of private signature keys. Public Key Certificates and Certificate Revocation Lists must be archived for a minimum period of seven years to enable verification of past transactions	Verify the following are stored for at least seven years a. DSC stored and generated by CA after the date of expiration b. Public Key certificates c. Certificate Revocation List d. Audit information e. subscriber agreements f. verification, identification and authentication information in respect of subscriber 2. Validate a second copy of all information retained or backed up is stored at three locations within the country including the CA site 3. Check the primary and	Mandatory	IT CA Rules SCHEDULE III 10, IT Regulations 3				

		secondary sites have security controls in place 4. Verify all information pertaining to CA's operation, Subscriber's application, verification, identification, authentication and Subscriber agreement is stored within the country and taken out of country only with CCA's permission 5. Verify information stored off-site is periodically verified for data integrity 6. On a sample basis verify archived records are sufficiently detailed to establish the proper operation of the component or the validity of any certificate (including those revoked or expired) issued by the CA					
3.1.8.23	Audit information, subscriber agreements, verification, identification and authentication information in respect of subscriber shall be retained for at least seven years	Verify the following are stored for at least seven years a. DSC stored and generated by CA after the date of expiration b. Public Key certificates c. Certificate Revocation List d. Audit information e. subscriber agreements f. verification, identification and authentication information in respect of subscriber 2. Validate a second copy of all information retained or backed up is stored at three locations within the country including the CA site 3. Check the primary and	Mandatory	IT CA Rules SCHEDULE III 10			

		secondary sites have security controls in place 4. Verify all information pertaining to CA's operation, Subscriber's application, verification, identification, authentication and Subscriber agreement is stored within the country and taken out of country only with CCA's permission 5. Verify information stored off-site is periodically verified for data integrity 6. On a sample basis verify archived records are sufficiently detailed to establish the proper operation of the component or the validity of any certificate (including those revoked or expired) issued by the CA						
3.1.8.24	A second copy of all information retained or backed up must be stored at three locations within the country including the Certifying Authority site and must be protected either by physical security alone, or a combination of physical and cryptographic protection. These secondary sites must provide adequate protection from environmental threats such as temperature, humidity and magnetism. The secondary site should be reachable in few hours	Verify the following are stored for at least seven years a. DSC stored and generated by CA after the date of expiration b. Public Key certificates c. Certificate Revocation List d. Audit information e. subscriber agreements f. verification, identification and authentication information in respect of subscriber 2. Validate a second copy of all information retained or backed up is stored at three locations within the country including the CA site 3. Check the primary and	Mandatory	IT CA Rules SCHEDULE III 10				

		secondary sites have security controls in place 4. Verify all information pertaining to CA's operation, Subscriber's application, verification, identification, authentication and Subscriber agreement is stored within the country and taken out of country only with CCA's permission 5. Verify information stored off-site is periodically verified for data integrity 6. On a sample basis verify archived records are sufficiently detailed to establish the proper operation of the component or the validity of any certificate (including those revoked or expired) issued by the CA						
3.1.8.25	All information pertaining to Certifying Authority's operation, Subscriber's application, verification, identification, authentication and Subscriber agreement shall be stored within the country. This information shall be taken out of the country only with the permission of Controller and where a properly constitutional warrant or such other legally enforceable document is produced	Verify the following are stored for at least seven years a. DSC stored and generated by CA after the date of expiration b. Public Key certificates c. Certificate Revocation List d. Audit information e. subscriber agreements f. verification, identification and authentication information in respect of subscriber 2. Validate a second copy of all information retained or backed up is stored at three locations within the country including the CA site 3. Check the primary and	Mandatory	IT CA Rules SCHEDULE III 10				

		secondary sites have security controls in place 4. Verify all information pertaining to CA's operation, Subscriber's application, verification, identification, authentication and Subscriber agreement is stored within the country and taken out of country only with CCA's permission 5. Verify information stored off-site is periodically verified for data integrity 6. On a sample basis verify archived records are sufficiently detailed to establish the proper operation of the component or the validity of any certificate (including those revoked or expired) issued by the CA						
3.1.8.26	Information stored off-site must be periodically verified for data integrity	Verify the following are stored for at least seven years a. DSC stored and generated by CA after the date of expiration b. Public Key certificates c. Certificate Revocation List d. Audit information e. subscriber agreements f. verification, identification and authentication information in respect of subscriber 2. Validate a second copy of all information retained or backed up is stored at three locations within the country including the CA site 3. Check the primary and	Mandatory	IT CA Rules SCHEDULE III 10				

		secondary sites have security controls in place 4. Verify all information pertaining to CA's operation, Subscriber's application, verification, identification, authentication and Subscriber agreement is stored within the country and taken out of country only with CCA's permission 5. Verify information stored off-site is periodically verified for data integrity 6. On a sample basis verify archived records are sufficiently detailed to establish the proper operation of the component or the validity of any certificate (including those revoked or expired) issued by the CA						
3.1.8.27	CA, CSP, and RA archive records shall be sufficiently detailed to establish the proper operation of the component or the validity of any certificate (including those revoked or expired) issued by the CA	Verify the following are stored for at least seven years a. DSC stored and generated by CA after the date of expiration b. Public Key certificates c. Certificate Revocation List d. Audit information e. subscriber agreements f. verification, identification and authentication information in respect of subscriber 2. Validate a second copy of all information retained or backed up is stored at three locations within the country including the CA site 3. Check the primary and	Mandatory	X.509 Policy 5.5.1				

		secondary sites have security controls in place 4. Verify all information pertaining to CA's operation, Subscriber's application, verification, identification, authentication and Subscriber agreement is stored within the country and taken out of country only with CCA's permission 5. Verify information stored off-site is periodically verified for data integrity 6. On a sample basis verify archived records are sufficiently detailed to establish the proper operation of the component or the validity of any certificate (including those revoked or expired) issued by the CA						
Protection of Archive								
3.1.8.28	No unauthorized user shall be permitted to write to, modify, or delete the archive. For the CA and CSP, the authorized individuals are Audit Administrators. For the RA, authorized individuals are someone other than the RA (e.g., Information Assurance Officer or IAO).	1. Verify only authorized users are permitted to write to, modify, or delete the archive 2. Validate the contents of archives are not released 3. Check the archive media are stored in a safe, secure storage facility separate from the component (CA, CSP) with physical and procedural security controls equivalent or better than those for component. Verify the number of times such request to share individual record was made and the record of subscriber was released to his/ her satisfaction	Mandatory	X.509 Policy 5.5.3				

3.1.8.29	The contents of the archive shall not be released except as determined by the CCA, the Licensed CA, or as required by law. Records of individual may be released upon request of any subscribers involved in the transaction or their legally recognized agents.	1. Verify only authorized users are permitted to write to, modify, or delete the archive 2. Validate the contents of archives are not released 3. Check the archive media are stored in a safe, secure storage facility separate from the component (CA, CSP) with physical and procedural security controls equivalent or better than those for component. Verify the number of times such request to share individual record was made and the record of subscriber was released to his/ her satisfaction	Mandatory	X.509 Policy 5.5.3				
3.1.8.30	Archive media shall be stored in a safe, secure storage facility separate from the component (CA, CSP, or RA) with physical and procedural security controls equivalent or better than those for component	1. Verify only authorized users are permitted to write to, modify, or delete the archive 2. Validate the contents of archives are not released 3. Check the archive media are stored in a safe, secure storage facility separate from the component (CA, CSP) with physical and procedural security controls equivalent or better than those for component. Verify the number of times such request to share individual record was made and the record of subscriber was released to his/ her satisfaction	Mandatory	X.509 Policy 5.5.3				
Requirements for Time-Stamping of Records								
3.1.8.31	The Certifying Authority shall provide Time Stamping Service for its subscribers. Error of the Time Stamping clock shall not be more than 1 in 10 ⁹ . Archived records	1. Verify the VA provides time stamping service for its subscribers with error of the Time Stamping clock less	Mandatory	X.509 Policy 5.5.5, IT Regulations 3				

	shall be time stamped such that order of events can be determined	than 1 in 10 ⁹ . 2. Validate on a sample basis that logs in the archive are time stamped						
Procedures to Obtain & Verify Archive Information								
3.1.8.32	Procedures detailing how to create, verify, package, and transmit archive information shall be published in the applicable CPS.	1. Verify for archived information, procedures have been established to perform following activities: a. Creation b. Verification c. Packaging d. Transmission	Mandatory	X.509 Policy 5.5.7				
Audit Trails and Verification								
3.1.8.33	Transactions that meet exception criteria shall be completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction	1. Verify on sample basis the transactions that meet exception criteria are completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction 2. Check audit trails are captured and sensitive information is analyzed to check for indicate possible fraudulent use of the system 3. Verify automated or manual procedures are used to monitor and promptly report all significant security events 4. Validate real time clock of the computer system is set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases. 5. Check computer system access records are kept for a minimum of two years 6. Verify computer	Mandatory	IT CA Rules SCHEDULE II 10				

		records of applications transactions and significant events are retained for a minimum period of two years or longer depending on specific record retention requirements.						
3.1.8.34	Adequate audit trails shall be captured and certain information needed to determine sensitive events and pattern analysis that would indicate possible fraudulent use of the system (e.g. repeated unsuccessful logons, access attempts over a series of days) shall be analyzed. This information includes such information as who, what, when, where, and any special information such as: • Success or failure of the event • Use of authentication keys, where applicable	1. Verify on sample basis the transactions that meet exception criteria are completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction 2. Check audit trails are captured and sensitive information is analyzed to check for indicate possible fraudulent use of the system 3. Verify automated or manual procedures are used to monitor and promptly report all significant security events 4. Validate real time clock of the computer system is set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases. 5. Check computer system access records are kept for a minimum of two years 6. Verify computer records of applications transactions and significant events are retained for a minimum period of two years or longer depending on specific record retention requirements.	Mandatory	IT CA Rules SCHEDULE II 10				

3.1.8.35	Automated or manual procedures shall be used to monitor and promptly report all significant security events, such as accesses, which are out-of pattern relative to time, volume, frequency, type of information asset, and redundancy. Other areas of analysis include: • Significant computer system events (e.g. configuration updates, system crashes) • Security profile changes • Actions taken by computer operations, system administrators, system programmers, and/or security administrators	1. Verify on sample basis the transactions that meet exception criteria are completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction 2. Check audit trails are captured and sensitive information is analyzed to check for indicate possible fraudulent use of the system 3. Verify automated or manual procedures are used to monitor and promptly report all significant security events 4. Validate real time clock of the computer system is set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases. 5. Check computer system access records are kept for a minimum of two years 6. Verify computer records of applications transactions and significant events are retained for a minimum period of two years or longer depending on specific record retention requirements.	Mandatory	IT CA Rules SCHEDULE II 10				
3.1.8.36	The real time clock of the computer system shall be set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases.	1. Verify on sample basis the transactions that meet exception criteria are completely and accurately highlighted and reviewed by personnel independent of	Mandatory	IT CA Rules SCHEDULE II 10				

		those that initiate the transaction 2. Check audit trails are captured and sensitive information is analyzed to check for indicate possible fraudulent use of the system 3. Verify automated or manual procedures are used to monitor and promptly report all significant security events 4. Validate real time clock of the computer system is set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases. 5. Check computer system access records are kept for a minimum of two years 6. Verify computer records of applications transactions and significant events are retained for a minimum period of two years or longer depending on specific record retention requirements.						
3.1.8.37	The real time clock of the computer or communications device shall be set to Indian Standard Time (IST). Further there shall be a procedure that checks and corrects drift in the real time clock.	1. Verify on sample basis the transactions that meet exception criteria are completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction 2. Check audit trails are captured and sensitive information is analyzed to check for indicate possible fraudulent use of the system 3. Verify automated	Mandatory	IT CA Rules SCHEDULE II 10				

		or manual procedures are used to monitor and promptly report all significant security events 4. Validate real time clock of the computer system is set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases. 5. Check computer system access records are kept for a minimum of two years 6. Verify computer records of applications transactions and significant events are retained for a minimum period of two years or longer depending on specific record retention requirements.						
3.1.8.38	Computer system access records shall be kept for a minimum of two years, in either hard copy or electronic form. Records, which are of legal nature and necessary for any legal or regulation requirement or investigation of criminal behavior, shall be retained as per laws of the land	1. Verify on sample basis the transactions that meet exception criteria are completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction 2. Check audit trails are captured and sensitive information is analyzed to check for indicate possible fraudulent use of the system 3. Verify automated or manual procedures are used to monitor and promptly report all significant security events 4. Validate real time clock of the computer system is set accurately to ensure the accuracy	Mandatory	IT CA Rules SCHEDULE II 10				

		of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases. 5. Check computer system access records are kept for a minimum of two years 6. Verify computer records of applications transactions and significant events are retained for a minimum period of two years or longer depending on specific record retention requirements.						
3.1.8.39	Computer records of applications transactions and significant events must be retained for a minimum period of two years or longer depending on specific record retention requirements.	1. Verify on sample basis the transactions that meet exception criteria are completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction 2. Check audit trails are captured and sensitive information is analyzed to check for indicate possible fraudulent use of the system 3. Verify automated or manual procedures are used to monitor and promptly report all significant security events 4. Validate real time clock of the computer system is set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases. 5. Check computer system access records are kept for a minimum of two years 6. Verify computer	Mandatory	IT CA Rules SCHEDULE II 10				

		records of applications transactions and significant events are retained for a minimum period of two years or longer depending on specific record retention requirements.						
Audit Log Backup Procedures								
3.1.8.40	Audit logs and audit summaries must be backed up or copied if in manual form.	1. Validate audit logs and summaries are backed up and copied if in manual form	Mandatory	IT CA Rules SCHEDULE III 9.5				
Vulnerability Assessments								
3.1.8.41	Events in the audit process are logged, in part, to monitor system vulnerabilities. The Certifying Authority must ensure that a vulnerability assessment is performed, reviewed and revised, if necessary, following an examination of these monitored events.	1. Verify the events in the audit process are logged, in part, to monitor system vulnerabilities	Mandatory	IT CA Rules SCHEDULE III 9.6				

3.1.9. Compliance Audit and Other Assessments

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Frequency or circumstances of assessment							
3.1.9.1	The period during which the CA issues Certificates shall be divided into an unbroken sequence of audit periods. An audit period must NOT exceed one year in duration.	1. Verify the annual audits are conducted by the CA 2. Validate CA conducted a point-in-time readiness assessment before issuing Publicly-Trusted Certificates in case a valid audit report did not exist 3. Check the following: a. Point-in-time readiness assessment was completed no earlier than twelve (12) months prior to issuing Publicly-Trusted Certificates b. It was followed	Mandatory	CA Browser Forum 8.1			

		by a complete audit within ninety (90) days of issuing the first Publicly-Trusted Certificate.						
3.1.9.2	If the CA does not have a currently valid Audit Report indicating compliance with the applicable audit schemes, then, before issuing Publicly-Trusted Certificates, the CA shall successfully complete a point-in-time readiness assessment performed in accordance with applicable standards.	1. Verify the annual audits are conducted by the CA 2. Validate CA conducted a point-in-time readiness assessment before issuing Publicly-Trusted Certificates in case a valid audit report did not exist 3. Check the following: a. Point-in-time readiness assessment was completed no earlier than twelve (12) months prior to issuing Publicly-Trusted Certificates b. It was followed by a complete audit within ninety (90) days of issuing the first Publicly-Trusted Certificate.	Mandatory	CA Browser Forum 8.1				
3.1.9.3	The point-in-time readiness assessment shall be completed no earlier than twelve (12) months prior to issuing Publicly-Trusted Certificates and shall be followed by a complete audit under such scheme within ninety (90) days of issuing the first Publicly-Trusted Certificate.	1. Verify the annual audits are conducted by the CA 2. Validate CA conducted a point-in-time readiness assessment before issuing Publicly-Trusted Certificates in case a valid audit report did not exist 3. Check the following: a. Point-in-time readiness assessment was completed no earlier than twelve (12) months prior to issuing Publicly-Trusted Certificates b. It was followed by a complete audit within ninety (90) days of issuing the first Publicly-Trusted Certificate.	Mandatory	CA Browser Forum 8.1				
Identity/qualifications of assessor								

3.1.9.4	The CA’s audit shall be performed by a Qualified Auditor. A Qualified Auditor means a natural person, Legal Entity, or group of natural persons or Legal Entities that collectively possess the following qualifications and skills: • Independence from the subject of the audit • The ability to conduct an audit that addresses the criteria specified in an Eligible Audit Scheme • Employs individuals who have proficiency in examining Public Key Infrastructure technology, information security tools and techniques, information technology and security auditing, and the third party attestation function; • For audits conducted in accordance with any one of the ETSI standard, accredited in accordance with ISO 17065 applying the requirements specified in ETSI EN 319 403; • For audits conducted in accordance with the WebTrust standard, licensed by WebTrust • Bound by law, government regulation, or professional code of ethics; and • Except in the case of an Internal Government Auditing Agency, maintains Professional Liability/Errors	1. Validate that the audit was performed by only by the CCA empaneled agency and auditors. 2. Check the auditor is be independent of the CA being audited	Mandatory	CA Browser Forum 8.2					
Assessor’s relationship to assessed entity									
3.1.9.5	The auditor shall be a firm, which is independent from the entity being audited. The Controller shall determine whether an auditor meets this requirement	1. Verify the auditor is a firm, independent from CA 2. Validate the CCA verifies auditor meets above requirement	Mandatory	CA Browser Forum 8.3, X.509 Policy 8.3					
Topics covered by assessment									
3.1.9.6	CAs shall have a compliance audit mechanism in place to ensure that the requirements of this CP and applicable CPS are being implemented and enforced.	1. Obtain details of the compliance audit mechanism to verify requirements of this CP and applicable CPS are being implemented and enforced	Mandatory	CA Browser Forum 8.4, X.509 Policy 8.4					

Actions taken as a result of deficiency								
3.1.9.7	When the auditor finds a discrepancy between how the CA is designed or is being operated or maintained, and the requirements of this CP, or the applicable CPS, the auditor shall take the following actions: • The auditor shall note the discrepancy; • The auditor shall notify the audited CA; and • The auditor shall notify the office of CCA.	1. For sample discrepancies raised by the auditor, verify the following actions were taken by the auditor: a. auditor noted discrepancy; b. The auditor notified the audited CA; and c. The auditor notified the office of CCA.	Mandatory	CA Browser Forum 8.5, X.509 Policy 8.5				
Communication of results								
3.1.9.8	An Audit Report, including identification of corrective measures taken or being taken by the CA, shall be provided to the Controller (in case of grant of license and its renewal) and the audited CA (in case of annual audit). The report shall identify the versions of the CP and CPS used in the assessment	1. Verify the audit reports are submitted to CCA and the audited CA 2. Validate the report identifies the versions of the CP and CPS used in the assessment	Mandatory	CA Browser Forum 8.6, X.509 Policy 8.6				

3.1.10. Licensing of Certifying Authorities

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Licensing of CA Authorities							
3.1.10.1	To ensure the integrity of its digital certificates, the Certifying Authority shall ensure the use of approved security controls in the certificate management processes, i.e. certificate registration, generation, issuance, publication, renewal, suspension, revocation and archival	1. Verify the CA uses approved security controls in the certificate management processes, i.e. certificate registration, generation, issuance, publication, renewal, suspension, revocation and archival 2. Check the method of verification of the identity of the applicant of a Public Key Certificates commensurate with the level of assurance accorded to the certificate	Mandatory	IT Regulations 3 3	No	3.1.10.1-277	
3.1.10.2	The following persons may apply for grant of a license to issue Digital Signature Certificates, namely:- • an individual, being a	1. Verify the following: a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met	Mandatory	IT CA Rules 8, IT Regulations 3			

	citizen of India and having a capital of five crores of rupees or more in his business or profession; • a company having – o paid up capital of not less than five crores of rupees; and o net worth of not less than fifty crores of rupees • a firm having – o capital subscribed by all partners of not less than five crores of rupees; and o net worth of not less than fifty crores of rupees • Central Government or a State Government or any of the Ministries or Departments, Agencies or Authorities of such Governments.	b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable). c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission d. validity of license is defined for five years from date of issue e. license is not transferable or heritable f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license remains valid. h. CA subjects itself to periodic audits i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within the stipulated period.					
3.1.10.3	The applicant being an individual, or a company, or a firm under sub-rule shall submit a performance bond or furnish a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner	1. Verify the following: a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met b. For licence renewal audit and annual audit, verify the continued maintenance of net	Mandatory	IT CA Rules 8			

	as may be approved by the Controller for an amount of 50 lakhs/ 01 crore of rupees and the performance bond or banker's guarantee shall remain valid for a period of six years from the date of its submission	worth by CA in the last 5 years(if applicable). c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01 crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission d. validity of license is defined for five years from date of issue e. license is not transferable or heritable f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license remains valid. h. CA subjects itself to periodic audits i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within the stipulated period.						
3.1.10.4	The license shall be valid for a period of five years from the date of issue. The license shall not be transferable or heritable	1. Verify the following: a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable). c. applicant submitted a performance bond or	Mandatory	IT Regulations 3				

		furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission d. validity of license is defined for five years from date of issue e. license is not transferable or heritable f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license remains valid. h. CA subjects itself to periodic audits i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within the stipulated period.						
3.1.10.5	The Controller can revoke or suspend the licence in accordance with the provisions of the Act	1. Verify the following: a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable). c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller	Mandatory	IT Regulations 3				

		in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission d. validity of license is defined for five years from date of issue e. license is not transferable or heritable f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license remains valid. h. CA subjects itself to periodic audits i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within the stipulated period.						
3.1.10.6	The Certifying Authority shall be bound to comply with all the parameters against which it was audited prior to issue of licence and shall consistently and continuously comply with those parameters during the period for which the licence shall remain valid.	1. Verify the following: a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable). c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an	Mandatory	IT Regulations 3				

		amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission d. validity of license is defined for five years from date of issue e. license is not transferable or heritable f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license remains valid. h. CA subjects itself to periodic audits i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within the stipulated period.						
3.1.10.7	The Certifying Authority shall subject itself to periodic audits to ensure that all conditions of the licence are consistently complied with by it. As the cryptographic components of the Certifying Authority systems are highly sensitive and critical, the components must be subjected to periodic expert review to ensure their integrity and assurance.	1. Verify the following: a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable). c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee	Mandatory	IT Regulations 3				

		remains valid for a period of six years from the date of its submission d. validity of license is defined for five years from date of issue e. license is not transferable or heritable f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license remains valid. h. CA subjects itself to periodic audits i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within the stipulated period.						
3.1.10.8	The Certifying Authority shall always assure the confidentiality of subscriber information	1. Verify the following: a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable). c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission	Mandatory	IT Regulations 3				

		d. validity of license is defined for five years from date of issue e. license is not transferable or heritable f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license remains valid. h. CA subjects itself to periodic audits i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within the stipulated period.						
3.1.10.9	The Certifying Authority shall comply with every order or direction issued by the Controller within the stipulated period.	1. Verify the following: a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable). c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission d. validity of license is defined for five years from date of issue e. license is not	Mandatory	IT Regulations 3				

		transferable or heritable f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license remains valid. h. CA subjects itself to periodic audits i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within the stipulated period.						
3.1.10.10	The method of verification of the identity of the applicant of a Public Key Certificates shall be commensurate with the level of assurance accorded to the certificate.	1. Verify the CA uses approved security controls in the certificate management processes, i.e. certificate registration, generation, issuance, publication, renewal, suspension, revocation and archival 2. Check the method of verification of the identity of the applicant of a Public Key Certificates commensurate with the level of assurance accorded to the certificate	Mandatory	IT Regulations 3				

3.2. Security Guidelines for Certifying Authorities

3.2.1. CA Business Practices Disclosure

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
CA Business Practices Disclosure							
3.2.1.1	The CA discloses its business practices including but not limited to the topics listed in RFC 3647 in its Certification Practice Statement (CPS)	1. Verify the CA has disclosed its business practices including but not limited to the topics listed in RFC 3647 7 in its CPS and CP	Mandatory	WebTrust 1.1			

3.2.1.2	The CA discloses its business practices including but not limited to the topics listed in RFC 3647 or RFC 2527 in its Certificate Policy (CP)	1. Verify the CA has disclosed its business practices including but not limited to the topics listed in RFC 3647 7 in its CPS and CP	Mandatory	WebTrust 1.2				
---------	---	--	-----------	--------------	--	--	--	--

3.2.2. Business Practices Management

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Certification Practice Statement (CPS) Management							
3.2.2.1	The Certification Practice Statement of the Certifying Authority shall comply with, and be governed by, the laws of the country	1. For the CA's CPS check the following: a. CPS complies with and is governed by laws of the country b. PA has approved the CPS c. Responsibilities for maintaining the CPS have been formally assigned to individuals. d. CPS is modified and approved in as per the defined process e. CPS is available to appropriate parties f. Revisions to the CPS are made available to appropriate parties. g. CA updates CPS as and when required	Mandatory	IT CA Rules 18			
3.2.2.2	The Policy Authority (PA) has final authority and responsibility for approving the CA's Certification Practice Statement (CPS).	1. For the CA's CPS check the following: a. CPS complies with and is governed by laws of the country b. PA has approved the CPS c. Responsibilities for maintaining the CPS have been formally assigned to individuals. d. CPS is modified and approved in as per the defined process e. CPS is available	Mandatory	WebTrust 2.1.1			

		to appropriate parties f. Revisions to the CPS are made available to appropriate parties. g. CA updates CPS as and when required						
3.2.2.3	Responsibilities for maintaining the CPS have been formally assigned.	1. For the CA's CPS check the following: a. CPS complies with and is governed by laws of the country b. PA has approved the CPS c. Responsibilities for maintaining the CPS have been formally assigned to individuals. d. CPS is modified and approved in as per the defined process e. CPS is available to appropriate parties f. Revisions to the CPS are made available to appropriate parties. g. CA updates CPS as and when required	Mandatory	WebTrust 2.1.2				
3.2.2.4	The CA's CPS is modified and approved in accordance with a defined review process.	1. For the CA's CPS check the following: a. CPS complies with and is governed by laws of the country b. PA has approved the CPS c. Responsibilities for maintaining the CPS have been formally assigned to individuals. d. CPS is modified and approved in as per the defined process e. CPS is available to appropriate parties f. Revisions to the CPS are made available to appropriate parties.	Mandatory	WebTrust 2.1.3				

		g. CA updates CPS as and when required						
3.2.2.5	The CA makes available its Certification Practice Statement (CPS) to all appropriate parties	1. For the CA's CPS check the following: a. CPS complies with and is governed by laws of the country b. PA has approved the CPS c. Responsibilities for maintaining the CPS have been formally assigned to individuals. d. CPS is modified and approved in as per the defined process e. CPS is available to appropriate parties f. Revisions to the CPS are made available to appropriate parties. g. CA updates CPS as and when required	Mandatory	WebTrust 2.1.4				
3.2.2.6	Revisions to the CA's CPS are made available to appropriate parties.	1. For the CA's CPS check the following: a. CPS complies with and is governed by laws of the country b. PA has approved the CPS c. Responsibilities for maintaining the CPS have been formally assigned to individuals. d. CPS is modified and approved in as per the defined process e. CPS is available to appropriate parties f. Revisions to the CPS are made available to appropriate parties. g. CA updates CPS as and when required	Mandatory	WebTrust 2.1.5				

3.2.2.7	The CA updates its CPS to reflect changes in the environment as they occur	1. For the CA's CPS check the following: a. CPS complies with and is governed by laws of the country b. PA has approved the CPS c. Responsibilities for maintaining the CPS have been formally assigned to individuals. d. CPS is modified and approved in as per the defined process e. CPS is available to appropriate parties f. Revisions to the CPS are made available to appropriate parties. g. CA updates CPS as and when required	Mandatory	WebTrust 2.1.6				
Certificate Policy (CP) Management								
3.2.2.8	The Policy Authority (PA) has the responsibility of defining the business requirements and policies for using digital certificates and specifying them in a Certificate Policy (CP) and supporting agreements	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.2.1				
3.2.2.9	The PA has final authority and responsibility for specifying and approving Certificate Policy(s).	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.2.2				
3.2.2.10	Certificate Policy(s) are approved by the Policy Authority in accordance with a defined annual review process, including responsibilities for maintaining and tracking changes to the Certificate Policy(s).	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.2.3				
3.2.2.11	A defined review process exists to assess that the Certificate Policy(s) are capable of support by the controls specified in the CPS.	1. No action required by the auditor for checking the controls as CP	Mandatory	WebTrust 2.2.4				

		template is shared by CCA						
3.2.2.12	The PA makes available the Certificate Policies supported by the CA to Subscribers and Relying Parties	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.2.5				
CP and CPS Consistency								
3.2.2.13	The PA is responsible for ensuring that the CA's control processes, as stated in a Certification Practice Statement (CPS) or equivalent, fully comply with the requirements of the CP.	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.3.1				
3.2.2.14	The CA addresses the requirements of the CP when developing its CPS	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.3.2				
3.2.2.15	The CA assesses the impact of proposed CPS changes to ensure that they are consistent with the CP.	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.3.3				
3.2.2.16	A defined review process exists to ensure that Certificate Policy(s) are supported by the CA's CPS.	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	WebTrust 2.3.4				
3.2.2.17	All changes in Certificate Policy and certification practice statement shall be published on the web site of the Certifying Authority and brought to the notice of the Controller well in advance of such publication. However any change shall not contravene any provision of the Act, rule or regulation or made there under.	1. No action required by the auditor for checking the controls as CP template is shared by CCA	Mandatory	IT Regulations 3				

3.2.3. Change Management

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Change Management							
3.2.3.1	Software testing and change control procedures exist and are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes.	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code,	Mandatory	WebTrust 3.7.2			

		data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented						
3.2.3.2	Change control procedures exist and are followed for the hardware, network component, and system configuration changes.	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system	Mandatory	WebTrust 3.7.3				

		j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented						
3.2.3.3	Application systems are reviewed and tested when operating system changes occur	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are	Mandatory	WebTrust 3.7.6				

		implemented in the production h. Authorisation procedures for change control is defined and documented. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented						
3.2.3.4	The implementation of changes is strictly controlled by the use of formal change control procedures to minimize the risk of corruption of information systems.	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management	Mandatory	WebTrust 3.7.7				

		process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented					
3.2.3.5	Organizational responsibilities for the change management process shall be defined and assigned	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system	Mandatory	IT CA Rules SCHEDULE II 21.1			

		changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented					
3.2.3.6	A risk and impact analysis, classification and prioritisation process shall be established	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency	Mandatory	IT CA Rules SCHEDULE II 21.1			

		software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented						
3.2.3.7	No changes to a production system shall be implemented until such changes have been	1. Obtain copy of CAs Change control procedures and check the following:	Mandatory	IT CA Rules SCHEDULE II 21.1				

	formally authorised. Authorisation procedures for change control shall be defined and documented	a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documented. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices						
--	--	---	--	--	--	--	--	--

		is documented						
3.2.3.8	Owners/Users shall be notified of all changes made to production system which may affect the processing of information on the said production system	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to	Mandatory	IT CA Rules SCHEDULE II 21.1				

		production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented						
3.2.3.9	Fall-back procedures in the event of a failure in the implementation of the change process shall be established and documented.	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production	Mandatory	IT CA Rules SCHEDULE II 21.1				

		system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented						
3.2.3.10	Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation shall be documented and implemented	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally	Mandatory	IT CA Rules SCHEDULE II 21.1				

		authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documented i. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented						
3.2.3.11	Version changes of application software and all system software installed on the computer systems and all communication devices shall be documented. Different versions of application software and system software must be kept in safe custody	1. Obtain copy of CAs Change control procedures and check the following: a. Software testing and change control procedures are followed for the implementation of software on operational systems including scheduled software releases, modifications, patches, and emergency software fixes b. Change control procedures are followed for the hardware, network component, and system configuration changes c. Application systems are reviewed and tested when operating system changes occur d. On a sample basis check that the implementation of changes are strictly controlled by the use of formal change control procedures e. responsibilities for	Mandatory	IT CA Rules SCHEDULE II 21.1				

		the change management process are defined and assigned f. risk and impact analysis, classification and prioritisation process are established as part of the procedure , check on sample basis g. only formally authorized changes are implemented in the production h. Authorisation procedures for change control is defined and documentedi. Owners/Users are notified of all changes made to production system j. Fall-back procedures in the event of a failure in the implementation of the change process are established and documented k. Procedures to protect, control access and changes to production source code, data, execution statements and relevant system documentation are documented and implemented l. Version changes of all application software, system software and communication devices is documented							
Testing Of Changes To Production System									
3.2.3.12	All changes in computer resource proposed in the production system shall be tested and the test results shall be reviewed and accepted by all concerned parties prior to implementation.	1. On a sample basis verify all changes in computer resource proposed in the production system are tested and the test results are reviewed and accepted by all concerned parties prior to implementation. 2. Validate user acceptance tests are performed in a controlled environment which includes requirements mentioned in control 3.2.2.13	Mandatory	IT CA Rules SCHEDULE II 21.2					
3.2.3.13	All user acceptance tests in respect of changes in	1. On a sample basis verify all changes in	Mandatory	IT CA Rules SCHEDULE II 21.2					

	computer resource in production system shall be performed in a controlled environment which includes: (i) Test objectives, (ii) A documented test plan, and (iii) acceptance criteria.	computer resource proposed in the production system are tested and the test results are reviewed and accepted by all concerned parties prior to implementation. 2. Validate user acceptance tests are performed in a controlled environment which includes requirements mentioned in control 3.2.2.13						
Review Of Changes								
3.2.3.14	Procedures shall be established for an independent review of programme changes before they are moved into a production environment to detect unauthorized or malicious codes	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall be clearly and properly	Mandatory	IT CA Rules SCHEDULE II 21.3				

		documented						
3.2.3.15	Procedures shall be established to schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall be clearly and properly documented	Mandatory	IT CA Rules SCHEDULE II 21.3				
3.2.3.16	All emergency changes/fixes in computer resource in the production system shall be reviewed and approved	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system	Mandatory	IT CA Rules SCHEDULE II 21.3				

		so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall be clearly and properly documented						
3.2.3.17	Periodic management reports on the status of the changes implemented in the computer resourced in the production system shall be submitted for management review	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for	Mandatory	IT CA Rules SCHEDULE II 21.3				

		management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall be clearly and properly documented						
3.2.3.18	Software updates and patches shall be reviewed for security implications before being implemented on Certifying Authority's system	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and	Mandatory	IT CA Rules SCHEDULE III 7				

		patches and their implementation on CA's system shall be clearly and properly documented						
3.2.3.19	Software updates and patches to rectify security vulnerability in critical systems used for Certifying Authority's operation shall be promptly reviewed and implemented	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall be clearly and properly documented	Mandatory	IT CA Rules SCHEDULE III 7				
3.2.3.20	Information on the software updates and patches and their implementation on Certifying Authority's system shall be clearly and properly documented	1. Verify the change management procedure mentions the following: a. an independent review of programme b. changes before they are moved into a production environment c. schedule and review	Mandatory	IT CA Rules SCHEDULE III 7				

		the implementation of the changes in computer resource in the production system so as to ensure proper functioning 2. Validate on sample basis for latest changes/ fixes in computer resource in the production system are reviewed and approved 3. Verify periodic management reports on the status of the changes implemented in the computer resourced in the production system are submitted for management review 4. Check the software updates and patches are reviewed for security implications before being implemented 5. Verify the software updates and patches to rectify security vulnerability in critical systems used are promptly reviewed and implemented 6. Validate the information on the software updates and patches and their implementation on CA's system shall be clearly and properly documented						
--	--	---	--	--	--	--	--	--

3.2.4. Operations Management

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Operations Management							
3.2.4.1	CA operating procedures are documented and maintained for each functional area.	1. Verify CA has documented operating procedures for functional areas and check the following: a. Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures b. Duties and areas of responsibility are segregated c. Development and testing facilities are separated from operational facilities	Mandatory	WebTrust 3.5.1			

		d. Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract. e. Capacity demands are monitored and projections of future capacity requirements made f. On a sample basis check that the acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance						
3.2.4.2	Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures.	1. Verify CA has documented operating procedures for functional areas and check the following: a. Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures b. Duties and areas of responsibility are segregated c. Development and testing facilities are separated from operational facilities d. Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract. e. Capacity demands are monitored and projections of future capacity requirements made f. On a sample basis check that the acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance	Mandatory	WebTrust 3.5.2				
3.2.4.3	Duties and areas of responsibility are segregated in order to reduce opportunities for	1. Verify CA has documented operating procedures for functional areas and check the	Mandatory	WebTrust 3.5.3				

	unauthorized modification or misuse of information or services	following: a. Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures b. Duties and areas of responsibility are segregated c. Development and testing facilities are separated from operational facilities d. Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract. e. Capacity demands are monitored and projections of future capacity requirements made f. On a sample basis check that the acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance						
3.2.4.4	Development and testing facilities are separated from operational facilities	1. Verify CA has documented operating procedures for functional areas and check the following: a. Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures b. Duties and areas of responsibility are segregated c. Development and testing facilities are separated from operational facilities d. Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract. e. Capacity demands are monitored and projections of future capacity requirements made f. On a sample basis	Mandatory	WebTrust 3.5.4				

		check that the acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance						
3.2.4.5	Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract.	1. Verify CA has documented operating procedures for functional areas and check the following: a. Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures b. Duties and areas of responsibility are segregated c. Development and testing facilities are separated from operational facilities d. Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract. e. Capacity demands are monitored and projections of future capacity requirements made f. On a sample basis check that the acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance	Mandatory	WebTrust 3.5.5				
3.2.4.6	Capacity demands are monitored and projections of future capacity requirements made to ensure that adequate processing power and storage are available.	1. Verify CA has documented operating procedures for functional areas and check the following: a. Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures b. Duties and areas of responsibility are segregated c. Development and testing facilities are separated from	Mandatory	WebTrust 3.5.6				

		operational facilities d. Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract. e. Capacity demands are monitored and projections of future capacity requirements made f. On a sample basis check that the acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance						
3.2.4.7	Acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance	1. Verify CA has documented operating procedures for functional areas and check the following: a. Formal management responsibilities and procedures exist to control all changes to CA equipment, software and operating procedures b. Duties and areas of responsibility are segregated c. Development and testing facilities are separated from operational facilities d. Prior to using external facilities management services, risks and related controls are identified, agreed upon with the contractor, and incorporated into the contract. e. Capacity demands are monitored and projections of future capacity requirements made f. On a sample basis check that the acceptance criteria for new information systems, upgrades and new versions are established and suitable tests of the system carried out prior to acceptance	Mandatory	WebTrust 3.5.7				

3.2.5. Measures to handle computer virus

Control	Control	Audit Checks	Control	References	Compliance	Document	Remarks
---------	---------	--------------	---------	------------	------------	----------	---------

No.			Type					
Measures to handle computer virus								
3.2.5.1	Detection and prevention controls to protect against viruses and malicious software, including on offline or air gapped systems are implemented. Employee awareness programs are in place.	1. Verify detection and prevention controls to protect against viruses and malicious software, including on offline or air gapped systems are implemented 2. Check an employee awareness program is implemented 3. Validate names of personal responsible for ensuring all file servers and personal computers are equipped with up-to-date virus protection and detection software. 4. Check if virus detection software is being used to check storage drives internal and external to the system on a periodic basis 5. Verify all diskettes and software are screened and verified by virus detection software before being loaded onto the computer system 6. Check magnetic media like tape cartridge, floppies etc. brought from outside are used on the data, file, PKI or computer server or personal computer on Intranet and Internet only after proper screening and verification by virus detection software	Mandatory	WebTrust 3.5.8				
3.2.5.2	Responsibilities and duties shall be assigned to ensure that all file servers and personal computers are equipped with up-to-date virus protection and detection software.	1. Verify detection and prevention controls to protect against viruses and malicious software, including on offline or air gapped systems are implemented 2. Check an employee awareness program is implemented 3. Validate names of personal responsible for ensuring all file servers and personal	Mandatory	IT CA Rules SCHEDULE II 11				

		computers are equipped with up-to-date virus protection and detection software. 4. Check if virus detection software is being used to check storage drives internal and external to the system on a periodic basis 5. Verify all diskettes and software are screened and verified by virus detection software before being loaded onto the computer system 6. Check magnetic media like tape cartridge, floppies etc. brought from outside are used on the data, file, PKI or computer server or personal computer on Intranet and Internet only after proper screening and verification by virus detection software					
3.2.5.3	Virus detection software must be used to check storage drives both internal and external to the system on a periodic basis	1. Verify detection and prevention controls to protect against viruses and malicious software, including on offline or air gapped systems are implemented 2. Check an employee awareness program is implemented 3. Validate names of personal responsible for ensuring all file servers and personal computers are equipped with up-to-date virus protection and detection software. 4. Check if virus detection software is being used to check storage drives internal and external to the system on a periodic basis 5. Verify all diskettes and software are screened and verified by virus detection software before being loaded onto the	Mandatory	IT CA Rules SCHEDULE II 11			

		computer system 6. Check magnetic media like tape cartridge, floppies etc. brought from outside are used on the data, file, PKI or computer server or personal computer on Intranet and Internet only after proper screening and verification by virus detection software						
3.2.5.4	All diskettes and software shall be screened and verified by virus detection software before being loaded onto the computer system. No magnetic media like tape cartridge, floppies etc. brought from outside shall be used on the data, file, PKI or computer server or personal computer on Intranet and Internet without proper screening and verification by virus detection software	1. Verify detection and prevention controls to protect against viruses and malicious software, including on offline or air gapped systems are implemented 2. Check an employee awareness program is implemented 3. Validate names of personal responsible for ensuring all file servers and personal computers are equipped with up-to-date virus protection and detection software. 4. Check if virus detection software is being used to check storage drives internal and external to the system on a periodic basis 5. Verify all diskettes and software are screened and verified by virus detection software before being loaded onto the computer system 6. Check magnetic media like tape cartridge, floppies etc. brought from outside are used on the data, file, PKI or computer server or personal computer on Intranet and Internet only after proper screening and verification by virus detection software	Mandatory	IT CA Rules SCHEDULE II 11				
3.2.5.5	A team shall be designated	1. Verify a team is	Mandatory	IT CA Rules SCHEDULE II 11				

	to deal with reported or suspected incidents of computer virus. The designated team shall ensure that latest version of antivirus software is loaded on all data, file, PKI servers and personal computers.	established for incidents management of computer virus 2. Validate the team ensures latest version of antivirus software is loaded on all data, file, PKI servers and personal computers.						
3.2.5.6	Procedures shall be established to limit the spread of viruses to other organization information assets. Such procedures inter alia shall include: • Communication to other business partners and users who may be at risk from an infected resource • Eradication and recovery procedures • Incident report must be documented and communicated per established procedures	1. Verify by checking procedures are established to limit the spread of viruses to other organization information assets 2. Check awareness and training programs are in place to communicate virus protection practices, available controls, areas of high risk to virus infection and responsibilities	Mandatory	IT CA Rules SCHEDULE II 11				
3.2.5.7	An awareness and training programme shall be established to communicate virus protection practices, available controls, areas of high risk to virus infection and responsibilities	1. Verify by checking procedures are established to limit the spread of viruses to other organization information assets 2. Check awareness and training programs are in place to communicate virus protection practices, available controls, areas of high risk to virus infection and responsibilities	Mandatory	IT CA Rules SCHEDULE II 11				

3.2.6. Relocation of hardware and software

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Relocation of hardware and software							
3.2.6.1	Whenever computers or computer peripherals are relocated (e.g. for maintenance, installation at different sites or storage), the following guidelines shall apply: • All removable media will be removed from the computer system and kept at secure location. • Internal drives will be overwritten, reformatted or removed as the	1. Perform walkthrough and verify Relocation of hardware and software is performed as per requirements mentioned in the control description	Mandatory	IT CA Rules SCHEDULE II 12			

	situation may be. • If applicable, ribbons will be removed from printers. • All paper will be removed from printers.							
--	---	--	--	--	--	--	--	--

3.2.7. Hardware and software maintenance

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Hardware and software maintenance							
3.2.7.1	Proper placement and installation of Information Technology equipment to reduce the effects of interference due to electromagnetic emanations.	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements	Mandatory	IT CA Rules SCHEDULE II 13			
3.2.7.2	Maintenance of an inventory and configuration chart of	1. For the hardware and software maintenance performed in the CA	Mandatory	IT CA Rules SCHEDULE II 13			

	hardware	system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements					
3.2.7.3	Identification and use of security features implemented within hardware.	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made	Mandatory	IT CA Rules SCHEDULE II 13			

		to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements						
3.2.7.4	Authorization, documentation, and control of change made to the hardware	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and	Mandatory	IT CA Rules SCHEDULE II 13				

		firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements						
3.2.7.5	Identification of support facilities including power and air conditioning	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements	Mandatory	IT CA Rules SCHEDULE II 13				
3.2.7.6	Provision of an uninterruptible power supply.	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference	Mandatory	IT CA Rules SCHEDULE II 13				

		b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements						
3.2.7.7	Organization must make proper arrangements for maintenance of computer hardware, software (both system and application) and firmware installed and used by them	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been	Mandatory	IT CA Rules SCHEDULE II 13				

		installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements						
3.2.7.8	It shall be the responsibility of the officer in charge of the operational site to ensure that contract for annual maintenance of hardware is always in place.	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements	Mandatory	IT CA Rules SCHEDULE II 13				

3.2.7.9	Organization must enter into maintenance agreements, if necessary, with the supplier of computer and communication hardware, software (both system and application) and firmware.	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements	Mandatory	IT CA Rules SCHEDULE II 13				
3.2.7.10	Maintenance personnel will sign non-disclosure agreements	1. For the hardware and software maintenance performed in the CA system check the following: a. secure placement and installation of IT equipment has been done to prevent electromagnetic interference b. inventory and configuration chart of hardware are maintained c. security features within hardware are identified and implemented	Mandatory	IT CA Rules SCHEDULE II 13				

		d. Authorization, documentation, and control of change made to the hardware is defined e. Provision of an uninterruptible power supply is present f. support facilities including power and air conditioning have been installed g. annual maintenance of hardware is in place h. maintenance agreements have been signed with the supplier of computer and communication hardware, software (both system and application) and firmware i. On a sample basis that maintenance personnel have signed non-disclosure agreements						
--	--	---	--	--	--	--	--	--

3.2.8. Purchase and Licensing of Hardware and Software

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Purchase and Licensing of Hardware and Software							
3.2.8.1	Hardware and software products that contain or are to be used to enforce security, and intended for use or interface into any organization system or network, must be verified to comply with these Information Technology Security Guidelines prior to the signing of any contract, purchase or lease.	Validate the hardware and software products comply with the Information Technology Security Guidelines	Mandatory	IT CA Rules SCHEDULE II 14			
3.2.8.2	Software, which is capable of bypassing or modifying the security system or operating system, integrity features, must be verified to determine that they conform to these Information Technology Security Guidelines. Where such compliance is not possible, then procedures shall be in place to ensure that the implementation and operation of that software does not compromise the	1. Verify procedures have been implemented to ensure that the implementation and operation of that software does not compromise the security of the system	Mandatory	IT CA Rules SCHEDULE II 14			

	security of the system.							
3.2.8.3	There shall be procedures to identify, select, implement and control software (system and application software) acquisition and installation to ensure compliance with the Indian Copyright Act and Information Technology Security Guidelines.	1. Validate procedures have been implemented to identify, select, implement and control software (system and application software) acquisition and installation 2. Check that it is in compliance with the Indian Copyright Act and Information Technology Security Guidelines	Mandatory	IT CA Rules SCHEDULE II 14				
3.2.8.4	It is prohibited to knowingly install on any system whether test or production, any software which is not licensed for use on the specific systems or networks.	1. For software installed on the CA systems verify the following: a. only licensed software are installed on systems used for CA operations b. licensing agreements exists for software installed and used on CA systems c. Illegally acquired or unauthorized software are not used on any computer, computer network or data communication equipment d. System Administrator or Network Administrator are responsible for removing any illegal software if detected	Mandatory	IT CA Rules SCHEDULE II 14				
3.2.8.5	No software will be installed and used on the system when appropriate licensing agreements do not exist, except during evaluation periods for which the user has documented permission to install and test the software under evaluation.	1. For software installed on the CA systems verify the following: a. only licensed software are installed on systems used for CA operations b. licensing agreements exists for software installed and used on CA systems c. Illegally acquired or unauthorized software are not used on any computer,	Mandatory	IT CA Rules SCHEDULE II 14				

		computer network or data communication equipment d. System Administrator or Network Administrator are responsible for removing any illegal software if detected						
3.2.8.6	Illegally acquired or unauthorized software must not be used on any computer, computer network or data communication equipment. In the event that any illegally acquired or unauthorized software is detected by the System Administrator or Network Administrator, the same must be removed	1. For software installed on the CA systems verify the following: a. only licensed software are installed on systems used for CA operations b. licensing agreements exists for software installed and used on CA systems c. Illegally acquired or unauthorized software are not used on any computer, computer network or data communication equipment d. System Administrator or Network Administrator are responsible for removing any illegal software if detected	Mandatory	IT CA Rules SCHEDULE II 14				

3.2.9. System Software

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
System Software							
3.2.9.1	All system software options and parameters shall be reviewed and approved by the management.	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementation. c. Vendor supplied default IDs are deleted or password changes before users access the computer system	Mandatory	IT CA Rules SCHEDULE II 15			

		d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All "Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment					
3.2.9.2	System software shall be comprehensively tested and its security functionality validated prior to implementation.	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementation. c. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed	Mandatory	IT CA Rules SCHEDULE II 15			

		in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All "Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment					
3.2.9.3	All vendor supplied default user IDs shall be deleted or password changed before allowing users to access the computer system	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementation. c. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to	Mandatory	IT CA Rules SCHEDULE II 15			

		system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All "Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment						
3.2.9.4	Versions of system software installed on the computer system and communication devices shall be regularly updated	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementation. c. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for	Mandatory	IT CA Rules SCHEDULE II 15				

		the system libraries h. All "Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment						
3.2.9.5	All changes proposed in the system software must be appropriately justified and approved by an authorized party	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementation. c. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All "Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access	Mandatory	IT CA Rules SCHEDULE II 15				

		to the application system's data and programme files in the production environment						
3.2.9.6	A log of all changes to system software shall be maintained, completely documented and tested to ensure the desired results.	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementation. c. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All "Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment	Mandatory	IT CA Rules SCHEDULE II 15				

3.2.9.7	There shall be no standing "Write" access to the system libraries. All "Write" access shall be logged and reviewed by the System Administrator for dubious activities.	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA management b. System software are tested and its security functionality validated prior to implementation. c. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All "Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment	Mandatory	IT CA Rules SCHEDULE II 15				
3.2.9.8	System Programmers shall not be allowed to have access to the application system's data and programme files in the production environment	1. For the CAs system software check the following: a. the system software operations and parameters are reviewed and approved by CA	Mandatory	IT CA Rules SCHEDULE II 15				

		management b. System software are tested and its security functionality validated prior to implementation. c. Vendor supplied default IDs are deleted or password changes before users access the computer system d. On sample basis that the versions of system software installed on the computer system and communication devices are regularly updated e. Changes proposed in the system software are appropriately justified and approved by an authorized party (check for recent sample changes performed) f. log of all changes to system software are maintained, completely documented and tested to ensure the desired results g. no standing "Write" access is present for the system libraries h. All "Write" access are logged and reviewed by the System Administrator i. System Programmers are not allowed to have access to the application system's data and programme files in the production environment						
3.2.9.9	Procedures to control the use of sensitive system utilities and system programmes that could bypass intended security controls shall be in place and documented. All usage shall be logged and reviewed by the System Administrator and another person independent of System Administrator for dubious activities.	1. Verify documented procedure is present to control the use of sensitive system utilities and system programmes 2. Validate all usage is logged and reviewed by the System Administrator and another person independent of System Administrator for dubious activities	Mandatory	IT CA Rules SCHEDULE II 15				

--	--	--	--	--	--	--	--	--

3.2.10. Documentation Security

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Documentation Security							
3.2.10.1	All documentation pertaining to application software and sensitive system software and changes made therein shall be updated to the current time, accurately and stored securely. An up-to-date inventory list of all documentation shall be maintained to ensure control and accountability.	1. Conduct a walkthrough of the documentation security process and verify the following: a. Documents pertaining to application software and sensitive system software are updated to the current time, accurately and stored securely. b. up-to-date inventory list of all documentation is maintained c. all documentation and subsequent changes are reviewed and approved by an independent authorized party prior to issue d. Access to application software documentation and sensitive system software documentation is restricted to authorized personnel on a "need-to-use" basis only e. Adequate backups of all documentation are maintained f. Copy of all critical documents and manuals is stored off site g. Documents are classified according to sensitivity h. Clear Desks policy has been implemented	Mandatory	IT CA Rules SCHEDULE II 16			
3.2.10.2	All documentation and subsequent changes shall be reviewed and approved by an independent authorized party prior to issue	1. Conduct a walkthrough of the documentation security process and verify the following: a. Documents	Mandatory	IT CA Rules SCHEDULE II 16			

		pertaining to application software and sensitive system software are updated to the current time, accurately and stored securely. b. up-to-date inventory list of all documentation is maintained c. all documentation and subsequent changes are reviewed and approved by an independent authorized party prior to issue d. Access to application software documentation and sensitive system software documentation is restricted to authorized personnel on a "need-to-use" basis only e. Adequate backups of all documentation are maintained f. Copy of all critical documents and manuals is stored off site g. Documents are classified according to sensitivity h. Clear Desks policy has been implemented						
3.2.10.3	Access to application software documentation and sensitive system software documentation shall be restricted to authorized personnel on a "need-to-use" basis only	1. Conduct a walkthrough of the documentation security process and verify the following: a. Documents pertaining to application software and sensitive system software are updated to the current time, accurately and stored securely. b. up-to-date inventory list of all documentation is maintained c. all documentation and subsequent changes are reviewed and approved by an independent authorized party	Mandatory	IT CA Rules SCHEDULE II 16				

		prior to issue d. Access to application software documentation and sensitive system software documentation is restricted to authorized personnel on a "need-to-use" basis only e. Adequate backups of all documentation are maintained f. Copy of all critical documents and manuals is stored off site g. Documents are classified according to sensitivity h. Clear Desks policy has been implemented						
3.2.10.4	Adequate backups of all documentation shall be maintained and a copy of all critical documentation and manuals shall be stored off-site.	1. Conduct a walkthrough of the documentation security process and verify the following: a. Documents pertaining to application software and sensitive system software are updated to the current time, accurately and stored securely. b. up-to-date inventory list of all documentation is maintained c. all documentation and subsequent changes are reviewed and approved by an independent authorized party prior to issue d. Access to application software documentation and sensitive system software documentation is restricted to authorized personnel on a "need-to-use" basis only e. Adequate backups of all documentation are maintained f. Copy of all critical documents and manuals is stored off	Mandatory	IT CA Rules SCHEDULE II 16				

		site g. Documents are classified according to sensitivity h. Clear Desks policy has been implemented						
3.2.10.5	Documentation shall be classified according to the sensitivity of its contents/ implications	1. Conduct a walkthrough of the documentation security process and verify the following: a. Documents pertaining to application software and sensitive system software are updated to the current time, accurately and stored securely. b. up-to-date inventory list of all documentation is maintained c. all documentation and subsequent changes are reviewed and approved by an independent authorized party prior to issue d. Access to application software documentation and sensitive system software documentation is restricted to authorized personnel on a "need-to-use" basis only e. Adequate backups of all documentation are maintained f. Copy of all critical documents and manuals is stored off site g. Documents are classified according to sensitivity h. Clear Desks policy has been implemented	Mandatory	T CA Rules SCHEDULE II 16				
3.2.10.6	Organizations shall adopt a clean desk policy for papers, diskettes and other documentation in order to reduce the risks of unauthorized access, loss of	1. Conduct a walkthrough of the documentation security process and verify the following: a. Documents	Mandatory	IT CA Rules SCHEDULE II 16				

	and damage to information outside normal working hours.	pertaining to application software and sensitive system software are updated to the current time, accurately and stored securely. b. up-to-date inventory list of all documentation is maintained c. all documentation and subsequent changes are reviewed and approved by an independent authorized party prior to issue d. Access to application software documentation and sensitive system software documentation is restricted to authorized personnel on a "need-to-use" basis only e. Adequate backups of all documentation are maintained f. Copy of all critical documents and manuals is stored off site g. Documents are classified according to sensitivity h. Clear Desks policy has been implemented						
--	---	--	--	--	--	--	--	--

3.2.11. Firewalls

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Firewalls							
3.2.11.1	All web servers for access by Internet users shall be isolated from other data and host servers.	1. Obtain the network architecture of the CAs system and check the following: a. Networks that operate at varying security levels are isolated from each other by appropriate firewalls b. internal network of the organization is physically and logically isolated from the Internet	Mandatory	IT CA Rules SCHEDULE II 18			

		and any other external connection by a firewall c. Vulnerability assessment is performed on firewalls prior installation and half yearly thereafter d. All web servers for access by Internet users are isolated from other data and host servers.						
3.2.11.2	Intelligent devices generally known as "Firewalls" shall be used to isolate organization's data network with the external network. Firewall device should also be used to limit network connectivity for unauthorized use.	1. Verify firewalls have been installed to protect the data network and to prevent unauthorized use	Mandatory	IT CA Rules SCHEDULE II 18				
3.2.11.3	Networks that operate at varying security levels shall be isolated from each other by appropriate firewalls. The internal network of the organization shall be physically and logically isolated from the Internet and any other external connection by a firewall.	1. Obtain the network architecture of the CAs system and check the following: a. Networks that operate at varying security levels are isolated from each other by appropriate firewalls b. internal network of the organization is physically and logically isolated from the Internet and any other external connection by a firewall c. Vulnerability assessment is performed on firewalls prior installation and half yearly thereafter d. All web servers for access by Internet users are isolated from other data and host servers.	Mandatory	IT CA Rules SCHEDULE II 18				
3.2.11.4	All firewalls shall be subjected to thorough test for vulnerability prior to being put to use and at least half-yearly thereafter.	1. Obtain the network architecture of the CAs system and check the following: a. Networks that	Mandatory	IT CA Rules SCHEDULE II 18				

		operate at varying security levels are isolated from each other by appropriate firewalls b. internal network of the organization is physically and logically isolated from the Internet and any other external connection by a firewall c. Vulnerability assessment is performed on firewalls prior installation and half yearly thereafter d. All web servers for access by Internet users are isolated from other data and host servers.						
3.2.11.5	All web servers for access by Internet users shall be isolated from other data and host servers.	1. Obtain the network architecture of the CAs system and check the following: a. Networks that operate at varying security levels are isolated from each other by appropriate firewalls b. internal network of the organization is physically and logically isolated from the Internet and any other external connection by a firewall c. Vulnerability assessment is performed on firewalls prior installation and half yearly thereafter d. All web servers for access by Internet users are isolated from other data and host servers.	Mandatory	IT CA Rules SCHEDULE II 18				

3.2.12. Connectivity

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Connectivity							

3.2.12.1	Organization shall establish procedure for allowing connectivity of their computer network or computer system to non-organization computer system or networks. The permission to connect other networks and computer system shall be approved by the Network Administrator and documented	1. Conduct a walkthrough to check the implementation of the following: a. procedure is established for allowing connectivity of CA computer network or computer system to non-organization computer system or networks b. permission to connect other networks and computer system are approved by NetworkAdministrator and documented c. All unused connections and network segments are disconnected from active networks d. suitability of new hardware/software particularly the protocol compatibility is assessed before connecting the same to the CA's network e. Internet access is not allowed to database server/ file server or server hosting sensitive data	Mandatory	IT CA Rules SCHEDULE II 19				
3.2.12.2	All unused connections and network segments should be disconnected from active networks. The computer system/personal computer or outside terminal accessing an organization's host system must adhere to the general system security and access control guidelines	1. Conduct a walkthrough to check the implementation of the following: a. procedure is established for allowing connectivity of CA computer network or computer system to non-organization computer system or networks b. permission to connect other networks and computer system are approved by NetworkAdministrator and documented c. All unused connections and network segments are disconnected from active networks d. suitability of new hardware/software particularly the protocol compatibility is assessed before connecting the same to the CA's network e. Internet access is not	Mandatory	IT CA Rules SCHEDULE II 19				

		allowed to database server/ file server or server hosting sensitive data						
3.2.12.3	The suitability of new hardware/software particularly the protocol compatibility should be assessed before connecting the same to the organization's network.	1. Conduct a walkthrough to check the implementation of the following: a. procedure is established for allowing connectivity of CA computer network or computer system to non-organization computer system or networks b. permission to connect other networks and computer system are approved by NetworkAdministrator and documented c. All unused connections and network segments are disconnected from active networks d. suitability of new hardware/software particularly the protocol compatibility is assessed before connecting the same to the CA's network e. Internet access is not allowed to database server/ file server or server hosting sensitive data	Mandatory	IT CA Rules SCHEDULE II 19				
3.2.12.4	No Internet access should be allowed to database server/ file server or server hosting sensitive data.	1. Conduct a walkthrough to check the implementation of the following: a. procedure is established for allowing connectivity of CA computer network or computer system to non-organization computer system or networks b. permission to connect other networks and computer system are approved by NetworkAdministrator and documented c. All unused connections and network segments are disconnected from active networks	Mandatory	IT CA Rules SCHEDULE II 19				

		d. suitability of new hardware/software particularly the protocol compatibility is assessed before connecting the same to the CA's network e. Internet access is not allowed to database server/ file server or server hosting sensitive data						
--	--	---	--	--	--	--	--	--

3.2.13. Technical Security Controls

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Activation Data							
3.2.13.1	The activation data used to unlock private keys, in conjunction with any other access control, shall have an appropriate level of strength for the keys or data to be protected and shall meet the applicable security policy requirements of the cryptographic module used to store the keys. Activation data may be user selected. If the activation data must be transmitted, it shall be via an appropriately protected channel, and distinct in time and place from the associated cryptographic module	1. Validate the activation data used to unlock private keys have an appropriate level of strength for the keys or data to be protected and meet the applicable security policy requirements of the cryptographic module used to store the keys. 2. Verify data used to unlock private keys is protected from disclosure 3. Check the data used to unlock private keys is protected from disclosure and account gets temporarily locked after a number of failed login attempts 4. Verify activation data is changed whenever the token is re-keyed or returned 5. Validate CA and CSP components are regularly synchronized with IST 6. Check the time derived is used for establishing time of components	Mandatory	X.509 Policy 6.4.1			

		covered in control 3.2.13.4						
3.2.13.2	Data used to unlock private keys shall be protected from disclosure. After a predetermined number of failed login attempts, a facility to temporarily lock the account shall be provided	1. Validate the activation data used to unlock private keys have an appropriate level of strength for the keys or data to be protected and meet the applicable security policy requirements of the cryptographic module used to store the keys. 2. Verify data used to unlock private keys is protected from disclosure 3. Check the data used to unlock private keys is protected from disclosure and account gets temporarily locked after a number of failed login attempts 4. Verify activation data is changed whenever the token is re-keyed or returned 5. Validate CA and CSP components are regularly synchronized with IST 6. Check the time derived is used for establishing time of components covered in control 3.2.13.4	Mandatory	X.509 Policy 6.4.2				
3.2.13.3	CAs, CSPs, shall change the activation data whenever the token is re-keyed or returned from maintenance	1. Validate the activation data used to unlock private keys have an appropriate level of strength for the keys or data to be protected and meet the applicable security policy	Mandatory	X.509 Policy 6.4.3				

		requirements of the cryptographic module used to store the keys. 2. Verify data used to unlock private keys is protected from disclosure 3. Check the data used to unlock private keys is protected from disclosure and account gets temporarily locked after a number of failed login attempts 4. Verify activation data is changed whenever the token is re-keyed or returned 5. Validate CA and CSP components are regularly synchronized with IST 6. Check the time derived is used for establishing time of components covered in control 3.2.13.4						
3.2.13.4	All CA and CSP components shall regularly synchronize with a time service such as Indian Standard Time Service. Time derived from the time service shall be used for establishing the time of: • Initial validity time of a Subscriber's Certificate • Revocation of a Subscriber's Certificate • Posting of CRL updates • OCSP or other CSP responses	1. Validate the activation data used to unlock private keys have an appropriate level of strength for the keys or data to be protected and meet the applicable security policy requirements of the cryptographic module used to store the keys. 2. Verify data used to unlock private keys is protected from disclosure 3. Check the data used to unlock private keys is protected from disclosure and account gets temporarily locked after a number of	Mandatory	X.509 Policy 6.8				

		failed login attempts 4. Verify activation data is changed whenever the token is re-keyed or returned 5. Validate CA and CSP components are regularly synchronized with IST 6. Check the time derived is used for establishing time of components covered in control 3.2.13.4						
--	--	---	--	--	--	--	--	--

3.2.14. Network Communication Security

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Network Communication Security							
3.2.14.1	All sensitive information on the network shall be protected by using appropriate techniques. The critical network devices such as routers, switches and modems should be protected from physical damage	1. Verify the CA network is protected by using appropriate techniques 2. Check physically critical network devices such as routers, switches and modems are protected from physical damage 3. Check the documented network configuration and inventories and verify these are updated regularly 4. For sample changes in the network check the following: a. Network Administrator's approval was taken b. Changes were documented c. Threats and risk assessment after changes in the network configuration is reviewed d. network operation are monitored for any security irregularity e. formal procedure is in place for identifying and resolving security problems 5. Verify the optical fibre in CAs	Mandatory	IT CA Rules SCHEDULE II 17	Yes	3.2.14.1-377	

		operational sir is armored cable to ensure security against 6. electromagnetic transmission 7. Validate CA has provisions to use network diagnostic tools on need basis					
3.2.14.2	The network configuration and inventories shall be documented and maintained.	1. Verify the CA network is protected by using appropriate techniques 2. Check physically critical network devices such as routers, switches and modems are protected from physical damage 3. Check the documented network configuration and inventories and verify these are updated regularly 4. For sample changes in the network check the following: a. Network Administrator's approval was taken b. Changes were documented c. Threats and risk assessment after changes in the network configuration is reviewed d. network operation are monitored for any security irregularity e. formal procedure is in place for identifying and resolving security problems 5. Verify the optical fibre in CAs operational sir is armored cable to ensure security against 6. electromagnetic transmission 7. Validate CA has provisions to use network diagnostic tools on need basis	Mandatory	IT CA Rules SCHEDULE II 17			
3.2.14.3	Prior authorization of the Network Administrator shall be obtained for making any changes to network configuration. The changes made in the network configuration shall be documented. The	1. Verify the CA network is protected by using appropriate techniques 2. Check physically critical network devices such as routers, switches and	Mandatory	IT CA Rules SCHEDULE II 17			

	threat and risk assessment of the network after changes in the network configuration shall be reviewed. The network operation shall be monitored for any security irregularity. A formal procedure should be in place for identifying and resolving security problems.	modems are protected from physical damage 3. Check the documented network configuration and inventories and verify these are updated regularly 4. For sample changes in the network check the following: a. Network Administrator's approval was taken b. Changes were documented c. Threats and risk assessment after changes in the network configuration is reviewed d. network operation are monitored for any security irregularity e. formal procedure is in place for identifying and resolving security problems 5. Verify the optical fibre in CAs operational sir is armored cable to ensure security against 6. electromagnetic transmission 7. Validate CA has provisions to use network diagnostic tools on need basis						
3.2.14.4	As far as possible, transmission medium within the Certifying Authority's operational site should be secured against electromagnetic transmission. In this regard, use of Optical Fibre Cable and armored cable may be preferred as transmission media as the case may be.	1. Verify the CA network is protected by using appropriate techniques 2. Check physically critical network devices such as routers, switches and modems are protected from physical damage 3. Check the documented network configuration and inventories and verify these are updated regularly 4. For sample changes in the network check the following: a. Network Administrator's approval was taken b. Changes were documented c. Threats and risk assessment after changes in the network	Mandatory	IT CA Rules SCHEDULE II 17				

		configuration is reviewed d. network operation are monitored for any security irregularity e. formal procedure is in place for identifying and resolving security problems 5. Verify the optical fibre in CAs operational sir is armored cable to ensure security against 6. electromagnetic transmission 7. Validate CA has provisions to use network diagnostic tools on need basis						
3.2.14.5	Network diagnostic tools, e.g., spectrum analyzer, protocol analyzer should be used on a need basis	1. Verify the CA network is protected by using appropriate techniques 2. Check physically critical network devices such as routers, switches and modems are protected from physical damage 3. Check the documented network configuration and inventories and verify these are updated regularly 4. For sample changes in the network check the following: a. Network Administrator's approval was taken b. Changes were documented c. Threats and risk assessment after changes in the network configuration is reviewed d. network operation are monitored for any security irregularity e. formal procedure is in place for identifying and resolving security problems 5. Verify the optical fibre in CAs operational sir is armored cable to ensure security against 6. electromagnetic transmission 7. Validate CA has provisions to use network diagnostic	Mandatory	IT CA Rules SCHEDULE II 17				

		tools on need basis						
Network Administrator								
3.2.14.6	Each organization shall designate a properly trained "Network Administrator" who will be responsible for operation, monitoring security and functioning of the network.	1. Obtain name of the Network administrator and verify the following: a. Network Administrator is properly trained b. Network Administrator regularly undertakes the review of network and also takes adequate measures to provide physical, logical and procedural safeguards for its security c. Network Administrator promptly investigates unusual activity or pattern of access on the computer network d. Network Administrator is alerted in case of a possible breach	Mandatory	IT CA Rules SCHEDULE II 20				
3.2.14.7	Network Administrator shall regularly undertake the review of network and also take adequate measures to provide physical, logical and procedural safeguards for its security. Appropriate follow up of any unusual activity or pattern of access on the computer network shall be investigated promptly by the Network Administrator	1. Obtain name of the Network administrator and verify the following: a. Network Administrator is properly trained b. Network Administrator regularly undertakes the review of network and also takes adequate measures to provide physical, logical and procedural safeguards for its security c. Network Administrator promptly investigates unusual activity or pattern of access on the computer network d. Network Administrator is alerted in case of a possible breach	Mandatory	IT CA Rules SCHEDULE II 20				

3.2.14.8	System must include a mechanism for alerting the Network Administrator of possible breaches in security, e.g., unauthorized access, virus infection and hacking.	1. Obtain name of the Network administrator and verify the following: a. Network Administrator is properly trained b. Network Administrator regularly undertakes the review of network and also takes adequate measures to provide physical, logical and procedural safeguards for its security c. Network Administrator promptly investigates unusual activity or pattern of access on the computer network d. Network Administrator is alerted in case of a possible breach	Mandatory	IT CA Rules SCHEDULE II 20				
3.2.14.9	Secure Network Management System should be implemented to monitor functioning of the computer network. Broadcast of network traffic should be minimized.	1. Verify secure network management system is implemented to monitor functioning of computer network 2. Validate only authorized and legal software are used on the network 3. Check the shared computer systems, network devices used for business applications comply with the requirement established in 3.1.6	Mandatory	IT CA Rules SCHEDULE II 20				
3.2.14.10	Only authorized and legal software shall be used on the network.	1. Verify secure network management system is implemented to monitor functioning of computer network 2. Validate only authorized and legal software are used on the network 3. Check the shared computer systems, network devices used for business applications comply with the requirement established in 3.1.6	Mandatory	IT CA Rules SCHEDULE II 20				

3.2.14.11	Shared computer systems, network devices used for business applications shall comply with the requirement established in System Integrity and Security Measures (Section 3.1.6).	1. Verify secure network management system is implemented to monitor functioning of computer network 2. Validate only authorized and legal software are used on the network 3. Check the shared computer systems, network devices used for business applications comply with the requirement established in 3.1.6	Mandatory	IT CA Rules SCHEDULE II 20				
3.2.14.12	Network connections from the Certifying Authority's system to external networks shall be restricted to only those connections which are essential to facilitate Certifying Authority's functional processes and services. Such network connections to the external network shall be properly secured and monitored regularly.	1. Understand the network connection process and check the following: a. Network connections for CA's system to external networks are restricted to only essential connections b. Network connection are secured and monitored regularly c. Network connections are initiated by the systems performing the functions of generation and management of DSC to connect those systems performing the registration and repository functions but not vice versa	Mandatory	IT CA Rules SCHEDULE III 8				
3.2.14.13	Network connections should be initiated by the systems performing the functions of generation and management of Digital Signature Certificate to connect those systems performing the registration and repository functions but not vice versa. If this is not possible, compensating controls (e.g. use of proxy servers) shall be implemented to protect the systems performing the function of generation and management of Digital Signature Certificate from potential attacks	1. Understand the network connection process and check the following: a. Network connections for CA's system to external networks are restricted to only essential connections b. Network connection are secured and monitored regularly c. Network connections are initiated by the systems performing the functions of generation and management of DSC to connect those systems performing	Mandatory	IT CA Rules SCHEDULE III 8				

		the registration and repository functions but not vice versa						
3.2.14.14	Systems performing the Digital Signature Certification function should be isolated to minimize their exposure to attempts to compromise the confidentiality, integrity and availability of the certification function.	1. Verify Systems performing the DSC function are isolated to minimize their exposure to attempts to compromise the confidentiality, integrity and availability of the certification function 2. communications between the CA's systems connected on a network should be secured (encrypted and digitally signed) 3. Intrusion detection tools are deployed to monitor critical networks and perimeter networks and alert administrators of network intrusions and penetration attempts in a timely manner	Mandatory	T CA Rules SCHEDULE III 8				
3.2.14.15	Communication between the Certifying Authority systems connected on a network shall be secure to ensure confidentiality and integrity of the information. For example, communications between the Certifying Authority's systems connected on a network should be encrypted and digitally signed	1. Verify Systems performing the DSC function are isolated to minimize their exposure to attempts to compromise the confidentiality, integrity and availability of the certification function 2. communications between the CA's systems connected on a network should be secured (encrypted and digitally signed) 3. Intrusion detection tools are deployed to monitor critical networks and perimeter networks and alert administrators of network intrusions and penetration attempts in a timely manner	Mandatory	IT CA Rules SCHEDULE III 8				
3.2.14.16	Intrusion detection tools should be deployed to monitor critical networks and perimeter networks	1. Verify Systems performing the DSC function are isolated to minimize their	Mandatory	IT CA Rules SCHEDULE III 8				

	and alert administrators of network intrusions and penetration attempts in a timely manner	exposure to attempts to compromise the confidentiality, integrity and availability of the certification function 2. communications between the CA's systems connected on a network should be secured (encrypted and digitally signed) 3. Intrusion detection tools are deployed to monitor critical networks and perimeter networks and alert administrators of network intrusions and penetration attempts in a timely manner						
--	--	---	--	--	--	--	--	--

Date: 2024-12-20

Intent Code: 16832437

Application Number: CCA/CA/20250108/6

For Government Ministry/Department/Agency/Authority

28. Particulars of Organisation: *

Organization Name: Meity

Administrative Ministry/Department: meity

Under State/Central Government: central

Flat/Door/Block No.: abholi

Premises/Building/Village: abholi

City: 1

Pin: 1

Pin: 221404

Pin: 1

Web page URL Address: <https://stackoverflow.com>

Name of the Head of Organisation: ram kumar shatrma

Designation: project Engineer

E-mail Address: sdas@gmail.com

29. Bank Details

Bank Name*: State Bank of India

Branch*: Abholi

Bank Account No.*: 1234578907

Type of Bank Account*: Saving

30. Whether bank draft/pay order for licence fee enclosed: N

32. Public Key @: okk it is done

Form for Application for Grant of Licence to be a Certifying Authority

For Individual

1. Full Name *

Last Name/Surname: Goyal

First Name: ram

Middle Name:

2. Have you ever been known by any other name? Yes

Last Name/Surname: sharma

First Name: raj

Middle Name: kumar

3. Address

A. Residential Address *

Flat/Door/Block No:abholi

Name of Premises/Building/Village:abholi

Road/Street/Lane/Post Office: abholi

Area/Locality/Taluka/Sub-Division: abholi

Town/City/District: 1

State/Union Territory: 1

Pin: 221404

Telephone No:1234567

Fax: 22334546

Mobile Phone No: 7646594789

B. Office Address *

Flat/Door/Block No:abholi

Name of Premises/Building/Village:abholi

Road/Street/Lane/Post Office: abholi

Area/Locality/Taluka/Sub-Division: abholi

Town/City/District: 1

State/Union Territory: 1

Pin: 221305

Telephone No:1234567

Fax: 23234566

Mobile Phone No:

4. Address for Communication *

Tick as applicable:

5. Father's Name *

Last Name/Surname: sharma

First Name: Sohan

Middle Name: kumar

6. Sex (For Individual Applicant Only)*:Male

7. Date Of Birth (dd/mm/yyyy)*:2024-12-14 00:00:00.0

8. Nationality*:Indian

9. Credit Card Details

Credit Card Type:

Credit Card No.:

Issued By:

10. E-mail Address: borogil438@pokeline.com, borogil438@pokeline.com

11. Web URL Address

URL: <https://stackoverflow.com>

12. Passport Details

Passport No.: 123456

Passport Issuing Authority: sumit

Passport Expiry Date (dd/mm/yyyy): 2024-12-28 00:00:00.0

13. Voter's Identity Card No.

Voter ID:

14. Income Tax PAN No.

PAN:

15. ISP Details

ISP Name: abc

ISP's Website Address, if any: <https://stackoverflow.com>

Your User Name at ISP, if any: uccff12356

16. Personal Web Page URL Address, if any

Web Page URL: <https://stackoverflow.com>

17. Capital in the Business or Profession

Capital (in Rs): sadfw2454

Controller of Certifying Authorities (CCA)

Details of the Empanelled Audit Agency

Effective Date: 01/07/2024 to 31/08/2024

* The empanel agency should ensure that the notified team of auditors (as per the records submitted/updated by the agency to the office of CCA) shall only conduct the Audit. The audit conducted by any other person/agency will not be accepted.

** The empanel agency should ensure that, in case of any addition and deletion in the auditor's team during the course of empanelment, the empanel agency is requested to contact O/o CCA before deployment/taking up any new assignment with new person.

Sl. No.	Name & Address of the applicant organisation	Telephone/Mobile Numbers	Email Id	Auditor
1	CCA abholi, abholi, abholi, Yangpu, Shanghai, China - 221404	16-6388956241	sumitsharma5689@gmail.com, raj@gmail.com	Sumit Kumar sharma
2	CCA abholi, abholi, abholi, Sarita Vihar, Delhi, India - 221404	91-6388956241, 6388956241	sumitsharma5689@gmail.com, raj@gmail.com	Sumit Kumar Sharma, Vinay Kumar Sharma

Controller of Certifying Authorities (CCA)

Details of the Empanelled Audit Agency

Effective Date: 01/07/2024 to 31/08/2024

* The empanel agency should ensure that the notified team of auditors (as per the records submitted/updated by the agency to the office of CCA) shall only conduct the Audit. The audit conducted by any other person/agency will not be accepted.

** The empanel agency should ensure that, in case of any addition and deletion in the auditor's team during the course of empanelment, the empanel agency is requested to contact O/o CCA before deployment/taking up any new assignment with new person.

Sl. No.	Name & Address of the applicant organisation	Telephone/Mobile Numbers	Email Id	Auditor
1	CCA abholi, abholi, abholi, Yangpu, Shanghai, China - 221404	16-6388956241	sumitsharma5689@gmail.com, raj@gmail.com	Sumit Kumar sharma
2	CCA abholi, abholi, abholi, Sarita Vihar, Delhi, India - 221404	91-6388956241, 6388956241	sumitsharma5689@gmail.com, raj@gmail.com	Sumit Kumar Sharma, Vinay Kumar Sharma

Controller of Certifying Authorities (CCA)

Report on Audit Agency Details

As on dd.mm.yyyy

Report on Empanelled Audit Agency details under the Controller of Certifying Authorities (CCA)

Sl. No.	Audit Agency Name	Telephone/Mobile Number(s)	Email Id(s)

[Your Name]

[Your Address]

[City, State, ZIP Code]

[Email Address]

[Phone Number]

[Date]

[Client's Name]

[Client's Company Name]

[Client's Address]

[City, State, ZIP Code]

Dear [Client's Name],

Re: Proposal for Converting HTML Web Page to React.js

I hope you're doing well. I understand that you're looking for someone to help convert your existing HTML web page into a dynamic, modern React.js application. I'm confident that I can assist you with this transition, ensuring that your landing page not only retains its current design and functionality but also takes full advantage of the powerful features that React.js offers.

What I Offer:

- Seamless Conversion: I will convert your HTML page into a React.js application, ensuring that all existing features and design elements are preserved while enhancing the performance and scalability of your web page.
- Component-Based Architecture: By breaking down your web page into reusable React

components, I will make your code more organized, maintainable, and easier to extend in the future.

- Improved Performance: React's virtual DOM and optimized rendering process will significantly improve the performance of your landing page, leading to a better user experience.
- Responsive and User-Friendly Design: The converted React page will maintain responsiveness across all devices and screen sizes, ensuring that your users enjoy a seamless experience regardless of how they access your site.

Why Choose React.js?

React.js is a leading JavaScript library for building user interfaces. It allows for fast, scalable, and simple development of web applications. By converting your HTML page to React, you'll benefit from:

- Enhanced User Experience: React's efficient rendering will make your site faster and more responsive.
- Maintainability: The component-based structure makes it easy to maintain and update your site as your needs evolve.
- Scalability: React's modular nature ensures that your site can grow and adapt as your business expands.

Next Steps:

If you choose to move forward, I would need the existing HTML code for review. I will then provide you with a detailed plan for the conversion process, including timelines and any additional recommendations.

Please feel free to share any specific requirements or concerns you may have. I'm excited about the opportunity to work with you on this project and help you achieve your goals.

Looking forward to your response!

Best regards,

[Your Name]

[Your Title]

[Your Contact Information]

Sumit Kumar Sharma

House No 5, DSB House ,Near
GD Goeaka Sarita Vihar, New
Delhi - 110025
sumitsharma5689@gmail.com
Phone-+916388956241

Career Objective:

To work in a dynamic organization which provides growth and opportunities to upgrade my skills and utilize them for the benefit of the organization.

Education:

Post-Graduation Diploma- PG-DAC in Advance Computing from C-DAC Delhi (2022)

Graduation – B.Tech in Computer Science & Engineering from Dr. A.P.J. Abdul Kalam Technical University (AKTU) (2021)

H.S.C. - Science stream (PCM) from Uttar Pradesh State Board (2016)

S.S.C. - Uttar Pradesh State Board (2014)

Skills

Technical Skills	Micro-service , JavaScript, React Js, Java, Spring Boot, Hibernate, RestAPI, Jenkins, Git, GitLab, HTML,CSS.
Database	SQL, PostgreSQL, MySQL,
Tools	VS Code, Spring Tool Suite (STS), IntelliJ, Jira,
Domain	e-Governance, Education, Health - H R
Environment	Development, Test, Production.

Projects:

1. Centre for e-Governance Management for Ministry of Electronics and Information Technology, GoI

Project Description:

This project aimed at developing web application to a supervised manage demonstrations and presentations that reflect the progress achieved in the implementation and usage of e-Governance. It covers successful and high impact e-Gov applications and content based on improved citizen service delivery, innovativeness, cost effectiveness and overall impact in fulfilling developmental objectives of the government.

Technology Used: JavaScript, React Js, Java, Spring Boot, RestAPI, MySQL.

2. Chips to Startup for Ministry of Electronics and Information Technology, GoI

Project Description:

The project aims to develop and maintain the web portal and proposal management system for the department of special manpower development program under the ministry of electronics and information technology, to meet the objective and vision of National Policy on Electronics -2019, an umbrella "Chips to Startup(C2S)" not only aims at developing Specialized Manpower in VLSI/Embedded System but also addresses each entity of the Electronics value chain via Specialized Manpower training, Design of application-oriented Systems and deployment by academia/ R&D organization.

Technology Used: JavaScript, React Js, Java, Spring Boot, RestAPI, PostgreSQL.

3. Training Centre Management System for International Corporation Division, Ministry of External Affairs, GoI

Project Description:

The project aims to develop and maintain the web application for manage Centre of Excellence which is established in various countries outside India. This application is designed for maintain students records and manage Centre working paperless and digitally. In this application students can apply various courses which is provided by Centre and get admitted into course and access various study material and for Centre side will maintain students and faculty, Centre employees' records like attendance, test, assignments, project, placement's, etc.

Technology Used: JavaScript, React Js, Java, Spring Boot, Hibernate, RestAPI, MySQL.

4. Human Resource Information System for National Health Mission, Jharkhand, State Government

Project Description:

The project aims to develop Human Resource Management (HRM, or simply HR) is a function in every organization which is designed to increase employee performance in aligning with employer's strategic objectives. HR is primarily focused on how people are managed within organizations, focusing on systems and policies. HRIS Software saves all the manual efforts and makes organizations' employee data easily accessible with just a click. With HRIS, employees can easily access and update their personal data. HR management software offers the ultimate solution, like Employee desk and Employee self-service, for employee satisfaction

Technology Used: JavaScript, React Js, Java, Spring Boot, Hibernate, RestAPI , Micro Service, PostgreSQL.

Employment History:

1. Centre for Development of Advanced Computing (C-DAC)

July-2022 – Present

Client: Various Ministries under Government of India and Government Related PSU Organizations.

Responsibilities Handled:

- Defining project Requirements through an SRS (Software Requirements Specification)
- Based on the requirements specified in SRS come out with best Architecture for the project to be developed.
- Design Module Preferences, standards and Database Schema according to requirements.
- Design and Develop project setup (frontend and backend) as per requirements.
- Design RESTAPIs as per Jira Stories and design efficient methods for backend processing.
- Design User-friendly and Responsive Front-end as per requirements.
- Test the developed software to maintain quality.
- Make a production ready code to deployed on cloud.

Declaration

I hereby declare that the above information furnished is true to the best of my knowledge and belief.

Sumit Kumar Sharma

Place: New Delhi

Sumit Kumar Sharma

House No 5, DSB House ,Near
GD Goeaka Sarita Vihar, New
Delhi - 110025
sumitsharma5689@gmail.com
Phone-+916388956241

Career Objective:

To work in a dynamic organization which provides growth and opportunities to upgrade my skills and utilize them for the benefit of the organization.

Education:

Post-Graduation Diploma- PG-DAC in Advance Computing from C-DAC Delhi (2022)

Graduation – B.Tech in Computer Science & Engineering from Dr. A.P.J. Abdul Kalam Technical University (AKTU) (2021)

H.S.C. - Science stream (PCM) from Uttar Pradesh State Board (2016)

S.S.C. - Uttar Pradesh State Board (2014)

Skills

Technical Skills	Micro-service , JavaScript, React Js, Java, Spring Boot, Hibernate, RestAPI, Jenkins, Git, GitLab, HTML,CSS.
Database	SQL, PostgreSQL, MySQL,
Tools	VS Code, Spring Tool Suite (STS), IntelliJ, Jira,
Domain	e-Governance, Education, Health - H R
Environment	Development, Test, Production.

Projects:

1. Centre for e-Governance Management for Ministry of Electronics and Information Technology, GoI

Project Description:

This project aimed at developing web application to a supervised manage demonstrations and presentations that reflect the progress achieved in the implementation and usage of e-Governance. It covers successful and high impact e-Gov applications and content based on improved citizen service delivery, innovativeness, cost effectiveness and overall impact in fulfilling developmental objectives of the government.

Technology Used: JavaScript, React Js, Java, Spring Boot, RestAPI, MySQL.

2. Chips to Startup for Ministry of Electronics and Information Technology, GoI

Project Description:

The project aims to develop and maintain the web portal and proposal management system for the department of special manpower development program under the ministry of electronics and information technology, to meet the objective and vision of National Policy on Electronics -2019, an umbrella "Chips to Startup(C2S)" not only aims at developing Specialized Manpower in VLSI/Embedded System but also addresses each entity of the Electronics value chain via Specialized Manpower training, Design of application-oriented Systems and deployment by academia/ R&D organization.

Technology Used: JavaScript, React Js, Java, Spring Boot, RestAPI, PostgreSQL.

3. Training Centre Management System for International Corporation Division, Ministry of External Affairs, GoI

Project Description:

The project aims to develop and maintain the web application for manage Centre of Excellence which is established in various countries outside India. This application is designed for maintain students records and manage Centre working paperless and digitally. In this application students can apply various courses which is provided by Centre and get admitted into course and access various study material and for Centre side will maintain students and faculty, Centre employees' records like attendance, test, assignments, project, placement's, etc.

Technology Used: JavaScript, React Js, Java, Spring Boot, Hibernate, RestAPI, MySQL.

4. Human Resource Information System for National Health Mission, Jharkhand, State Government

Project Description:

The project aims to develop Human Resource Management (HRM, or simply HR) is a function in every organization which is designed to increase employee performance in aligning with employer's strategic objectives. HR is primarily focused on how people are managed within organizations, focusing on systems and policies. HRIS Software saves all the manual efforts and makes organizations' employee data easily accessible with just a click. With HRIS, employees can easily access and update their personal data. HR management software offers the ultimate solution, like Employee desk and Employee self-service, for employee satisfaction

Technology Used: JavaScript, React Js, Java, Spring Boot, Hibernate, RestAPI , Micro Service, PostgreSQL.

Employment History:

1. Centre for Development of Advanced Computing (C-DAC)

July-2022 – Present

Client: Various Ministries under Government of India and Government Related PSU Organizations.

Responsibilities Handled:

- Defining project Requirements through an SRS (Software Requirements Specification)
- Based on the requirements specified in SRS come out with best Architecture for the project to be developed.
- Design Module Preferences, standards and Database Schema according to requirements.
- Design and Develop project setup (frontend and backend) as per requirements.
- Design RESTAPIs as per Jira Stories and design efficient methods for backend processing.
- Design User-friendly and Responsive Front-end as per requirements.
- Test the developed software to maintain quality.
- Make a production ready code to deployed on cloud.

Declaration

I hereby declare that the above information furnished is true to the best of my knowledge and belief.

Sumit Kumar Sharma

Place: New Delhi

Controller of Certifying Authorities (CCA)

Report on Audit Agency Details

As on dd.mm.yyyy

Report on Empanelled Audit Agency details under the Controller of Certifying Authorities (CCA)

Sl. No.	Name & Address of the applicant organisation	Telephone/Mobile Number(s)	Email Id(s)	Auditors

Form for Application for Grant of Licence to be a Certifying Authority

For Individual

1. Full Name *

Last Name/Surname: Goyal

First Name: ram

Middle Name:

2. Have you ever been known by any other name? Yes

Last Name/Surname: sharma

First Name: raj

Middle Name: kumar

3. Address

A. Residential Address *

Flat/Door/Block No:abholi

Name of Premises/Building/Village:abholi

Road/Street/Lane/Post Office: abholi

Area/Locality/Taluka/Sub-Division: abholi

Town/City/District: 1

State/Union Territory: 1

Pin: 221404

Telephone No:1234567

Fax: 22334546

Mobile Phone No: 7646594789

B. Office Address *

Flat/Door/Block No:abholi

Name of Premises/Building/Village:abholi

Road/Street/Lane/Post Office: abholi

Area/Locality/Taluka/Sub-Division: abholi

Town/City/District: 1

State/Union Territory: 1

Pin: 221305

Telephone No:1234567

Fax: 23234566

Mobile Phone No:

4. Address for Communication *

Tick as applicable:

5. Father's Name *

Last Name/Surname: sharma

First Name: Sohan

Middle Name: kumar

6. Sex (For Individual Applicant Only)*:Male

7. Date Of Birth (dd/mm/yyyy)*:2024-12-14 00:00:00.0

8. Nationality*:Indian

9. Credit Card Details

Credit Card Type:

Credit Card No.:

Issued By:

10. E-mail Address: borogil438@pokeline.com, borogil438@pokeline.com

11. Web URL Address

URL: <https://stackoverflow.com>

12. Passport Details

Passport No.: 123456

Passport Issuing Authority: sumit

Passport Expiry Date (dd/mm/yyyy): 2024-12-28 00:00:00.0

13. Voter's Identity Card No.

Voter ID:

14. Income Tax PAN No.

PAN:

15. ISP Details

ISP Name: abc

ISP's Website Address, if any: <https://stackoverflow.com>

Your User Name at ISP, if any: uccff12356

16. Personal Web Page URL Address, if any

Web Page URL: <https://stackoverflow.com>

17. Capital in the Business or Profession

Capital (in Rs): sadfw2454

Controller of Certifying Authorities (CCA)

Details of the Empanelled Audit Agency

Effective Date: 01/07/2024 to 31/08/2024

* The empanel agency should ensure that the notified team of auditors (as per the records submitted/updated by the agency to the office of CCA) shall only conduct the Audit. The audit conducted by any other person/agency will not be accepted.

** The empanel agency should ensure that, in case of any addition and deletion in the auditor's team during the course of empanelment, the empanel agency is requested to contact O/o CCA before deployment/taking up any new assignment with new person.

Sl. No.	Name & Address of the applicant organisation	Telephone/Mobile Numbers	Email Id	Auditor
1	CCA abholi, abholi, abholi, Yangpu, Shanghai, China - 221404	16-6388956241	sumitsharma5689@gmail.com, raj@gmail.com	Sumit Kumar sharma
2	CCA abholi, abholi, abholi, Sarita Vihar, Delhi, India - 221404	91-6388956241, 6388956241	sumitsharma5689@gmail.com, raj@gmail.com	Sumit Kumar Sharma, Vinay Kumar Sharma

Controller of Certifying Authorities (CCA)

Details of the Empanelled Audit Agency

Effective Date: 01/07/2024 to 31/08/2024

* The empanel agency should ensure that the notified team of auditors (as per the records submitted/updated by the agency to the office of CCA) shall only conduct the Audit. The audit conducted by any other person/agency will not be accepted.

** The empanel agency should ensure that, in case of any addition and deletion in the auditor's team during the course of empanelment, the empanel agency is requested to contact O/o CCA before deployment/taking up any new assignment with new person.

Sl. No.	Name & Address of the applicant organisation	Telephone/Mobile Numbers	Email Id	Auditor
1	CCA abholi, abholi, abholi, Yangpu, Shanghai, China - 221404	16-6388956241	sumitsharma5689@gmail.com, raj@gmail.com	Sumit Kumar sharma
2	CCA abholi, abholi, abholi, Sarita Vihar, Delhi, India - 221404	91-6388956241, 6388956241	sumitsharma5689@gmail.com, raj@gmail.com	Sumit Kumar Sharma, Vinay Kumar Sharma

Controller of Certifying Authorities (CCA)

Report on Audit Agency Details

As on dd.mm.yyyy

Report on Empanelled Audit Agency details under the Controller of Certifying Authorities (CCA)

Sl. No.	Audit Agency Name	Telephone/Mobile Number(s)	Email Id(s)

[Your Name]

[Your Address]

[City, State, ZIP Code]

[Email Address]

[Phone Number]

[Date]

[Client's Name]

[Client's Company Name]

[Client's Address]

[City, State, ZIP Code]

Dear [Client's Name],

Re: Proposal for Converting HTML Web Page to React.js

I hope you're doing well. I understand that you're looking for someone to help convert your existing HTML web page into a dynamic, modern React.js application. I'm confident that I can assist you with this transition, ensuring that your landing page not only retains its current design and functionality but also takes full advantage of the powerful features that React.js offers.

What I Offer:

- Seamless Conversion: I will convert your HTML page into a React.js application, ensuring that all existing features and design elements are preserved while enhancing the performance and scalability of your web page.
- Component-Based Architecture: By breaking down your web page into reusable React

components, I will make your code more organized, maintainable, and easier to extend in the future.

- Improved Performance: React's virtual DOM and optimized rendering process will significantly improve the performance of your landing page, leading to a better user experience.
- Responsive and User-Friendly Design: The converted React page will maintain responsiveness across all devices and screen sizes, ensuring that your users enjoy a seamless experience regardless of how they access your site.

Why Choose React.js?

React.js is a leading JavaScript library for building user interfaces. It allows for fast, scalable, and simple development of web applications. By converting your HTML page to React, you'll benefit from:

- Enhanced User Experience: React's efficient rendering will make your site faster and more responsive.
- Maintainability: The component-based structure makes it easy to maintain and update your site as your needs evolve.
- Scalability: React's modular nature ensures that your site can grow and adapt as your business expands.

Next Steps:

If you choose to move forward, I would need the existing HTML code for review. I will then provide you with a detailed plan for the conversion process, including timelines and any additional recommendations.

Please feel free to share any specific requirements or concerns you may have. I'm excited about the opportunity to work with you on this project and help you achieve your goals.

Looking forward to your response!

Best regards,

[Your Name]

[Your Title]

[Your Contact Information]

Sumit Kumar Sharma

House No 5, DSB House ,Near
GD Goeaka Sarita Vihar, New
Delhi - 110025
sumitsharma5689@gmail.com
Phone-+916388956241

Career Objective:

To work in a dynamic organization which provides growth and opportunities to upgrade my skills and utilize them for the benefit of the organization.

Education:

Post-Graduation Diploma- PG-DAC in Advance Computing from C-DAC Delhi (2022)

Graduation – B.Tech in Computer Science & Engineering from Dr. A.P.J. Abdul Kalam Technical University (AKTU) (2021)

H.S.C. - Science stream (PCM) from Uttar Pradesh State Board (2016)

S.S.C. - Uttar Pradesh State Board (2014)

Skills

Technical Skills	Micro-service , JavaScript, React Js, Java, Spring Boot, Hibernate, RestAPI, Jenkins, Git, GitLab, HTML,CSS.
Database	SQL, PostgreSQL, MySQL,
Tools	VS Code, Spring Tool Suite (STS), IntelliJ, Jira,
Domain	e-Governance, Education, Health - H R
Environment	Development, Test, Production.

Projects:

1. Centre for e-Governance Management for Ministry of Electronics and Information Technology, GoI

Project Description:

This project aimed at developing web application to a supervised manage demonstrations and presentations that reflect the progress achieved in the implementation and usage of e-Governance. It covers successful and high impact e-Gov applications and content based on improved citizen service delivery, innovativeness, cost effectiveness and overall impact in fulfilling developmental objectives of the government.

Technology Used: JavaScript, React Js, Java, Spring Boot, RestAPI, MySQL.

2. Chips to Startup for Ministry of Electronics and Information Technology, GoI

Project Description:

The project aims to develop and maintain the web portal and proposal management system for the department of special manpower development program under the ministry of electronics and information technology, to meet the objective and vision of National Policy on Electronics -2019, an umbrella "Chips to Startup(C2S)" not only aims at developing Specialized Manpower in VLSI/Embedded System but also addresses each entity of the Electronics value chain via Specialized Manpower training, Design of application-oriented Systems and deployment by academia/ R&D organization.

Technology Used: JavaScript, React Js, Java, Spring Boot, RestAPI, PostgreSQL.

3. Training Centre Management System for International Corporation Division, Ministry of External Affairs, GoI

Project Description:

The project aims to develop and maintain the web application for manage Centre of Excellence which is established in various countries outside India. This application is designed for maintain students records and manage Centre working paperless and digitally. In this application students can apply various courses which is provided by Centre and get admitted into course and access various study material and for Centre side will maintain students and faculty, Centre employees' records like attendance, test, assignments, project, placement's, etc.

Technology Used: JavaScript, React Js, Java, Spring Boot, Hibernate, RestAPI, MySQL.

4. Human Resource Information System for National Health Mission, Jharkhand, State Government

Project Description:

The project aims to develop Human Resource Management (HRM, or simply HR) is a function in every organization which is designed to increase employee performance in aligning with employer's strategic objectives. HR is primarily focused on how people are managed within organizations, focusing on systems and policies. HRIS Software saves all the manual efforts and makes organizations' employee data easily accessible with just a click. With HRIS, employees can easily access and update their personal data. HR management software offers the ultimate solution, like Employee desk and Employee self-service, for employee satisfaction

Technology Used: JavaScript, React Js, Java, Spring Boot, Hibernate, RestAPI , Micro Service, PostgreSQL.

Employment History:

1. Centre for Development of Advanced Computing (C-DAC)

July-2022 – Present

Client: Various Ministries under Government of India and Government Related PSU Organizations.

Responsibilities Handled:

- Defining project Requirements through an SRS (Software Requirements Specification)
- Based on the requirements specified in SRS come out with best Architecture for the project to be developed.
- Design Module Preferences, standards and Database Schema according to requirements.
- Design and Develop project setup (frontend and backend) as per requirements.
- Design RESTAPIs as per Jira Stories and design efficient methods for backend processing.
- Design User-friendly and Responsive Front-end as per requirements.
- Test the developed software to maintain quality.
- Make a production ready code to deployed on cloud.

Declaration

I hereby declare that the above information furnished is true to the best of my knowledge and belief.

Sumit Kumar Sharma

Place: New Delhi

Sumit Kumar Sharma

House No 5, DSB House ,Near
GD Goeaka Sarita Vihar, New
Delhi - 110025
sumitsharma5689@gmail.com
Phone-+916388956241

Career Objective:

To work in a dynamic organization which provides growth and opportunities to upgrade my skills and utilize them for the benefit of the organization.

Education:

Post-Graduation Diploma- PG-DAC in Advance Computing from C-DAC Delhi (2022)

Graduation – B.Tech in Computer Science & Engineering from Dr. A.P.J. Abdul Kalam Technical University (AKTU) (2021)

H.S.C. - Science stream (PCM) from Uttar Pradesh State Board (2016)

S.S.C. - Uttar Pradesh State Board (2014)

Skills

Technical Skills	Micro-service , JavaScript, React Js, Java, Spring Boot, Hibernate, RestAPI, Jenkins, Git, GitLab, HTML,CSS.
Database	SQL, PostgreSQL, MySQL,
Tools	VS Code, Spring Tool Suite (STS), IntelliJ, Jira,
Domain	e-Governance, Education, Health - H R
Environment	Development, Test, Production.

Projects:

1. Centre for e-Governance Management for Ministry of Electronics and Information Technology, GoI

Project Description:

This project aimed at developing web application to a supervised manage demonstrations and presentations that reflect the progress achieved in the implementation and usage of e-Governance. It covers successful and high impact e-Gov applications and content based on improved citizen service delivery, innovativeness, cost effectiveness and overall impact in fulfilling developmental objectives of the government.

Technology Used: JavaScript, React Js, Java, Spring Boot, RestAPI, MySQL.

2. Chips to Startup for Ministry of Electronics and Information Technology, GoI

Project Description:

The project aims to develop and maintain the web portal and proposal management system for the department of special manpower development program under the ministry of electronics and information technology, to meet the objective and vision of National Policy on Electronics -2019, an umbrella "Chips to Startup(C2S)" not only aims at developing Specialized Manpower in VLSI/Embedded System but also addresses each entity of the Electronics value chain via Specialized Manpower training, Design of application-oriented Systems and deployment by academia/ R&D organization.

Technology Used: JavaScript, React Js, Java, Spring Boot, RestAPI, PostgreSQL.

3. Training Centre Management System for International Corporation Division, Ministry of External Affairs, GoI

Project Description:

The project aims to develop and maintain the web application for manage Centre of Excellence which is established in various countries outside India. This application is designed for maintain students records and manage Centre working paperless and digitally. In this application students can apply various courses which is provided by Centre and get admitted into course and access various study material and for Centre side will maintain students and faculty, Centre employees' records like attendance, test, assignments, project, placement's, etc.

Technology Used: JavaScript, React Js, Java, Spring Boot, Hibernate, RestAPI, MySQL.

4. Human Resource Information System for National Health Mission, Jharkhand, State Government

Project Description:

The project aims to develop Human Resource Management (HRM, or simply HR) is a function in every organization which is designed to increase employee performance in aligning with employer's strategic objectives. HR is primarily focused on how people are managed within organizations, focusing on systems and policies. HRIS Software saves all the manual efforts and makes organizations' employee data easily accessible with just a click. With HRIS, employees can easily access and update their personal data. HR management software offers the ultimate solution, like Employee desk and Employee self-service, for employee satisfaction

Technology Used: JavaScript, React Js, Java, Spring Boot, Hibernate, RestAPI , Micro Service, PostgreSQL.

Employment History:

1. Centre for Development of Advanced Computing (C-DAC)

July-2022 – Present

Client: Various Ministries under Government of India and Government Related PSU Organizations.

Responsibilities Handled:

- Defining project Requirements through an SRS (Software Requirements Specification)
- Based on the requirements specified in SRS come out with best Architecture for the project to be developed.
- Design Module Preferences, standards and Database Schema according to requirements.
- Design and Develop project setup (frontend and backend) as per requirements.
- Design RESTAPIs as per Jira Stories and design efficient methods for backend processing.
- Design User-friendly and Responsive Front-end as per requirements.
- Test the developed software to maintain quality.
- Make a production ready code to deployed on cloud.

Declaration

I hereby declare that the above information furnished is true to the best of my knowledge and belief.

Sumit Kumar Sharma

Place: New Delhi

Controller of Certifying Authorities (CCA)

Report on Audit Agency Details

As on dd.mm.yyyy

Report on Empanelled Audit Agency details under the Controller of Certifying Authorities (CCA)

Sl. No.	Name & Address of the applicant organisation	Telephone/Mobile Number(s)	Email Id(s)	Auditors

For Company/Firm/Body of Individuals/Association of Persons/Local Authority

18. Registration Number*: CDA12345

19. Date of Incorporation/Agreement/Partnership*: 2024-09-29

20. Particulars of Business, if any:

Name of Office: Centre for Development of Advanced Computing

Flat/Door/Block No.: abholi

Name of Premises/Building/Village: abholi

Road/Street/Lane/Post Office: abholi

Area/Locality/Taluka/Sub-Division: abholi

City: 3

Pin: 221404

Country: 1

State: 4

Telephone No.: 6342456433

Fax: 11233564

Web page URL address, if any: cdac.in

No. of Branches: 2

Nature of Business: communication

27. Details of Partners/Members/Directors:

Number of Partners/Members/Directors: 5

1) Details of Partners/Members/Directors:

A. Full Name:

Last Name/Surname: sharma

First Name: Sumit

Middle Name: Kumar

B. Address:

Flat/Door/Block No.: J – 1917

Name of Premises/Building/Village: CR PARK

Road/Street/Lane/Post Office: NEW DELHI

Area/Locality/Taluka/Sub-Division: NEW DELHI

City: 1

Pin: 110019

Country: 1

State: 1

Telephone No.: 6342456433

Fax No.: 112335675

Mobile Phone No.: 6388956241

C. Nationality:

Nationality: Indian

Visa details (if applicable): N/A

D. Passport Details:

Passport No.: 12345678

Passport Issuing Authority: MOE

Passport Expiry Date: 2024-09-22 00:00:00.0

E. Voter's Identity Card No.:

F. Income Tax PAN No.:

G. E-mail Address: sumit@cdac.in

H. Personal Web Page URL, if any:

<https://stackoverflow.com>

27. Authorised Representative:

Name: Your Authorised Representative Name here

Address:

Location information and AddressDTOs can be included here based on filteredAppLocations and addressDTOList.

Short Attendance Regularization

Name:

Emp:

Month

Date	Time In	Time Out	Short Attendance in Hours & Minutes	Reason for Short Attendance	Remarks

Signature of Member

Name

Signature of FLA

Name

For Company/Firm/Body of Individuals/Association of Persons/Local Authority

18. Registration Number*: CDA12345

19. Date of Incorporation/Agreement/Partnership*: 2024-09-29

20. Particulars of Business, if any:

Name of Office: Centre for Development of Advanced Computing

Flat/Door/Block No.: abholi

Name of Premises/Building/Village: abholi

Road/Street/Lane/Post Office: abholi

Area/Locality/Taluka/Sub-Division: abholi

City: 3

Pin: 221404

Country: 1

State: 4

Telephone No.: 6342456433

Fax: 11233564

Web page URL address, if any: cdac.in

No. of Branches: 2

Nature of Business: communication

Short Attendance Regularization

Name:

Emp:

Month

Date	Time In	Time Out	Short Attendance in Hours & Minutes	Reason for Short Attendance	Remarks

Signature of Member

Name

Signature of FLA

Name

For Company/Firm/Body of Individuals/Association of Persons/Local Authority

18. Registration Number*: CDA12345

19. Date of Incorporation/Agreement/Partnership*: 2024-09-29

20. Particulars of Business, if any:

Name of Office: Centre for Development of Advanced Computing

Flat/Door/Block No.: abholi

Name of Premises/Building/Village: abholi

Road/Street/Lane/Post Office: abholi

Area/Locality/Taluka/Sub-Division: abholi

City: 3

Pin: 221404

Country: 1

State: 4

Telephone No.: 6342456433

Fax: 11233564

Web page URL address, if any: cdac.in

No. of Branches: 2

Nature of Business: communication

27. Details of Partners/Members/Directors:

Number of Partners/Members/Directors: 5

1) Details of Partners/Members/Directors:

A. Full Name:

Last Name/Surname: sharma

First Name: Sumit

Middle Name: Kumar

B. Address:

Flat/Door/Block No.: J – 1917

Name of Premises/Building/Village: CR PARK

Road/Street/Lane/Post Office: NEW DELHI

Area/Locality/Taluka/Sub-Division: NEW DELHI

City: 1

Pin: 110019

Country: 1

State: 1

Telephone No.: 6342456433

Fax No.: 112335675

Mobile Phone No.: 6388956241

C. Nationality:

Nationality: Indian

Visa details (if applicable): N/A

D. Passport Details:

Passport No.: 12345678

Passport Issuing Authority: MOE

Passport Expiry Date: 2024-09-22 00:00:00.0

E. Voter's Identity Card No.:

F. Income Tax PAN No.:

G. E-mail Address: sumit@cdac.in

H. Personal Web Page URL, if any:

<https://stackoverflow.com>

27. Authorised Representative:

Name: Your Authorised Representative Name here

Address:

Location information and AddressDTOs can be included here based on filteredAppLocations and addressDTOList.

Short Attendance Regularization

Name:

Emp:

Month

Date	Time In	Time Out	Short Attendance in Hours & Minutes	Reason for Short Attendance	Remarks

Signature of Member

Name

Signature of FLA

Name